SHIVA ZEN

Sistema de Gestão para Clínica de Estética

Jaqueline Aranha Estética

Documentação Técnica do Projeto
Requisitos, Modelagem UML, Arquitetura e Implantação

Versão 3.2 | 29/10/2026

Sumário

1. Introdução 4
1.1 Objetivo do documento 4
1.2 Contexto e problema 4
1.3 Escopo 4
1.4 Números do projeto 4
2. Visão Geral da Solução 5
2.1 Tecnologias 5
2.2 Perfis de acesso 5
3. Atores do Sistema 6
4. Requisitos Funcionais 7
5. Requisitos Não Funcionais 10
6. Regras de Negócio 12
7. Casos de Uso 19
7.1 Especificação dos casos de uso 26
8. Modelo de Domínio (Diagramas de Classes) 31
8.1 Dicionário de entidades 36
9. Camada de Serviços (Casos de Uso da Aplicação) 40
9.1 Responsabilidade de cada serviço 45
10. Diagramas de Estados 47
10.1 Tabela de transições do atendimento 52
10.2 Efeitos automáticos 52
11. Diagramas de Sequência 54
11.1 Passo a passo do agendamento online 63
12. Diagramas de Atividades 64
13. Arquitetura 67
13.1 Componentes 68
13.2 Integrações externas 69
13.3 Decisões de arquitetura (ADR) 70
14. Modelo de Dados 75
14.1 Lógica no banco 82
15. Segurança e Conformidade com a LGPD 83

15.1 Segurança da aplicação 83
15.2 LGPD 83
16. Qualidade e Testes 84
17. Implantação e Operação 87
17.1 Rotinas (cron) 89
18. Rotas 90
19. API (OpenAPI 3.1) 92
19.1 Contrato das respostas 92
19.2 Autenticação 92
19.3 Operações 92
Glossário 94
Histórico de Versões 95

1. Introdução

1.1 Objetivo do documento

Este documento descreve de forma completa o sistema Shiva Zen — plataforma web de gestão da clínica de estética Jaqueline Aranha: requisitos funcionais e não funcionais, regras de negócio, a modelagem UML (casos de uso, classes, sequência, estados, atividades, componentes e implantação), o modelo de dados, a arquitetura, a segurança e a conformidade com a LGPD, a estratégia de qualidade e o roteiro de implantação. O conteúdo é derivado do código-fonte: os diagramas de classes e de dados são gerados a partir dos models do Django e as contagens são lidas do repositório na geração do documento.

1.2 Contexto e problema

A clínica atendia por WhatsApp e agenda de papel: horários perdidos, faltas sem controle, pacotes de sessões anotados à mão, comissões calculadas em planilha e nenhum registro formal de consentimento para dados de saúde. O sistema substitui esse fluxo por um agendamento online com confirmação de celular, uma agenda única para a equipe, o controle de pacotes e de comissões em livro-razão, o prontuário com histórico e a prova de cada aceite exigido pela LGPD.

1.3 Escopo

Site público com catálogo, promoções e agendamento online (a cliente não tem senha: prova o celular por código SMS); área "Meus agendamentos" (acompanhar, cancelar e remarcar); links individuais para confirmar presença, avaliar o atendimento (NPS), responder a ficha de anamnese e aceitar termos; portal da profissional; painel administrativo (agenda, aprovação de pedidos, agendamento pela recepção, clientes e prontuário, catálogo, pacotes, promoções, comissões, financeiro, NPS, termos, formulários, usuários, configurações e auditoria); rotinas automáticas disparadas por cron (fila de e-mail, lembretes, NPS, pacotes, expiração de pedidos, retenção LGPD) e integrações (SMS, WhatsApp, e-mail, push, captcha e monitoramento de erros).

1.4 Números do projeto

Item	Quantidade
Entidades (tabelas do domínio)	38
Migrations do banco	78
Testes automatizados	2078
Requisitos funcionais	47
Requisitos não funcionais	23
Regras de negócio catalogadas	57
Casos de uso especificados	33
Rotas HTTP	34

2. Visão Geral da Solução

2.1 Tecnologias

Camada	Tecnologia	Uso
Back-end	Python 3.12, Django 5.2	Monólito renderizado no servidor; regras nos serviços
Banco de dados	PostgreSQL 18	Constraints, EXCLUDE, triggers, procedures e views
Front-end	Vite, Tailwind CSS 4, Alpine.js (CSP), django-cotton, FullCalendar e Chart.js (npm)	Design system único (tokens claro/escuro, componentes), sem CDN, PWA
Servidor	gunicorn + WhiteNoise em Docker	Contêiner não-root, estáticos com hash
Hospedagem	Railway	Ambiente de produção (main) e de testes (dev)
Autenticação	Django auth + django-otp (TOTP) + django-axes	Equipe com 2FA obrigatório
Mensageria	Resend (anymail), Zenvia, WhatsApp Cloud API, Web Push	E-mail, SMS do OTP, lembretes, push
Qualidade	Django test runner, ruff, mypy, import-linter, Playwright, axe-core, pip-audit	CI com 9 jobs

2.2 Perfis de acesso

Três perfis usam o sistema: a cliente (sem senha, identificada pelo celular verificado por SMS), a profissional (portal próprio, com 2FA) e a administradora (dona/recepção, painel completo, com 2FA). O agendador externo (cron) é um ator de sistema autenticado por token.

3. Atores do Sistema

Ator	Descrição
Visitante / Cliente (público, sem login)	Navega no site e agenda sem conta: a identidade é o celular, confirmado por código SMS em todo agendamento. Aceita a Política de Privacidade, o consentimento para dado de saúde e os termos do procedimento, escolhe as autorizações de comunicação, entra na lista de espera e responde NPS por link. Precisa ter 18 anos ou mais.
Cliente cadastrada	Cliente com cadastro ativo (mesmo celular). Entra em "Meus agendamentos" por celular ou e-mail (o código vai ao celular do cadastro) ou direto ao fim do agendamento online, reagenda (até 24 h antes) e cancela pela sessão do portal (com menos de 24 h de horário aprovado conta falta), confirma presença pelo link do lembrete D-1, aceita termos pendentes e exerce os direitos LGPD (preferências, revogação do consentimento de saúde, pedido de correção/exclusão, exportar dados sem a ficha de saúde, descadastrar).
Profissional	Usuário PROFISSIONAL vinculado a um profissional ativo, com 2FA obrigatório em produção. Usa o portal /profissional/: agenda própria, aprova/rejeita os próprios pedidos, marca realizado (com termo aceito ou override auditado), anota a sessão e lê a ficha só das clientes com vínculo. Gera o link do feed iCal, ativa o push e consulta as próprias comissões.
Administrador (ADMIN)	Usuário ADMIN (is_staff), com 2FA obrigatório. Painel completo, incluindo as tarefas de recepção: agenda, agendamento interno, aprovação, clientes, autorizações de comunicação e prontuário, profissionais e exceções de agenda, catálogo, pacotes, promoções, financeiro, comissões, NPS e depoimentos, lista de espera, formulários e termos, usuários, configurações, Branding e auditoria.
Sistema / Cron externo	Serviço Cron do Railway (rodar_jobs_devidos a cada 15 min, horários na JOB_AGENDA) ou agendador externo que chama POST /cron/run/<job>/ com o header X-Cron-Token, ou o comando rodar_job no servidor: fila de e-mail, lembrete D-1, sem desfecho, NPS, alerta de detrator, pacotes, aniversário, limpeza de status, retenção LGPD, housekeeping e feriados. Sem Celery.
Serviços externos	Zenvia (SMS/OTP e status de entrega), WhatsApp Cloud API (lembrete, NPS, aviso de vaga e respostas — nota e "PARAR" — via webhook assinado), provedor de e-mail, Cloudflare Turnstile e Sentry.

4. Requisitos Funcionais

ID	Ator	Descrição
RF01	Cliente (público)	Consultar serviços, equipe, promoções (com o mesmo preço do agendamento), galeria e depoimentos autorizados.
RF02	Cliente (público)	Agendar online escolhendo procedimento, data/horário e profissional, confirmando o celular com código SMS (até 3 horários futuros ativos pelo site); em dia sem horário, pedir aviso de vaga já preenchido.
RF03	Cliente (público)	No agendamento, aceitar a Política de Privacidade e os termos do procedimento, consentir o uso do dado de saúde (termo SAÚDE), escolher as autorizações de comunicação e responder a ficha de anamnese.
RF04	Cliente (público)	Acessar "Meus agendamentos" com celular ou e-mail cadastrado (código sempre ao celular) — ou direto ao fim do agendamento online, sem novo SMS — e ver agendamentos futuros e passados, retornos a combinar e o código de indicação; sair só por POST.
RF05	Cliente (público)	Reagendar um atendimento até 24 h antes pelo portal, escolhendo novo horário disponível.
RF06	Cliente (público)	Cancelar um atendimento futuro pelo portal, com o aviso de que, com menos de 24 h de um horário aprovado, o cancelamento conta como falta.
RF07	Cliente (público)	Confirmar presença ou cancelar pelo link do lembrete D-1 (WhatsApp ou e-mail), com o mesmo aviso de cancelamento tardio.
RF08	Cliente (público)	Aceitar termos pendentes pelo link do atendimento.
RF09	Cliente (público)	Entrar na lista de espera sem criar cadastro (nome, celular, procedimento, data, turno e profissional opcionais; captcha, honeypot e limite diário por IP) e, com o celular verificado, receber o aviso de vaga por e-mail/WhatsApp, continuando na fila até a data passar ou agendar.
RF10	Cliente (público)	Responder o NPS (0–10) e autorizar a publicação do depoimento.
RF11	Cliente (público)	Responder ficha de anamnese por link, com consentimento para dado de saúde.
RF12	Cliente (público)	Baixar os próprios dados (DSAR, sem a ficha de saúde) com código SMS em "Meus dados", descadastrar-se de marketing e pesquisas por link e parar as mensagens de WhatsApp respondendo "PARAR".
RF13	Sistema	Oferecer o WhatsApp da clínica como caminho de agendamento quando o SMS não estiver disponível.
RF14	Equipe	Entrar com e-mail e senha, cadastrar e validar 2FA (obrigatório para ADMIN e PROFISSIONAL em produção), gerar códigos de backup e redefinir a senha por link.
RF15	ADMIN	Aprovar ou rejeitar pedidos PENDENTES (individual ou em lote, item a item: o que outra tela decidiu fica de fora sem desfazer os outros), com e-mail à cliente.
RF16	ADMIN (recepção)	Agendar pelo painel para cliente existente ou nova (cadastrada na mesma transação), com os horários do mesmo cálculo do site, valor do dia ou combinado e e-mail de confirmação à cliente.
RF17	ADMIN	Operar a agenda: lista com filtros por dia e marcadores em lote, seletor de status só para AGENDADO/CONFIRMADO (Realizado e Faltou só a partir do início), calendário com arrastar-e-soltar (motivo detalhado da recusa), valor cobrado, link do termo, override "Realizado sem termo aceito", desfazer realização e o botão "Agendar retorno" quando o retorno é devido.
RF18	Profissional	Usar o portal: agenda do dia/semana, pedidos pendentes (aprovar/rejeitar), marcar realizado, anotar a sessão, ver alertas de saúde e a ficha das clientes com vínculo, ativar push (novo agendamento, cliente cancelou/remarcou, atendimentos sem desfecho).
RF19	ADMIN / Profissional	Registrar e consultar o prontuário (com as perguntas do formulário PRONTUARIO) e o histórico de versões, e anotar as sessões.
RF20	ADMIN	Gerir clientes: busca sem acento, ficha com alertas, pacotes, histórico, autorizações de comunicação e edição validada (telefone/CPF/e-mail únicos).
RF21	ADMIN	Gerir profissionais (grade semanal, exceções — folga, horário diferente, bloqueio —, antecedências, novo link do feed iCal), procedimentos, preços (vigência nova

		a partir de hoje), habilitações e bloqueios de agenda (inclusive para todos os profissionais). Desativar a profissional revoga o feed iCal dela; edição que deixaria atendimento futuro sem quem atenda é recusada.
RF22	ADMIN	Gerir pacotes: criar/editar o catálogo, vender (itens congelados na venda), acompanhar saldo e validade, cancelar com valor devolvido (reembolso no mês do cancelamento) e prorrogar a validade.
RF23	ADMIN	Gerir promoções e disparar o e-mail da promoção (período dos atendimentos) em lotes, uma vez, para clientes com consentimento; reenviar só com confirmação.
RF24	ADMIN	Acompanhar dashboard e financeiro por competência mensal (?mes=: faturamento de avulsos + vendas de pacote − reembolsos do mês, faltas, rankings, últimos 12 meses), comissões em livro-razão (créditos com base e percentual, pagamentos, estornos e saldo por profissional), pagar uma comissão ou o repasse em lote com recibo para imprimir e exportar o Excel gerencial do mês.
RF25	ADMIN	Acompanhar o NPS e aprovar ou retirar depoimentos do site.
RF26	ADMIN	Ver a lista de espera (inclusive as inscrições anônimas, com nome e celular de contato) e avisar manualmente uma vaga: e-mail quando há destino e o aviso registrado mesmo sem e-mail.
RF27	ADMIN	Gerir formulários (anamnese, pesquisa e perguntas do prontuário) e termos versionados (LGPD, saúde, procedimento), e acompanhar a conformidade dos aceites.
RF28	ADMIN	Gerir usuários da equipe (sem trancar a equipe fora; desligamento revoga o feed iCal), as regras operacionais (registro tipado: e-mail do alerta, faltas para pausar o online e anos de experiência do site), a identidade visual (contatos e marca), notificações, pré-visualizar e-mails e consultar a auditoria.
RF29	Sistema	Executar os jobs periódicos pela agenda única (serviço Cron com rodar_jobs_devidos, cron HTTP autenticado ou rodar_job; job de mensagem no máximo 1×/dia): fila de e-mail, lembrete D-1 (WhatsApp ou e-mail), atendimentos sem desfecho, NPS, alerta de detrator, pacotes, aniversário, limpeza de status, retenção LGPD, housekeeping e feriados.
RF30	Sistema	Deixar o retorno gratuito devido (janela em dias) quando o procedimento exige, para a recepção marcar com a cliente — o sistema não reserva horário sozinho.
RF31	Sistema	Ao mudar o status do atendimento, aplicar na mesma transação: débito de sessão de pacote, comissão (crédito/estorno), cashback, faltas, retorno e aviso à lista de espera.
RF32	Sistema externo	Receber webhooks do WhatsApp (resposta de NPS e pedido de "PARAR") e da Zenvia (status de SMS), autenticados (assinatura da Meta; segredo no header e/ou IP permitido na Zenvia), em tempo constante.
RF33	ADMIN	Na ficha da cliente, ver as autorizações de comunicação por canal, revogá-las a pedido e registrar autorização com justificativa (histórico preservado).
RF34	Profissional	Gerar o link do feed iCal da própria agenda (exibido uma única vez).
RF35	Sistema	Enfileirar os e-mails transacionais (inclusive o lembrete D-1) na própria notificação e reenviá-los com espera crescente até 5 tentativas.
RF36	Sistema	Registrar automaticamente, por trigger, toda alteração das tabelas sensíveis com autor, IP e origem.
RF37	ADMIN	Gerir as regras de comissão no painel (percentual XOR valor fixo, por profissional e/ou procedimento, com a especificidade e o número de usos à vista); regra já usada só é desativada.
RF38	Profissional	Consultar "Minhas comissões" do mês: cada crédito com a base e a regra, o status e o saldo a receber, sem nome de cliente (só leitura).
RF39	Cliente (público)	Em "Meus agendamentos", mudar as próprias preferências de comunicação (promoções por e-mail, lembrete e pesquisa por WhatsApp), com o estado vigente à vista e o registro com origem PORTAL.
RF40	Cliente (público) / ADMIN	Revogar o consentimento de dado de saúde pelo portal (ou a equipe, a pedido, pelo Django admin com motivo), com trilha e o aviso de que a ficha feita fica pelo prazo de guarda.

RF41	Cliente (público)	Pedir correção ou exclusão dos dados pelo portal: o pedido fica na auditoria com o prazo de resposta (15 dias) e vai por e-mail à clínica (encarregado > e-mail do administrador > e-mail da marca).
RF42	Cliente (público)	Baixar os próprios dados pelo portal (sem a ficha de saúde), exigindo código confirmado há até 10 minutos.
RF43	Cliente (público)	Enviar mensagem pelo formulário de contato, com aceite da política, captcha, honeypot, 5/min e 20/dia por IP e teto diário global; sem caixa de marketing; se o e-mail não sair, a página mantém o texto e oferece o WhatsApp.
RF44	Sistema	Exibir a Política de Privacidade a partir do termo LGPD vigente (texto, versão e vigência), emoldurado pela identificação da clínica e do encarregado.
RF45	Sistema	Registrar na auditoria a leitura de alertas de saúde na agenda e na visão geral do painel ("Leu alertas de saúde", sem nome de cliente).
RF46	Sistema	Mostrar no site público só números com dado real — nota média do NPS (com 10+ respostas), clientes atendidas (a partir de 50, arredondadas para baixo), tratamentos agendáveis online e anos de experiência informados pela clínica —, escondendo o que não atinge o mínimo.
RF47	Cliente (público)	Consultar as perguntas frequentes por categoria na página /duvidas/ (agendamento, pagamentos e pacotes, tratamentos, privacidade e dados), com respostas geradas das regras que o sistema aplica; a página inicial mostra as 5 em destaque e leva para a lista completa.

5. Requisitos Não Funcionais

ID	Categoria	Descrição
RNF01	Segurança	Content-Security-Policy com nonce por request, sem unsafe-inline em script-src/style-src e sem handlers inline; nenhum CDN (bibliotecas de terceiros pelo npm, no bundle do Vite; o único host externo de script é o captcha); frame-ancestors none (exceto o widget).
RNF02	Segurança	HTTPS obrigatório com HSTS de 1 ano (preload), X-Frame-Options DENY, nosniff, COOP/CORP, Permissions-Policy e cookies HttpOnly/SameSite/Secure.
RNF03	Segurança	2FA TOTP obrigatório para ADMIN e PROFISSIONAL em produção, conferido a cada request no painel, portal, Django admin e push; códigos de backup; sem tela de login paralela; recuperação só por comando no servidor.
RNF04	Segurança	OTP com HMAC-SHA256 (OTP_HMAC_KEY ou a SECRET_KEY), comparação em tempo constante, 5 tentativas, propósitos isolados, desafio preso ao telefone e latência mínima no pedido de código do portal e do "Meus dados" (a resposta não revela, nem pelo tempo, quem é cliente).
RNF05	Segurança	Rate-limit em camadas: cotas de SMS (telefone, IP, global), limites por IP nos endpoints e formulários públicos (lista de espera, contato com teto diário global, "Meus dados" também por telefone), 30 ações de escrita por minuto por usuário na agenda do painel, django-axes no login; captcha Turnstile no pedido de código, no contato e na lista de espera; honeypot nos formulários sem login.
RNF06	Privacidade	Áreas privadas sem cache no navegador (no-store), Referrer-Policy no-referrer nas rotas com token, X-Robots-Tag noindex nas privadas, Clear-Site-Data no logout; links públicos guardam só o SHA-256 do token; tokens, e-mail, CPF e telefone redigidos no access log, no log da aplicação e no Sentry.
RNF07	Segurança	Segredos só em variáveis de ambiente, lidas e validadas só nos settings (ruff TID251; .env.example conferido contra o código); SECRET_KEY obrigatória fora de DEBUG; DJANGO_ENV inválido derruba o boot; system checks aranha.W001–W016 apontam configuração de produção faltando e os erros E001–E004 (sem chave de cifragem, sem Postgres, segredo fraco, OTP acima do teto do banco) barram o pre-deploy.
RNF08	Confiabilidade	Canais de mensagem falham fechado: sem credencial nada é enviado nem marcado como enviado; I/O externo só após o commit; e-mail transacional em fila no banco com reenvio (sem Celery, nada roda em segundo plano sem rastro).
RNF09	LGPD	Autorizações de comunicação por finalidade × canal em histórico append-only (texto exibido, IP, navegador, autor); aceite da política, do termo de saúde (art. 11) e dos termos do procedimento com prova (IP, navegador, SHA-256).
RNF10	LGPD	Retenção automatizada (OTP, notificações, auditoria, trilha, links, logs de login, clientes inativas/excluídas, fichas de pedidos não realizados, lista de espera, registro de saúde aos 20 anos do último evento, pacote 5 anos após o fim) e esquecimento por pseudonimização, executados por procedures do Postgres; prazos LGPD fixos no settings e conferidos contra o texto publicado (aranha.W016); inventário LGPD coluna a coluna conferido por teste.
RNF11	LGPD	Direitos do titular pela área da cliente: acesso/portabilidade (JSON sem a ficha de saúde), pedido de correção ou exclusão com prazo, preferências e revogação de consentimento (inclusive o de saúde), e pseudonimização pela clínica.
RNF12	LGPD	Trilha de auditoria (log_auditoria) e trilha de dados (historico_alteracao, por trigger) com autor, IP e origem, ambas append-only no banco; a leitura de alerta de saúde nas listas do painel também vai para a auditoria; PII mascarada em logs e no Sentry (send_default_pii=False).
RNF13	Integridade	Invariantes no banco: EXCLUDE (atendimento, grade, folgas), UNIQUE parciais, CHECKs, 47 triggers (atualizado_em, imutabilidade de ledgers, prova de aceite, termo aceito, prontuário, anotação, item de pacote, consentimento e link; validação de consumo, de comissão e da regra de comissão usada) e FKs PROTECT no histórico clínico/financeiro.
RNF14	Confiabilidade	Migrações aplicadas numa transação única com lock_timeout no pre-deploy (tudo ou nada); data migrations com pré-checagem que aborta listando os registros;

		rollback de produção por restauração do backup.
RNF15	Confiabilidade	FSM com transições validadas sob lock e auditadas; efeitos explícitos (services/atendimento) na mesma transação do status; efeitos idempotentes (1 retorno por origem, 1 consumo e 1 crédito de comissão ativo por atendimento, job de mensagem 1×/dia, cashback único).
RNF16	Desempenho	gunicorn 1 worker × 4 threads com cache local (Redis opcional para escalar); estáticos comprimidos e com hash (WhiteNoise); índices das consultas reais, busca trigram sem acento, alertas de saúde em lote, statement_timeout na conexão e consultas lentas pelo pg_stat_statements.
RNF17	Observabilidade	Healthchecks /healthz/ (liveness + build do front) e /health/ (banco, cache, front); Sentry opcional; logs JSON em produção; jobs devolvem 500 (cron HTTP) ou exit 1 (serviço Cron) quando falham e avisam o monitor (CRON_MONITOR_URL).
RNF18	Qualidade	Cerca de 2.020 testes automatizados em 124 arquivos, num runner só (manage.py test); CI com SQLite, Postgres 18 (conformidade do padrão SQL, trilha e paridade das funções com o Python), data migrations em paralelo, build do front, wizard e painel no Chromium (Playwright), varredura visual de todas as rotas (desktop claro e celular escuro: erros de página, JS e CSP, rolagem lateral e acessibilidade pelo axe-core), imagem Docker com smoke do pre-deploy e do start, pip-audit, npm audit e gitleaks bloqueantes; ruff, import-linter, mypy nos services e cobertura combinada (SQLite + Postgres) com catraca (≈ 87 %).
RNF19	Usabilidade	Interface pt-BR em tom de estética e bem-estar, em caixa de frase; contraste AA nos tokens, foco visível, formulários acessíveis, diálogos nativos e respeito a prefers-reduced-motion; telas da equipe num design system de componentes (texto base de 15px, nada abaixo de 12px, abas acessíveis, tabela que vira cartões no celular); wizard com as etapas visíveis e botão Continuar fixo no celular, operável por teclado; tema claro/escuro automático; fontes locais; fotos responsivas (WebP com JPEG de reserva, dimensões reservadas); PWA instalável para o site e para a equipe.
RNF20	Manutenibilidade	Camadas views → services/utils → models e áreas de views independentes verificadas por import-linter; fontes únicas (services/agenda, services/atendimento, SlotService, preços, Branding, termos, consentimentos); recusas tipadas (RegraDeNegocio); contrato JSON único (utils/respostas) e telefone numa fonte só (utils/telefone); Django Forms no painel; componentes cotton e Alpine CSP; textos que também são regra (política de privacidade, FAQ) gerados das constantes (conteudo/); documentação viva e requisitos gerados a partir de dados versionados.
RNF21	Implantação	Imagem Docker multi-stage (Node para o front, Python para a app) com dependências fixadas (requirements.lock), usuário não-root sem shell, código só leitura, sem curl e healthcheck; deploy no Railway com pre-deploy de migração e criação do ADMIN e um serviço Cron para os jobs.
RNF22	Privacidade	Dado de saúde cifrado em repouso na aplicação (Fernet, CHAVES_CIFRAGEM com subchave por finalidade e rotação por comando): dump ou backup sem a chave não expõe a ficha.
RNF23	Manutenibilidade	Padrão SQL em todas as tabelas (nomes snake_case PT-BR, prefixos pk_/fk_/uq_/ck_/ix_/ex_/tg_/fn_, ON DELETE real, COMMENT em toda tabela, defaults no banco), conferido por teste no pg_catalog.

6. Regras de Negócio

ID	Título	Descrição
RN01	Papéis da equipe	Usuario.papel = ADMIN ou PROFISSIONAL (CHECK; o RECEPCAO saiu na 0072). ADMIN (is_staff) tem o painel completo, inclusive a recepção; PROFISSIONAL vinculado a um profissional ativo usa o portal /profissional/. A cliente nunca é usuária.
RN02	Identidade da cliente pelo celular	A cliente não tem conta nem senha: a identidade é o telefone (só dígitos, 10–11, sem DDI), único entre clientes ativos (UNIQUE parcial). E-mail e CPF são opcionais e também únicos entre ativos. O e-mail digitado nunca é identidade. Cadastro mínimo: CPF, CEP e endereço só pela finalidade (nota fiscal e contrato de pacote); RG, profissão e foto não são coletados. O telefone tem uma forma canônica só (utils/telefone).
RN03	Idade mínima	O agendamento online exige data de nascimento e idade mínima de 18 anos.
RN04	Bloqueio online por faltas	Cada falta — e cada cancelamento tardio da própria cliente (RN52) — soma em faltas_consecutivas; ao atingir o limite (regra operacional MAX_FALTAS_BLOQUEIO, inteiro de 1 a 10, padrão 3; valor não numérico ou menor que 1 gravado por fora da tela vale como 3) a cliente fica bloqueada para agendar online — decisão automatizada: o wizard diz o motivo e o caminho de revisão (WhatsApp; LGPD art. 20). Comparecer (REALIZADO) zera o contador e desbloqueia. A clínica ainda pode agendar pelo painel.
RN05	Exclusão lógica da cliente	Excluir cliente é soft delete (deletado_em); exclusão física só explícita. A pseudonimização segue a RN40/RN41.
RN06	Fluxo do agendamento público	Procedimento → data/horário → dados + código SMS → confirmar, num caso de uso só (services/agendamento_online.solicitar; o form confere o OTP e a view só liga os dois). O servidor revalida tudo no confirmar: termo LGPD vigente, procedimento/profissional ativos, habilitação, data futura, feriado, slot livre para a duração inteira, fichas e aceites; cada recusa tem um código. A ficha obrigatória respondida nos 12 meses anteriores ao horário não é exigida de novo (só a pendente ou vencida); "Atualizar" uma ficha em dia ou opcional grava uma resposta nova. Dia sem horário livre oferece "Avise-me se vagar" (lista de espera já preenchida). Sem provedor de SMS o agendamento online fica indisponível e o botão Agendar leva ao WhatsApp.
RN07	Antecedência mínima	Por profissional: min_notice_horas (padrão 2 h, faixa 0–720).
RN08	Antecedência máxima	Por profissional: max_advance_dias (padrão 60 dias, faixa 1–365). Não há teto global.
RN09	Cálculo de disponibilidade	SlotService (fonte única): slots de 30 min a partir da grade semanal (agenda_horario) e das exceções (agenda_excecao: folga do profissional, feriado/recesso da clínica, horário diferente, bloqueios pontuais e recorrentes do profissional ou de todos), atendimentos ativos sobrepostos na duração inteira + intervalo do procedimento, antecedência mínima e máxima.
RN10	Anti double-booking	Um profissional não pode ter dois atendimentos ativos sobrepostos: trava de 30 s no cache durante a confirmação do site, SELECT FOR UPDATE em services/agenda.reservar e constraint EXCLUDE no Postgres. Corrida perdida vira HorarioIndisponivel com a mensagem "Este horário acabou de ser reservado".
RN11	Pedido público: aprovação ou confiança	O pedido é sempre da titular do celular verificado: com cadastro existente o nome do cadastro fica (nome diferente é ignorado; renomear só pelo painel). Pelo site, no máximo 3 horários futuros ativos por cliente (MAX_ATIVOS_ONLINE; o 4º é recusado e a recepção marca pelo painel). Cliente de confiança — já atendida (1+ REALIZADO), sem falta em aberto, sem bloqueio e com menos de 2 horários futuros — tem o pedido online criado como AGENDADO, com e-mail de confirmação na hora; as demais (primeira vez incluída) ficam PENDENTE e a profissional recebe o e-mail de aprovação. Aprovar (botões do painel, em lote — item a item, cada um na sua transação — ou portal) = AGENDADO + e-mail de confirmação; recusar = CANCELADO + e-mail. Pedido sem decisão a menos de 1 h do início é cancelado pelo job de

		hora em hora, com o e-mail "não conseguimos confirmar a tempo", e a vaga volta para a lista de espera.
RN12	Agendamento interno	A recepção agenda pelo painel (services/agenda.agendar_pela_recepcao; entrada validada por forms/agenda.AgendamentoPainelForm): cliente existente ou nova (ClienteRapidoForm: nome, telefone com DDD e e-mail opcional, gravada na mesma transação; inativa não agenda), profissional que realiza o procedimento e horário do mesmo SlotService, revalidado no servidor (services/agenda.validar_horario, com o motivo detalhado para a equipe: conflito, bloqueio, folga, expediente); não há OTP; o atendimento nasce AGENDADO, a cliente recebe o e-mail de confirmação e o valor diferente do preço do dia fica como "Valor combinado pela recepção" (preço cheio em valor_original); avisa a ficha obrigatória pendente.
RN13	Preço gravado com promoção da data	O atendimento grava o preço vigente na data do atendimento (profissional > base) com a promoção que vale nesse dia: valor_cobrado, valor_original, promoção e descrição. O resumo do wizard mostra exatamente esse valor; a vitrine ("A partir de", services/precos) mostra o preço base do dia com a promoção que o agendamento aplicaria, só quando ela reduz o valor.
RN14	Aceite da Política de Privacidade	Obrigatório no agendamento; grava AceiteTermo da versão LGPD vigente com IP, navegador e SHA-256 do texto aceito.
RN15	Consentimento para dado de saúde (art. 11)	A ficha de anamnese (no wizard ou pelo link) só é gravada com a caixa de consentimento específica marcada; o aceite vira AceiteTermo da versão SAUDE vigente (IP, navegador, SHA-256 do texto) e vai também para a auditoria. É a única base do dado de saúde (art. 11 I) e é revogável: RN55.
RN16	Termos de procedimento	Termos do procedimento (próprio e gerais) são aceitos no wizard; versão já aceita não é pedida de novo. Faltando aceite, o atendimento mostra "Termo pendente" e a clínica gera o link do termo, válido até o fim do atendimento. Marcar REALIZADO com termo pendente exige o override explícito "Realizado sem termo aceito", auditado.
RN17	Consentimentos de comunicação	Três autorizações por finalidade × canal — promoções por e-mail, lembrete/aviso de vaga por WhatsApp e pesquisa de satisfação por WhatsApp —, nunca pré-marcadas. Cada concessão ou revogação é uma linha nova e imutável (texto exibido, IP, navegador, autor, data); vale a mais recente; marcar de novo depois de um descadastro volta a valer. O descadastro por link revoga marketing e pesquisa e mantém o lembrete D-1. A equipe revoga a pedido da cliente e só registra autorização com justificativa. Responder "PARAR" (ou sair, stop, cancelar mensagens, descadastrar — a mensagem inteira) no WhatsApp revoga o lembrete e a pesquisa por WhatsApp (origem WHATSAPP) e a cliente recebe a confirmação com o caminho de volta.
RN18	Código OTP	Código de 6 dígitos (secrets), armazenado como HMAC-SHA256 com a SECRET_KEY, nunca em texto; validade 10 min; 5 tentativas; reenvio mínimo de 60 s; gerar um novo invalida o anterior; comparação em tempo constante.
RN19	OTP preso ao telefone	Todo agendamento público exige o código enviado ao celular informado (só celular recebe SMS). Cotas de SMS: 3/h por telefone, 10/h por IP, 60/h global, checadas antes de gerar o código. Propósitos isolados (AGENDAMENTO, LOGIN_CLIENTE, DSAR). Respostas não revelam se o telefone é cadastrado.
RN20	Máquina de estados do atendimento	PENDENTE → AGENDADO/CANCELADO/REAGENDADO; AGENDADO → CONFIRMADO/REALIZADO/CANCELADO/FALTOU/REAGENDADO; CONFIRMADO → REALIZADO/CANCELADO/FALTOU/REAGENDADO; REALIZADO, CANCELADO, FALTOU e REAGENDADO são terminais. AGENDADO = horário aprovado; CONFIRMADO = a cliente confirmou. Os efeitos da transição (pacote, comissão, cashback, faltas, retorno, lista de espera) gravam na mesma transação do status: tudo ou nada. REALIZADO e FALTOU só valem a partir do início (menos 30 min, TOLERANCIA_DESFECHO): antes, a FSM recusa (desfecho_antes_do_inicio).
RN21	Reagendamento pela cliente	Só pelo portal "Meus agendamentos" (id + sessão do OTP, só agendamentos do telefone verificado; não há link de reagendar), até 24 h antes. services/agenda.reagendar: o antigo vira REAGENDADO antes de o novo

		entrar; o novo herda preço, promoção, vínculo de retorno e a ficha. Fica AGENDADO se o original estava aprovado e a profissional é a mesma; senão volta a PENDENTE.
RN22	Cancelamento pela cliente	Pelo portal (id do atendimento + sessão do OTP) ou pelo link do lembrete D-1 (só AGENDADO/CONFIRMADO), a qualquer momento antes do início, por uma regra só (services/agenda.cancelar_pela_cliente, linha travada); a trilha registra "[pela cliente]". Com menos de 24 h de horário aprovado é cancelamento tardio (RN52). Cancelamento feito pela clínica avisa a cliente por e-mail. Quando a cliente cancela ou remarca, a profissional recebe push ("Cliente cancelou" / "Cliente remarcou").
RN23	Lembrete D-1 e confirmação de presença	Às 08:00 e às 18:00 o job lembrete_diario lembra os atendimentos AGENDADO do dia seguinte: WhatsApp (template aprovado) a quem tem a autorização de lembrete vigente, telefone e o canal configurado; e-mail (fila) às demais — aviso do serviço contratado. Uma vez por atendimento. O link (link_acesso CONFIRMAR_PRESENCA, válido até o início) permite confirmar (→ CONFIRMADO) ou cancelar, uma única vez.
RN24	Faltas	Só a equipe marca FALTOU: o sistema nunca marca falta sozinho. Todo dia às 08:00 (job sem_desfecho) cada profissional recebe um push com quantos atendimentos dela já terminaram sem Realizado/Faltou/Cancelado. Não há cobrança de taxa de no-show.
RN25	Retorno obrigatório (F-RET)	Procedimento com retorno obrigatório deixa, ao REALIZADO, o retorno DEVIDO na janela [mínimo, máximo] dias após o atendimento — o sistema não reserva horário sozinho. A recepção marca com a cliente em "Retornos a marcar" (só horários livres dentro da janela; AGENDADO, valor 0) e a cliente vê em Meus agendamentos o prazo do retorno sem custo. No máximo 1 retorno vivo por origem (UNIQUE). Retorno não gera comissão, cashback nem débito de pacote.
RN26	Pacotes — consumo	Sessão REALIZADA debita 1 sessão do item congelado (compra_pacote_item) do pacote que vence primeiro (1 consumo por atendimento). A validade é conferida na data da sessão. O banco garante que o consumo é de um item da mesma compra, do mesmo procedimento, nunca de retorno e só com saldo. Antes do REALIZADO, o atendimento que um pacote vai cobrir (mesma ordem, descontando as sessões já marcadas) aparece como "Sessão do pacote" no painel, no portal, no e-mail e na página de sucesso — nunca o preço cheio.
RN27	Pacotes — venda e ciclo de vida	A venda congela o nome e os itens (procedimento, sessões e valor de 1 sessão = valor pago rateado pelo preço de tabela de cada procedimento no dia — rateio ponderado; uniforme se falta preço); o catálogo continua editável só para vendas futuras. ATIVO → FINALIZADO (todas as sessões usadas), EXPIRADO (job diário, vencimento < hoje) ou CANCELADO (valor devolvido em dinheiro entre 0 e o valor pago — sugerido = sessões restantes × valor da sessão —, motivo, cancelado_em, auditado sem o nome da cliente; nunca vira crédito na carteira). O ADMIN prorroga a validade de compra ATIVA ou EXPIRADA (data nova depois da atual, motivo; EXPIRADA volta a ATIVA). Aviso por e-mail 7 e 1 dia antes do vencimento com saldo.
RN28	Promoções e preços	Preço versionado por vigência (data local). Promoção = desconto 0–100% XOR preço fixo (CHECK), por período; promoção geral só vale como percentual; aplica-se só quando reduz o valor e nunca deixa negativo.
RN29	Valor cobrado e faturamento	A clínica pode registrar o valor combinado (não em cancelado/faltou/reagendado, retorno ou realizado com comissão lançada). Financeiro por competência mensal (?mes=AAAA-MM): faturamento = avulsos realizados com valor > 0 no mês do atendimento + vendas de pacote no mês da venda − reembolsos no mês do cancelamento (mês fechado não muda; pode haver mês com pacotes negativos); sessão de pacote e retorno não somam. Ticket médio e LTV pela mesma regra; o Excel gerencial do mês fecha com o card e a exportação é auditada.
RN30	Comissão (livro-razão)	Ao REALIZADO (não em retorno) lança 1 CREDITO pela regra mais específica (profissional+procedimento > profissional > procedimento > global; empate =

		mais recente): percentual 0–100 ou valor fixo (limitado à base) sobre o valor cobrado ou, em sessão de pacote, sobre o valor unitário congelado; o CREDITO congela a base e o percentual aplicados. No máximo 1 crédito ativo por atendimento (estornado, pode nascer outro). A baixa é um PAGAMENTO — um a um ou em lote ("pagar pendentes até dd/mm" por profissional, com recibo sem nome de cliente) — e o cancelamento um ESTORNO, ambos referenciando o crédito; estornado não se paga; comissão paga nunca é estornada (cancelar ou desfazer o realizado é recusado); nada é alterado ou apagado. Status e saldo são derivados e o saldo pode ficar negativo. Regra já usada não muda nem se exclui (trigger): só desativa.
RN31	Cashback por indicação	No 1º atendimento REALIZADO e pago da indicada, a indicadora recebe R$ 50,00 na carteira (idempotente); cancelamento estorna; saldo nunca negativo; ledger imutável.
RN32	Lista de espera sem cadastro	O formulário público (captcha, honeypot, 20 inscrições/dia por IP) nunca cria nem altera cliente: a inscrição é anônima (nome e celular) e só se liga ao cadastro — e só aceita e-mail de contato — com o celular verificado por SMS na sessão. Uma inscrição por pessoa (cliente ou celular) + procedimento + dia. Quando um atendimento ativo futuro vira CANCELADO ou REAGENDADO, os compatíveis (procedimento, dia, profissional vazio ou igual, turno vazio ou o da vaga, vaga fora da antecedência mínima), em ordem de chegada, recebem e-mail e WhatsApp (com autorização) com link para agendar — só as inscrições ligadas ao cadastro; a anônima a recepção avisa pelo painel. Sem reserva do horário; o aviso grava ultimo_aviso_em e a inscrição continua na fila até a data passar ou a pessoa agendar o procedimento.
RN33	NPS	WhatsApp de NPS entre 24 h e 7 dias após o REALIZADO, nunca em retorno, no máximo 1 pesquisa por cliente a cada 90 dias (NPS_INTERVALO_DIAS), com autorização de pesquisa vigente (até 3 tentativas; job 1×/dia); link válido por 7 dias; 1 avaliação por atendimento; nota 0–10, pelo link ou respondendo o WhatsApp (o mesmo services/nps.registrar_avaliacao). Nota ≤ 6 gera alerta por e-mail à clínica. O cálculo do NPS é único (arredondamento "meio para cima") no painel, nas views e no banco. Depois da nota, a página /nps/<token>/obrigado/ oferece a pesquisa pós-atendimento (formulário PESQUISA) aplicável e não respondida (opcional, sem mensagem extra).
RN34	Depoimentos	Só aparecem no site com opt-in da cliente, aprovação da clínica, nota ≥ 9 e comentário; nome exibido abreviado; cliente excluída ou pseudonimizada nunca aparece.
RN35	Aniversário e promoções por e-mail	Aniversário = e-mail de felicitação sem desconto, com consentimento de marketing (1×/dia). Promoção por e-mail só pelo painel, só para quem consentiu, sem cupom, anunciada pela data do atendimento ("para atendimentos de dd/mm a dd/mm" — é quando o preço vale), com link de descadastro; disparo único em lotes de 25 com o cursor na própria promoção (cada lote reservado antes de sair); reenviar para todos exige confirmação explícita.
RN36	Prontuário e histórico	Ficha 1:1 com campos clínicos e as perguntas do formulário PRONTUARIO (no máximo 1 ativo). Cada edição grava antes a versão anterior (histórico append-only, imutável); edição concorrente é recusada; POST parcial não apaga campos. Anotações de sessão também são append-only (correção = nova anotação).
RN37	Acesso do profissional à ficha	O profissional só lê a ficha de quem tem atendimento REALIZADO nos últimos 180 dias ou ativo entre ontem e +60 dias (escrita sem PENDENTE); ADMIN lê todas. Toda leitura, gravação e negativa é auditada.
RN38	Alertas de saúde	Alergias, contraindicações, medicamentos e respostas marcadas como alerta de saúde nas fichas aparecem como texto visível no portal, na agenda do painel e na ficha da cliente (calculados em lote); marcador "ficha pendente" quando a ficha obrigatória não foi respondida. Onde a ficha vale (global, categoria ou procedimento — todo atendimento é presencial) é decidido por uma regra única (FormularioAnamnese.aplica_a); para cliente agendada pelo painel, o botão "Link da ficha" gera o convite (60 dias). Quem revogou o

		consentimento de saúde tem no topo dos alertas "Consentimento de saúde revogado em dd/mm/aaaa". A agenda e a visão geral do painel registram na auditoria "Leu alertas de saúde" (tabela prontuario, ids das clientes e a tela) quando mostram alerta. Na agenda, o REALIZADO com retorno devido mostra o botão "Agendar retorno (até dd/mm)".
RN39	Termos versionados e imutáveis	1 versão ativa por escopo (LGPD e SAUDE globais; PROCEDIMENTO geral ou por procedimento). Versão com aceite não pode ser editada (model + trigger): mudar = publicar nova versão. O aceite é imutável e nunca apagado. O termo LGPD é a Política de Privacidade inteira (RN56).
RN40	Retenção de dados	OTP 24 h; texto de notificação 12 meses; auditoria (com o IP) e trilha de dados 5 anos; link público vencido ou revogado 90 dias; logs de login 90 dias. Prazos LGPD fixos no settings (os publicados na política, RN56): cliente sem atendimento há 5 anos ou excluída há 30 dias é pseudonimizada, exceto enquanto houver registro de saúde dentro da janela de 20 anos ou pacote a menos de 5 anos do fim (RN53, RN54); registro de saúde expurgado 20 anos depois do último evento de saúde (RN53); ficha de pedido não realizado apagada após 90 dias; lista de espera apagada quando a data passa ou a pessoa agenda. A escrita é das procedures do Postgres (fonte única).
RN41	Direito ao esquecimento (pseudonimização)	sp_anonimizar_cliente pseudonimiza (art. 13 §4): nome vira [ANONIMIZADO-pk]; contatos, documentos, nascimento, endereço, código de indicação e quem indicou saem; revoga as autorizações vigentes (histórico fica sem IP/navegador); tira IP/navegador do aceite LGPD (e dos de SAÚDE/procedimento quando não há mais registro de saúde); soft delete; apaga OTPs, a lista de espera (inclusive a inscrição anônima com o mesmo celular), texto de notificações e fichas que não são de atendimento realizado; retira o depoimento e o comentário do NPS; revoga todos os links públicos; pseudonimiza o nome nos textos da auditoria e apaga os detalhes das trilhas LGPD da titular. Atendimentos, aceites, pacotes e o registro de saúde (até o expurgo) ficam ligados a esse id.
RN42	Acesso aos dados (DSAR)	A cliente baixa os próprios dados em JSON pela área "Meus agendamentos" (código confirmado há até 10 min) ou em /lgpd/meus-dados/ com código SMS (propósito DSAR, captcha, 10/h por IP e 5/h por telefone): cadastro, preferências, consentimentos, atendimentos, NPS, aceites, pacotes, carteira, lista de espera, notificações e a declaração do tratamento (finalidades, bases, operadores e prazos, da mesma fonte da política). Sem a ficha de saúde (o celular pode ter mudado de dono): o arquivo diz como pedir. Resposta idêntica exista ou não o cadastro; ação auditada.
RN43	Auditoria e trilha de dados	Toda ação sensível grava autor (+ nome), tabela, registro, detalhes com PII mascarada e IP (LGPD art. 37), com o Ator da requisição (usuário, IP, origem). Além disso, triggers registram cada alteração das 11 tabelas sensíveis em historico_alteracao. As duas trilhas são append-only no banco.
RN44	Login da equipe e 2FA	E-mail + senha (mínimo 10, validadores do Django). 2FA TOTP obrigatório para ADMIN e PROFISSIONAL em produção (cadastro forçado após o login, conferido a cada request; válvula de emergência por variável de ambiente com aviso). Códigos de backup no painel; trocar de aparelho exige o código atual; recuperação por comando setup_2fa --force. Sessão da equipe de 8 h deslizantes; logout só via POST.
RN45	Bloqueio de login e reset de senha	django-axes bloqueia por 1 h após 5 falhas, por IP + usuário e por IP (nunca por usuário sozinho, que trancaria a dona fora com o e-mail público); rate-limit no login (10/min por IP, 5/min por e-mail). Reset de senha com token de 1 h, 3 pedidos/15 min por IP, resposta genérica; sem backend de e-mail real nada é enviado.
RN46	Exceções de agenda	Folga (do profissional ou da clínica inteira: feriado nacional/local e recesso, carregados pelo job mensal de feriados), horário diferente (1 por profissional/dia) e bloqueio (pontual ou recorrente por RRULE diária/semanal/mensal). Grade sem janelas sobrepostas e folgas do mesmo profissional sem sobreposição (EXCLUDE). Exceção inativa fica registrada e é ignorada (ex.: feriado em que a clínica abre).

RN47	Links públicos	Todo link das mensagens (confirmar presença, NPS, termo, ficha, descadastro, feed iCal) é um link_acesso com finalidade e 1 alvo; o banco guarda só o SHA-256 do token. Validade por finalidade: confirmação até o início, termo até o fim do atendimento, NPS 7 dias, ficha 60 dias, descadastro e feed sem validade. Gerar novo feed revoga o anterior e o desligamento da profissional (ela, o login dela ou o vínculo do login) revoga o vigente; a URL aparece só na geração.
RN48	Dados de saúde cifrados	Campos clínicos e respostas do prontuário, versões do prontuário, anotações de sessão e fichas de anamnese ficam cifrados em repouso (Fernet, chave por finalidade); a aplicação lê em claro e o banco não busca pelo conteúdo. Rotação de chave por comando.
RN49	Fila de e-mail transacional	Confirmação, cancelamento, lembrete D-1 por e-mail e pedido de aprovação à profissional nascem Notificacao EMAIL PENDENTE na transação de quem pediu e saem no on_commit; se falhar, o job emails reenvia com espera crescente (5/10/20/40 min) até 5 tentativas ou 48 h (→ FALHOU). A fila não guarda cópia de dado pessoal.
RN50	Execução dos jobs periódicos	Os horários ficam em jobs.JOB_AGENDA (fonte única, horário de Brasília). O serviço Cron do Railway roda rodar_jobs_devidos a cada 15 min (os jobs cujo horário caiu na janela; a falha de um não impede os outros); o cron HTTP (X-Cron-Token, 30 chamadas/h por IP, erro só com o tipo e uma referência) e rodar_job são alternativas. Jobs de mensagem sem marca por destinatário (aniversário, pacote expirando, NPS) rodam no máximo 1 vez por dia: a 2ª chamada recebe 409 (execucao_job).
RN51	Regras operacionais e cadastros da equipe	As regras que a dona ajusta formam um registro tipado (models/configuracao.CHAVES): email_admin (e-mail válido ou vazio) e MAX_FALTAS_BLOQUEIO (1 a 10), lidas por Configuracao.ler; a tela Regras operacionais grava só essas chaves (sem chave livre) e "Restaurar padrão" apaga a linha. A marca e os contatos têm a tela Identidade visual. Usuários: e-mail único, PROFISSIONAL exige o vínculo (1 login por profissional), ninguém muda o próprio papel nem se desativa e o último ADMIN ativo não sai. Preço base muda por vigência nova a partir de hoje, só quando o valor muda; tirar a habilitação de quem tem atendimento futuro do procedimento é recusado.
RN52	Cancelamento tardio conta falta	A cliente sempre pode cancelar online antes do início (a vaga volta para a lista de espera), mas cancelar com menos de 24 h (JANELA_MINIMA_ALTERACAO) um horário já aprovado (AGENDADO/CONFIRMADO) soma 1 em faltas_consecutivas e pode suspender o agendamento online, sem virar FALTOU; pedido PENDENTE não conta. O portal e a página do link avisam antes de confirmar.
RN53	Expurgo do registro de saúde aos 20 anos	Prontuário, versões, anotações, fichas e a trilha do prontuário são apagados 20 anos depois do último evento de saúde da cliente (último REALIZADO, edição/versão do prontuário, anotação ou ficha) pela etapa saude do housekeeping, que também tira IP/navegador dos aceites SAÚDE e de procedimento. Os triggers só aceitam o DELETE com a flag local e 20 anos de idade: um prazo menor faz a etapa falhar, nunca apagar antes.
RN54	Retenção do pacote	Quem comprou pacote não é pseudonimizada pela retenção até 5 anos depois de o pacote expirar ou ser cancelado (sem validade: da compra) — prazo do contrato.
RN55	Consentimento de saúde revogável	A cliente revoga o consentimento de dado de saúde na área "Meus agendamentos" (ou a equipe, a pedido, pelo Django admin com motivo): grava cliente.saude_revogada_em e a trilha; vale dali em diante — o registro feito fica pelo prazo de guarda e os alertas mostram a revogação. Um aceite SAÚDE novo (ficha respondida com o consentimento) reativa. A ficha ainda em dia (12 meses) continua valendo no wizard depois da revogação.
RN56	Política de Privacidade como fonte única	O texto da política (conteudo/lgpd.py: dados, finalidades e bases, saúde, mensagens, decisões automatizadas, operadores, cookies, segurança, direitos e prazos) é o termo LGPD aceito no wizard, a página /politica-de-privacidade/ (versão vigente, com versão e vigência) e a declaração do "baixar meus

		dados". Os prazos LGPD ficam fixos no settings, sem variável de ambiente; o check aranha.W016 acusa divergência com o texto vigente. Precisa de revisão jurídica da dona antes do go-live.
RN57	Números do site só com dado real	Os números do site público (home, "Sobre" e páginas de serviço) saem de services/prova_social, nunca escritos à mão: nota média = média do NPS (0–10) ÷ 2, em 5 estrelas desenhadas em meias, só com 10 ou mais respostas; clientes atendidas = clientes distintas com atendimento REALIZADO, só a partir de 50 e arredondadas para baixo ("127" vira "120+"); tratamentos = procedimentos agendáveis online; anos de experiência = regra operacional anos_experiencia (inteiro opcional de 1 a 60; em branco não aparece). Número abaixo do mínimo some da página. Recalculados a cada 10 minutos (cache), e na hora quando a configuração muda.

7. Casos de Uso

Os casos de uso estão divididos por subsistema: uma visão geral com todos os atores e um diagrama por área. «include» marca o passo sempre executado; «extend», o opcional ou condicional.

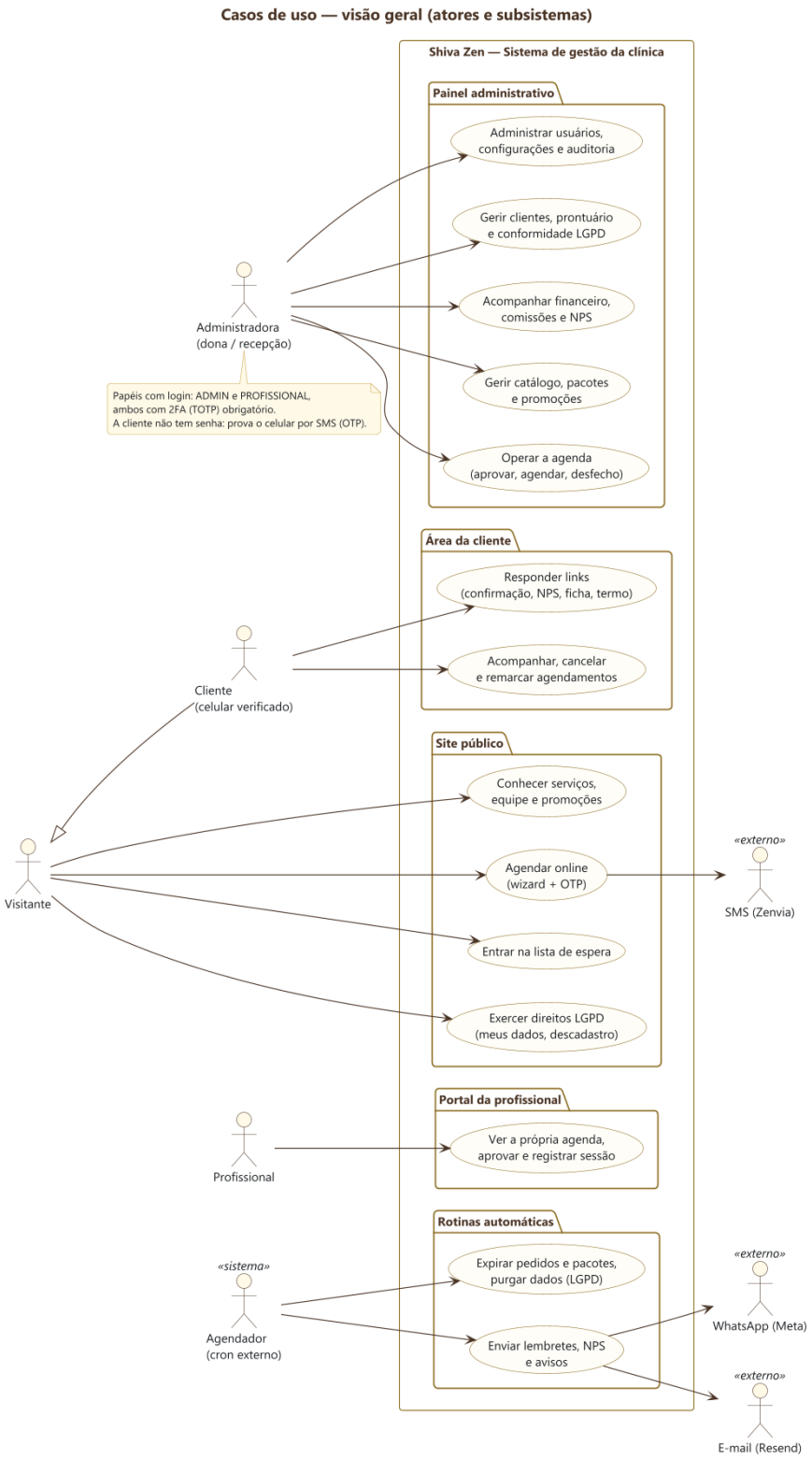


Figura 1 — Casos de uso — visão geral (atores e subsistemas).

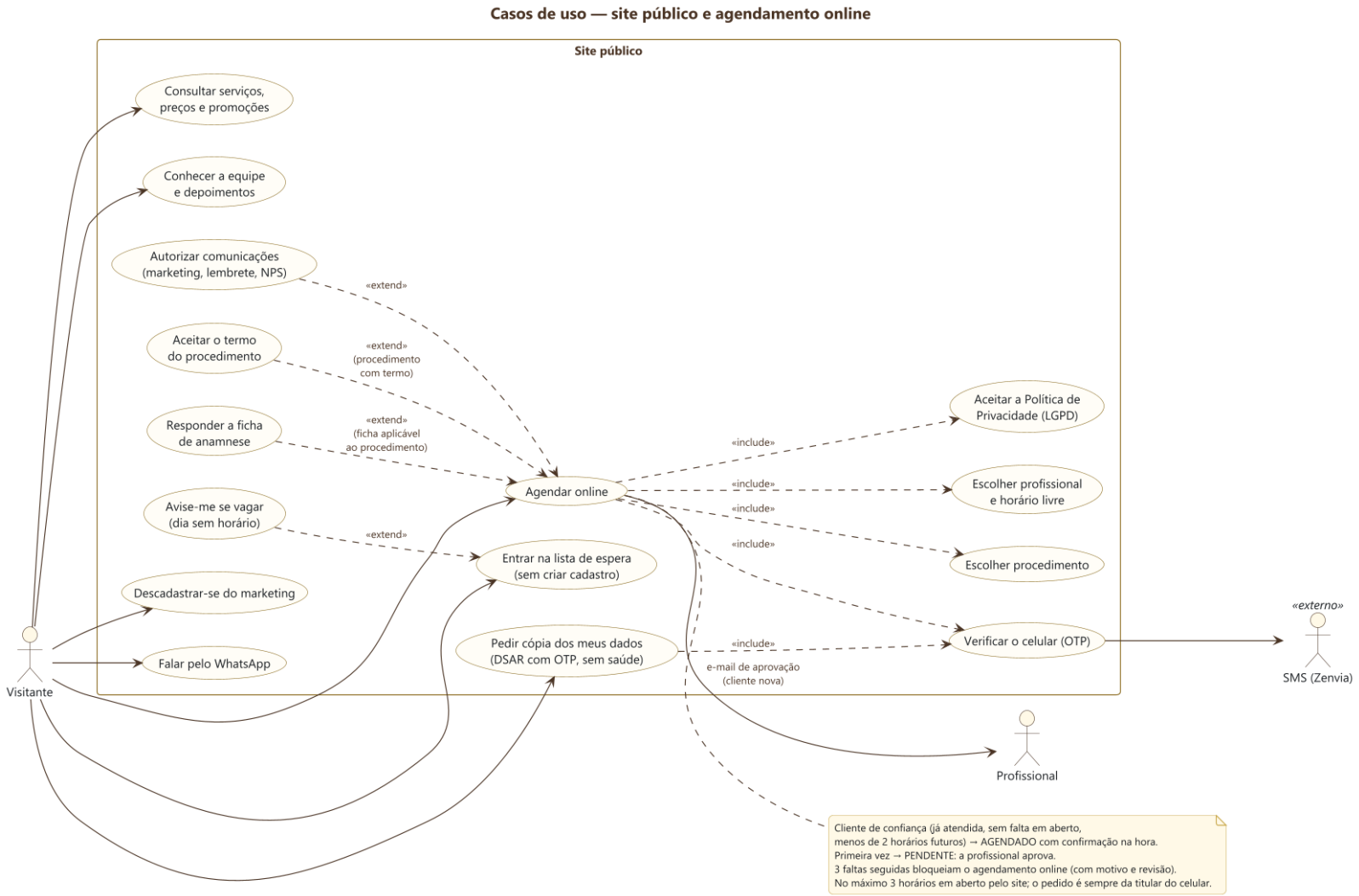


Figura 2 — Casos de uso — site público e agendamento online.

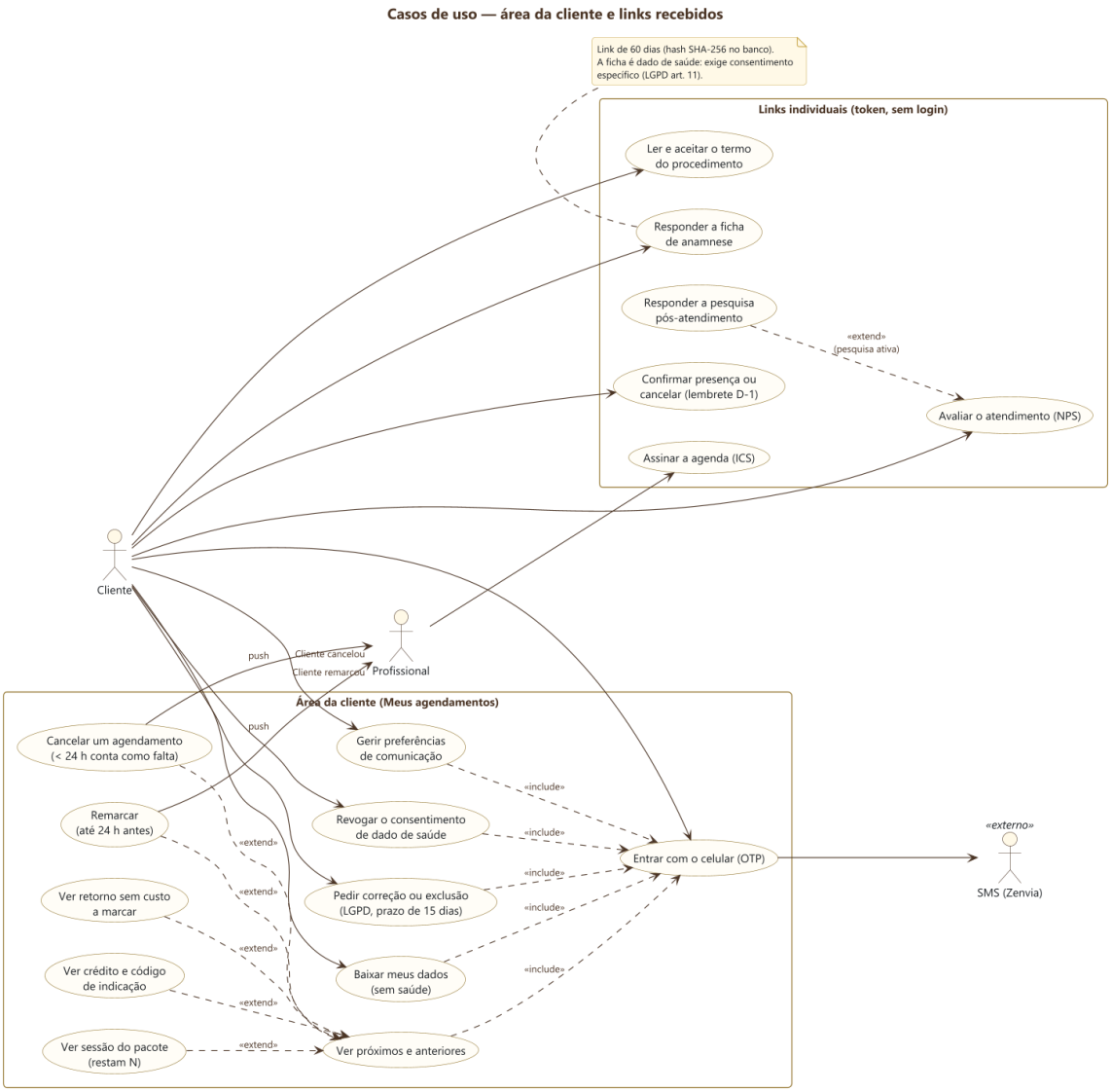


Figura 3 — Casos de uso — área da cliente e links recebidos.

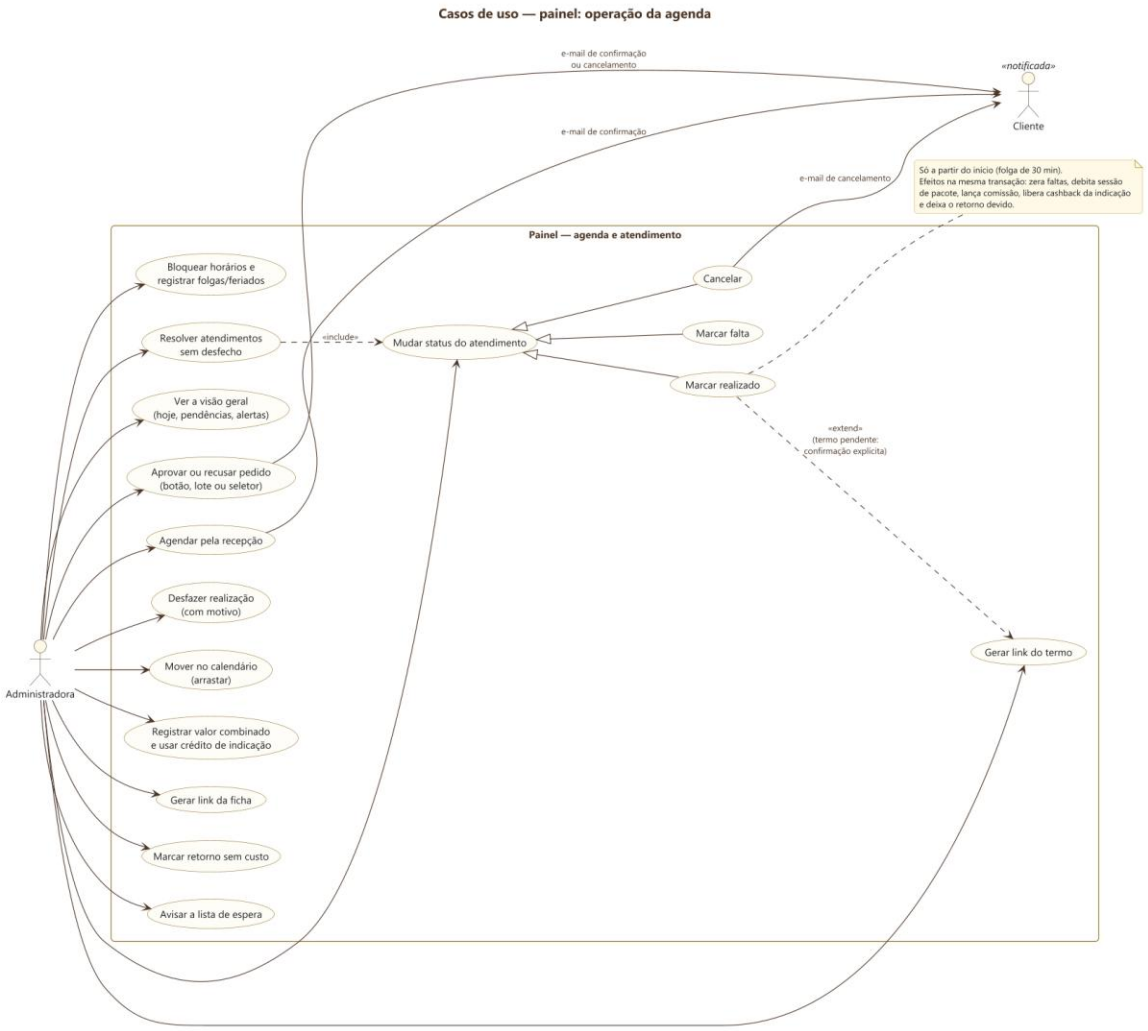


Figura 4 — Casos de uso — painel: operação da agenda.

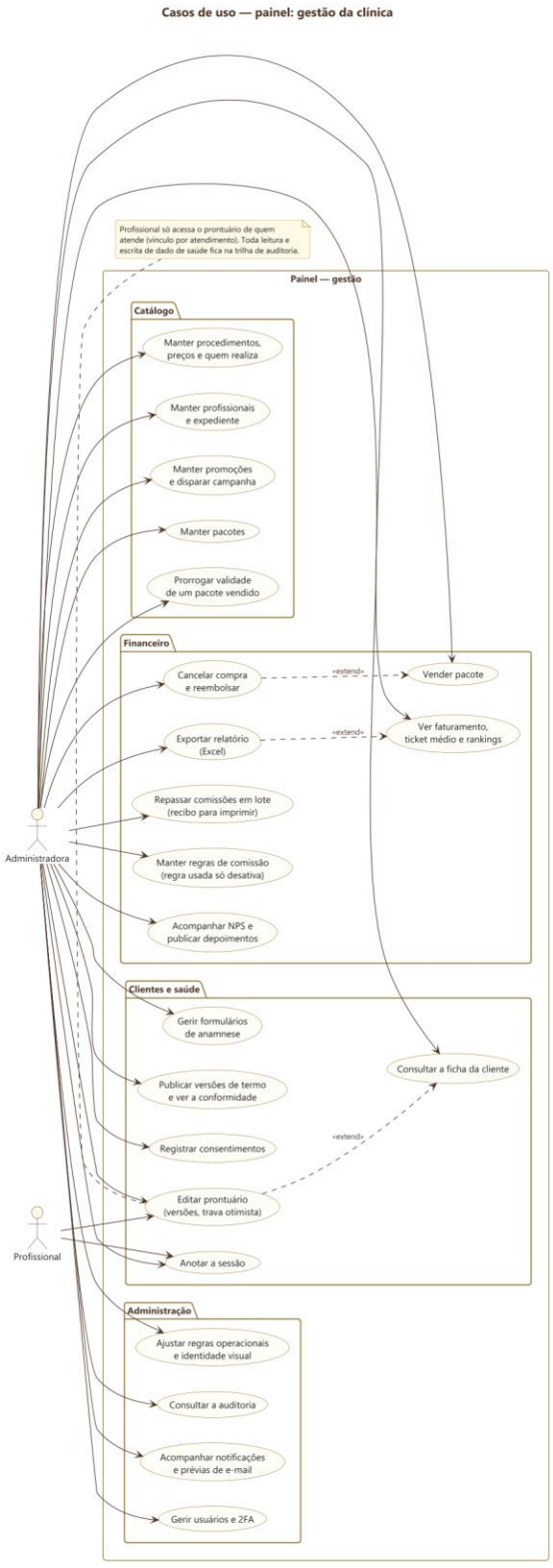


Figura 5 — Casos de uso — painel: gestão da clínica.

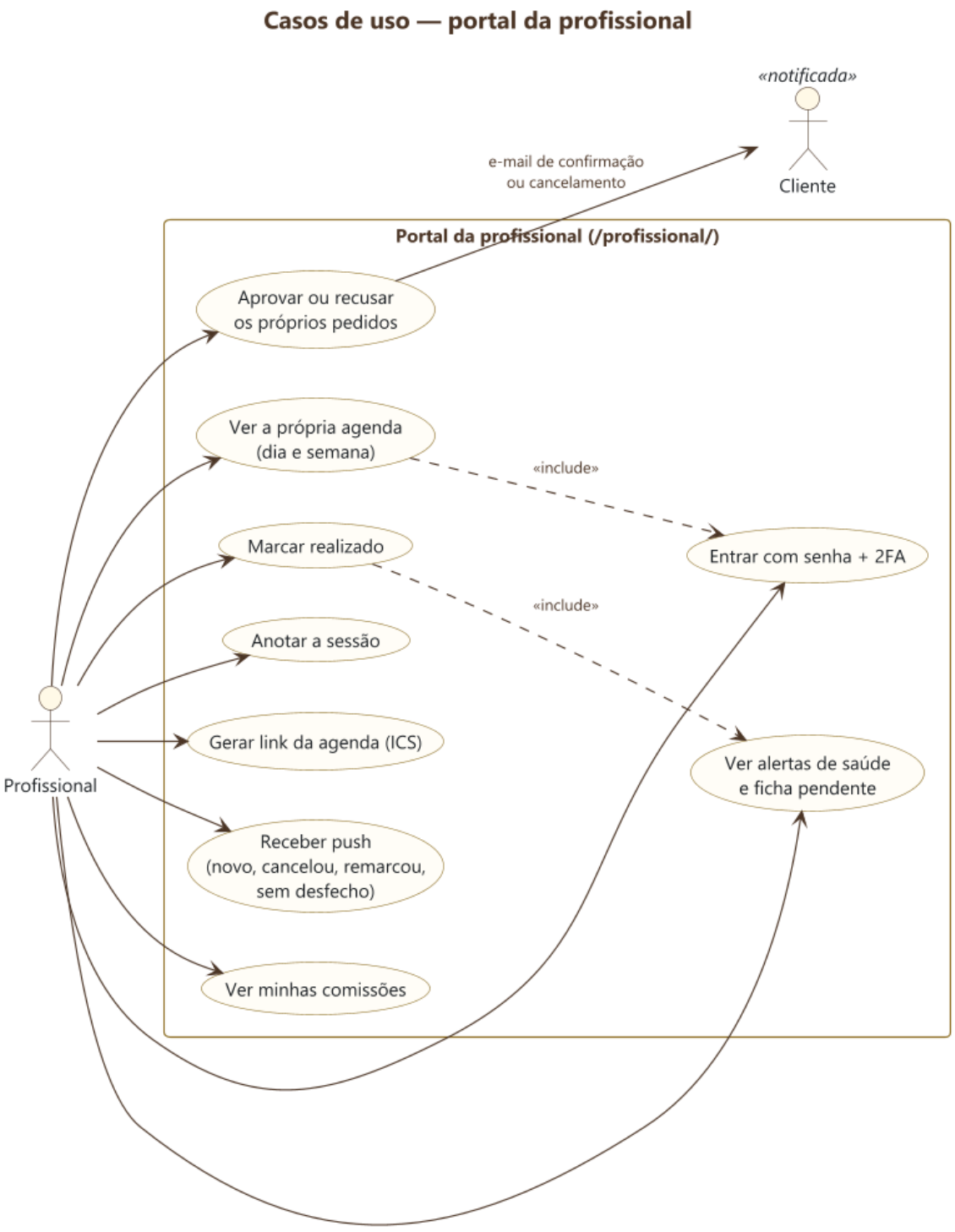


Figura 6 — Casos de uso — portal da profissional.

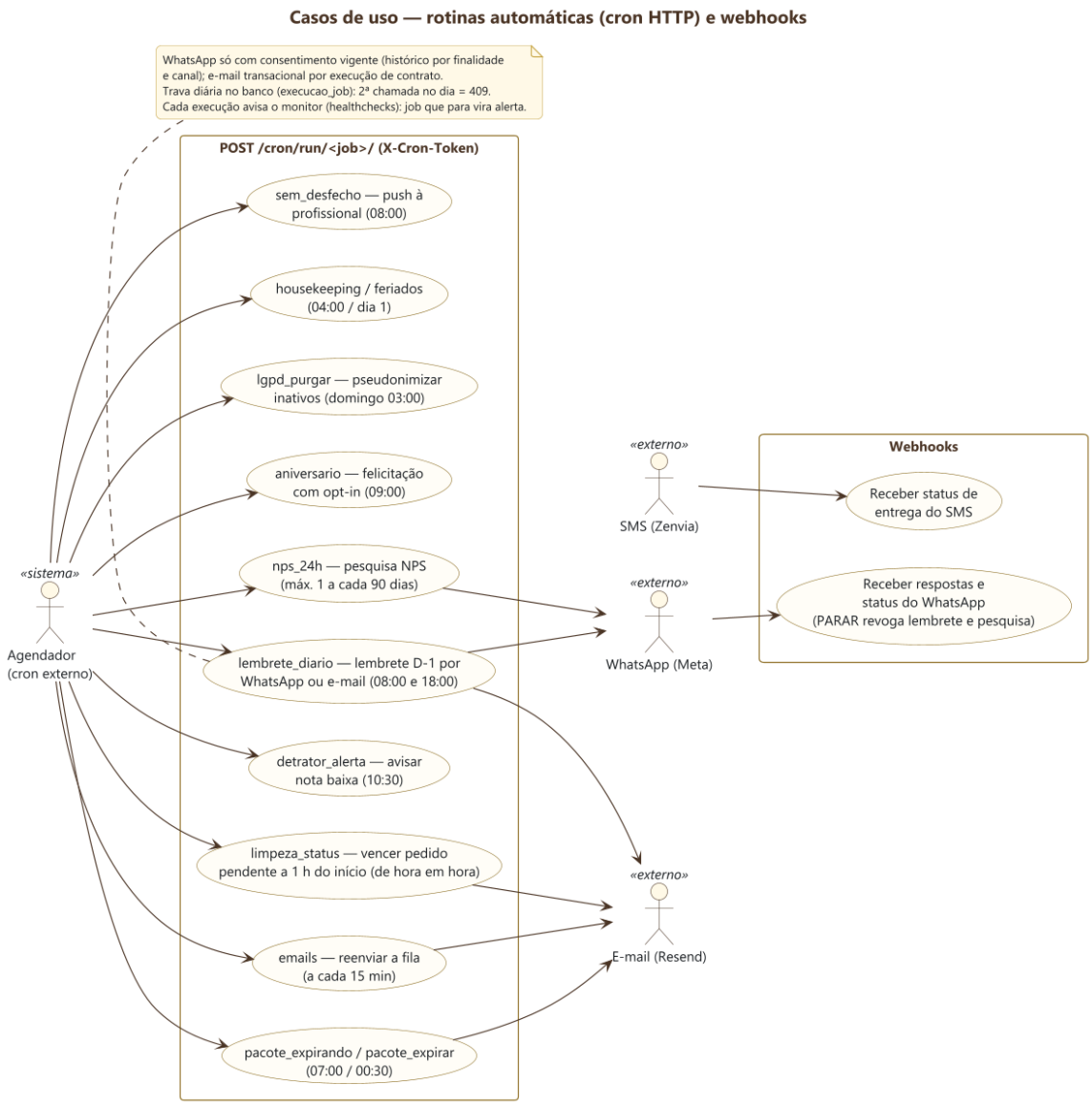


Figura 7 — Casos de uso — rotinas automáticas e webhooks.

7.1 Especificação dos casos de uso

ID	Caso de uso	Atores	Fluxo principal
UC01	Agendar online	Visitante / Cliente (público, sem login), Cliente cadastrada, Serviços externos	Cliente escolhe procedimento, data/horário e profissional (botão Continuar a cada etapa), informa dados, aceita a política e os termos, consente o dado de saúde, escolhe as autorizações de comunicação e responde a ficha; confirma o celular com código SMS (UC02). O form confere idade ≥ 18 e o celular verificado; o caso de uso services/agendamento_online.solicitar revalida termo LGPD, horário (services/agenda.validar_horario), fichas (12 meses) e termos; trava o slot (cache + SELECT FOR UPDATE + EXCLUDE), cria a cliente ou usa o cadastro da titular do telefone (o nome do cadastro fica; bloqueio online e

			teto de 3 horários ativos), registra os consentimentos (histórico), grava o atendimento PENDENTE com o preço da data (services/agenda.reservar), os aceites com prova (LGPD, SAÚDE, procedimento) e a ficha cifrada; o pedido de aprovação à profissional entra na fila de e-mail, o push sai no on_commit, a cliente sai da lista de espera do procedimento e a área "Meus agendamentos" abre sem novo SMS.
UC02	Verificar celular por OTP	Visitante / Cliente (público, sem login), Cliente cadastrada, Serviços externos	Cliente informa o celular; o sistema valida o captcha (se configurado), recusa telefone fixo, checa intervalo e cotas de SMS, gera o código (HMAC) e envia pela Zenvia. A cliente digita o código; o sistema confere (5 tentativas) e marca o telefone como verificado na sessão por 30 min, devolvendo o pré-preenchimento do cadastro daquele telefone.
UC03	Consultar disponibilidade	Visitante / Cliente (público, sem login)	O wizard consulta dias do mês e horários livres; o SlotService calcula os slots de 30 min por profissional a partir da grade semanal e das exceções (folga, feriado/recesso, horário diferente, bloqueios), atendimentos, intervalo do procedimento e antecedências.
UC04	Reagendar atendimento	Cliente cadastrada	Só pelo portal (id + sessão do OTP, só agendamentos do telefone verificado): exige ≥ 24 h de antecedência; escolhe novo horário (UC03); services/agenda.reagendar marca o antigo REAGENDADO e cria o novo com preço, retorno e ficha; fica AGENDADO se já aprovado e com a mesma profissional, senão PENDENTE.
UC05	Cancelar atendimento	Cliente cadastrada	Pelo portal (id + sessão do OTP) ou pelo link do lembrete D-1 (só AGENDADO/CONFIRMADO): services/agenda.cancelar_pela_cliente trava a linha e leva o atendimento ativo e futuro a CANCELADO pela FSM (trilha "[pela cliente]"); com menos de 24 h de um horário aprovado é cancelamento tardio — soma 1 falta (o portal e a página avisam antes); a vaga é oferecida à lista de espera.
UC06	Entrar em Meus agendamentos	Cliente cadastrada, Serviços externos	Cliente informa celular ou e-mail; se houver cadastro, o código vai ao celular do cadastro (resposta e tempo sempre iguais); após o código — ou ao fim do agendamento online, sem novo SMS — sessão de 1 h presa ao telefone com agendamentos futuros e passados, reagendar, cancelar, minhas preferências, revogação do consentimento de saúde, pedido de correção/exclusão e baixar meus dados (código de até 10 min). Sair só por POST.
UC07	Confirmar presença	Cliente cadastrada	Pelo link do lembrete D-1 (WhatsApp ou e-mail; link_acesso válido até o início): confirmar (AGENDADO → CONFIRMADO) ou cancelar, uma única vez.
UC08	Entrar na lista de espera	Visitante / Cliente (público, sem login)	Pelo menu ou pelo "Avise-me se vagar" do wizard (procedimento, data e profissional já preenchidos), informa nome, celular, procedimento, data, turno/profissional e e-mail opcional; captcha, honeypot e limite diário por IP. O sistema nunca cria cadastro: a inscrição é anônima, salvo se o celular foi verificado na sessão (aí se liga ao cadastro e guarda o e-mail só nela). Quando uma vaga compatível abre (dia, profissional, turno), a inscrição ligada ao cadastro recebe aviso por e-mail/WhatsApp e continua na fila até a data passar ou agendar.

UC09	Responder ficha de anamnese por link	Visitante / Cliente (público, sem login)	Pelo link (60 dias): responde a ficha; para ficha de saúde marca o consentimento do art. 11 (aceite do termo SAÚDE com prova); respostas validadas contra o schema e gravadas cifradas; uma resposta por link. O convite sai do botão "Link da ficha" na agenda do painel (cliente agendada pela recepção).
UC10	Responder NPS	Cliente cadastrada, Serviços externos	Pelo link (7 dias) ou respondendo o WhatsApp: nota 0–10, comentário e autorização do depoimento; uma avaliação por atendimento; a página de obrigado oferece a pesquisa pós-atendimento, se houver.
UC11	Aceitar termo por link	Cliente cadastrada	Pelo link do atendimento (link_acesso TERMO, válido até o fim dele): lê e aceita os termos pendentes; o aceite grava IP, navegador e SHA-256 do texto.
UC12	Exercer direitos LGPD	Cliente cadastrada, Serviços externos	Baixar os dados em JSON (portal com código de até 10 min ou "Meus dados" com código SMS — DSAR: cadastro, preferências, consentimentos com histórico, atendimentos, aceites, NPS, pacotes, carteira, lista de espera e a declaração do tratamento; a ficha de saúde não sai pelo site), mudar as preferências de comunicação, revogar o consentimento de saúde, pedir correção ou exclusão (prazo de 15 dias, e-mail à clínica), descadastrar-se por link (revoga marketing e pesquisa) e responder "PARAR" no WhatsApp (revoga lembrete e pesquisa por WhatsApp).
UC13	Autenticar equipe	Administrador (ADMIN), Profissional	Login por e-mail/senha com rate-limit e django-axes; sem 2FA cadastrado vai ao cadastro obrigatório; com 2FA passa pelo desafio (UC14); reset de senha por link (1 h). Logout só via POST.
UC14	Cadastrar / validar 2FA	Administrador (ADMIN), Profissional	Cadastro por QR (SVG) e confirmação do primeiro código; desafio a cada sessão (TOTP ou código de backup); códigos de backup gerados no painel; trocar de aparelho exige o código atual.
UC15	Operar o portal do profissional	Profissional	Agenda do dia/semana e pedidos pendentes com alertas de saúde; aprovar/rejeitar; marcar realizado a partir do início (termo aceito ou override auditado — a mesma regra do painel); anotar a sessão; abrir a ficha quando há vínculo.
UC16	Gerir agendamentos no painel	Administrador (ADMIN)	Lista com filtros por dia e marcadores em lote (termo pendente, ficha pendente, alertas, pacote, crédito; a leitura de alerta vai para a auditoria); aprovar/rejeitar individual ou em lote, item a item (e-mail pela fila); seletor de status só para AGENDADO/CONFIRMADO, com Realizado/Faltou a partir do início (409 sem termo, salvo override; 409 antes do início); calendário com arrastar-e-soltar (services/agenda.mover, motivo detalhado da recusa); valor cobrado; link do termo; "Agendar retorno" quando devido.
UC17	Gerir clientes e prontuário	Administrador (ADMIN), Profissional	Ficha da cliente (dados validados, alertas, pacotes, histórico, autorizações de comunicação); prontuário com as perguntas do formulário PRONTUARIO, histórico de versões, trava de edição concorrente e trilha de leitura; anotações de sessão append-only. Conteúdo clínico cifrado.
UC18	Gerir profissionais e disponibilidade	Administrador (ADMIN)	Profissionais (grade semanal, antecedências, habilitações, preços; desativar revoga o feed iCal e é recusado se deixaria atendimento futuro sem quem atenda), exceções de agenda (folga, horário diferente,

			bloqueio pontual ou recorrente, inclusive para todos), feriados e recessos, procedimentos e novo link do feed iCal.
UC19	Gerir pacotes	Administrador (ADMIN)	Criar/editar pacotes do catálogo (vale para vendas futuras), vender a uma cliente (itens congelados com o valor unitário do rateio ponderado), acompanhar saldo/validade, prorrogar a validade e cancelar com valor devolvido (deduz no mês do cancelamento).
UC20	Gerir promoções e campanhas	Administrador (ADMIN), Serviços externos	CRUD de promoções (percentual XOR preço fixo, período) e disparo único do e-mail em lotes para clientes com consentimento, sem cupom, anunciando o período dos atendimentos; reenviar só com confirmação.
UC21	Financeiro e comissões	Administrador (ADMIN)	Dashboard e financeiro por competência mensal (?mes=: avulsos + vendas de pacote − reembolsos do mês, faltas, rankings, ticket médio, últimos 12 meses); comissões em livro-razão (créditos com base e percentual, pagamentos, estornos, saldo por profissional — pode ficar negativo), pagar um crédito ou o repasse em lote com recibo, regras de comissão (usada só desativa) e o Excel gerencial do mês.
UC22	Gerir lista de espera	Administrador (ADMIN), Serviços externos	Ver as inscrições (ligadas ao cadastro ou anônimas, com nome e celular de contato) e avisar manualmente uma vaga: e-mail quando há destino, aviso registrado (ultimo_aviso_em) e auditado mesmo sem e-mail — a recepção completa pelo WhatsApp ou telefone.
UC23	Gerir formulários e termos	Administrador (ADMIN)	Formulários de anamnese, pesquisa e perguntas do prontuário (lista de perguntas com alerta de saúde; 1 PRONTUARIO ativo) e termos versionados LGPD, SAÚDE e de procedimento (1 ativo por escopo; imutáveis após aceite); painel de conformidade dos aceites.
UC24	Administrar o sistema	Administrador (ADMIN)	Usuários da equipe (link para definir senha, ativar/desativar; o último ADMIN ativo não sai), regras operacionais (registro tipado), identidade visual, notificações, pré-visualização de e-mails e auditoria.
UC25	Executar jobs periódicos	Sistema / Cron externo, Serviços externos	O serviço Cron roda rodar_jobs_devidos a cada 15 min (ou o agendador externo chama POST /cron/run/<job>/ com X-Cron-Token, ou rodar_job no servidor) e executa os jobs cujo horário da JOB_AGENDA venceu: fila de e-mail (15 min), lembrete D-1 (08:00 e 18:00), sem desfecho, NPS, alerta de detrator, pacotes, aniversário, limpeza de status, retenção LGPD e housekeeping (procedures do Postgres), feriados; 500/exit 1 quando o job falha, 409 na 2ª execução do dia de um job de mensagem; trilha com origem cron:<job> ou comando:<job>.
UC26	Receber webhooks	Serviços externos, Sistema / Cron externo	WhatsApp: handshake e eventos assinados (captura a nota de NPS e o pedido de "PARAR", que revoga lembrete e pesquisa por WhatsApp). Zenvia: status de entrega com IP permitido e/ou segredo no header (tempo constante).
UC27	Agendar pela recepção	Administrador (ADMIN)	Buscar cliente (sem acento) ou cadastrar nova (nome, telefone com DDD, e-mail opcional — na mesma transação), escolher procedimento, profissional que o realiza e horário do SlotService (revalidado no servidor, motivo detalhado da recusa); valor do dia (promoção) ou combinado; services/agenda.agendar_pela_recepcao

			cria o atendimento AGENDADO, enfileira o e-mail de confirmação à cliente e audita; aviso de ficha pendente.
UC28	Moderar depoimentos	Administrador (ADMIN)	No painel de NPS, aprovar (só com opt-in da cliente e comentário) ou retirar depoimentos do site; auditado.
UC29	Gerir autorizações de comunicação	Administrador (ADMIN)	Na ficha da cliente: ver o estado de cada finalidade × canal, revogar a pedido da cliente e registrar autorização com justificativa (origem PAINEL, autor); o histórico é preservado e o mais recente vale.
UC30	Assinar o feed iCal da agenda	Profissional, Administrador (ADMIN)	Gerar o link do feed iCal (no portal ou no painel): o link anterior é revogado e a URL aparece uma única vez; o banco guarda só o hash do token.
UC31	Consultar minhas comissões	Profissional	No portal, "Minhas comissões" do mês (?mes=, pela data do atendimento): cada crédito com a base, a regra e o status, os totais por status e o saldo a receber, sem nome de cliente; só leitura.
UC32	Contatar a clínica pelo site	Visitante / Cliente (público, sem login)	Preenche nome, e-mail, telefone opcional, assunto e mensagem e aceita a política; o sistema confere captcha, honeypot, limite por IP e o teto diário global e envia ao e-mail de contato da clínica (reply-to = a pessoa); sem envio, a página mantém o texto e oferece o WhatsApp. Nada fica no banco.
UC33	Revogar o consentimento de saúde	Cliente cadastrada, Administrador (ADMIN)	Na área "Meus agendamentos" (ou a equipe, a pedido, pela ação do Django admin com motivo): o sistema grava cliente.saude_revogada_em e a trilha; os alertas passam a mostrar a revogação; a ficha feita fica pelo prazo de guarda; um aceite SAÚDE novo reativa.

8. Modelo de Domínio (Diagramas de Classes)

Os diagramas de classes são gerados a partir dos models (docs/uml/gerar_uml.py): atributos com o tipo Python, enumerações (TextChoices), métodos públicos — inclusive a máquina de estados do atendimento — e os QuerySets de domínio. Cada diagrama mostra as associações que saem das classes da parte; as classes de outras partes aparecem em cinza, só com o nome.

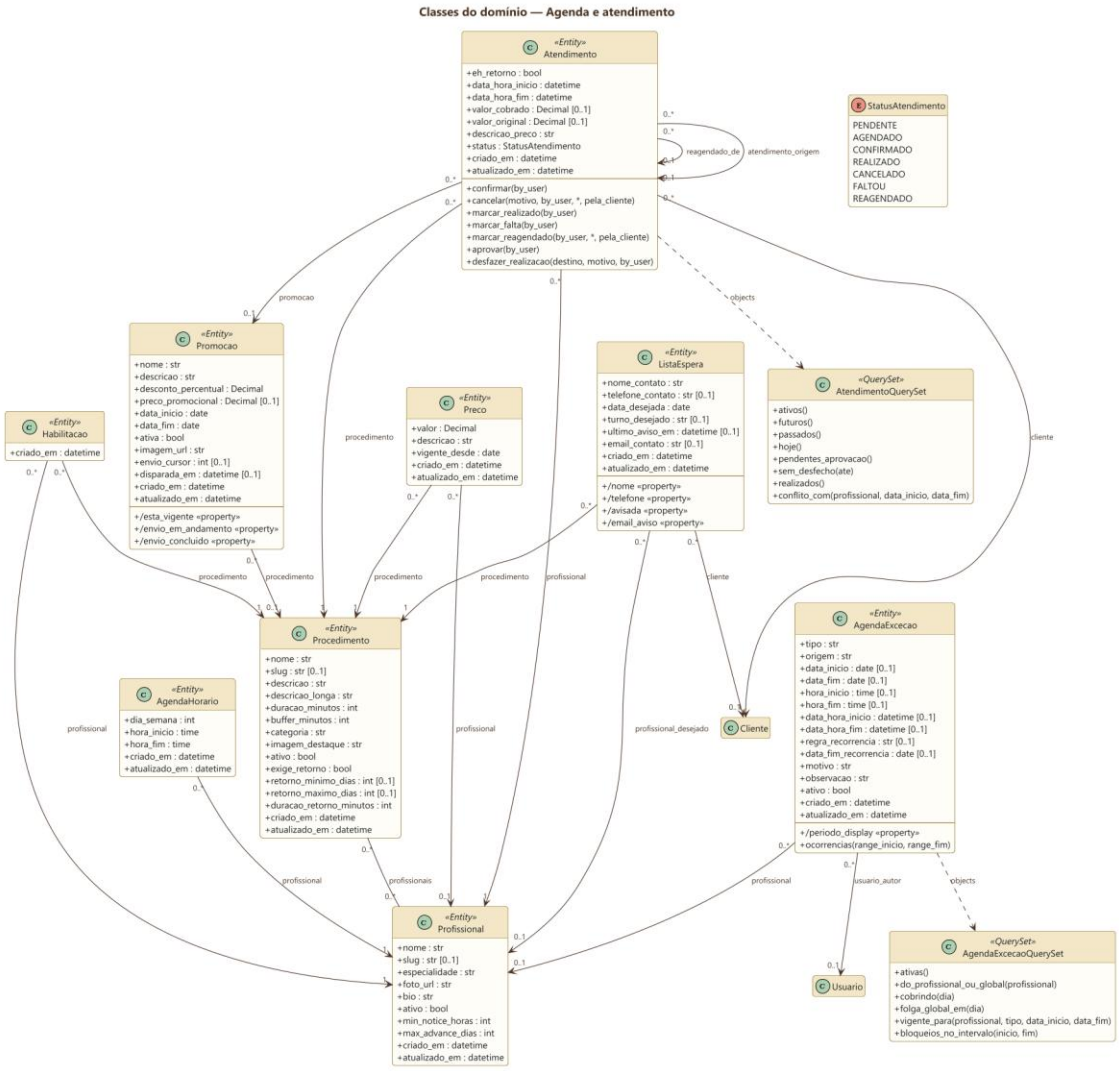


Figura 8 — Classes — agenda e atendimento.

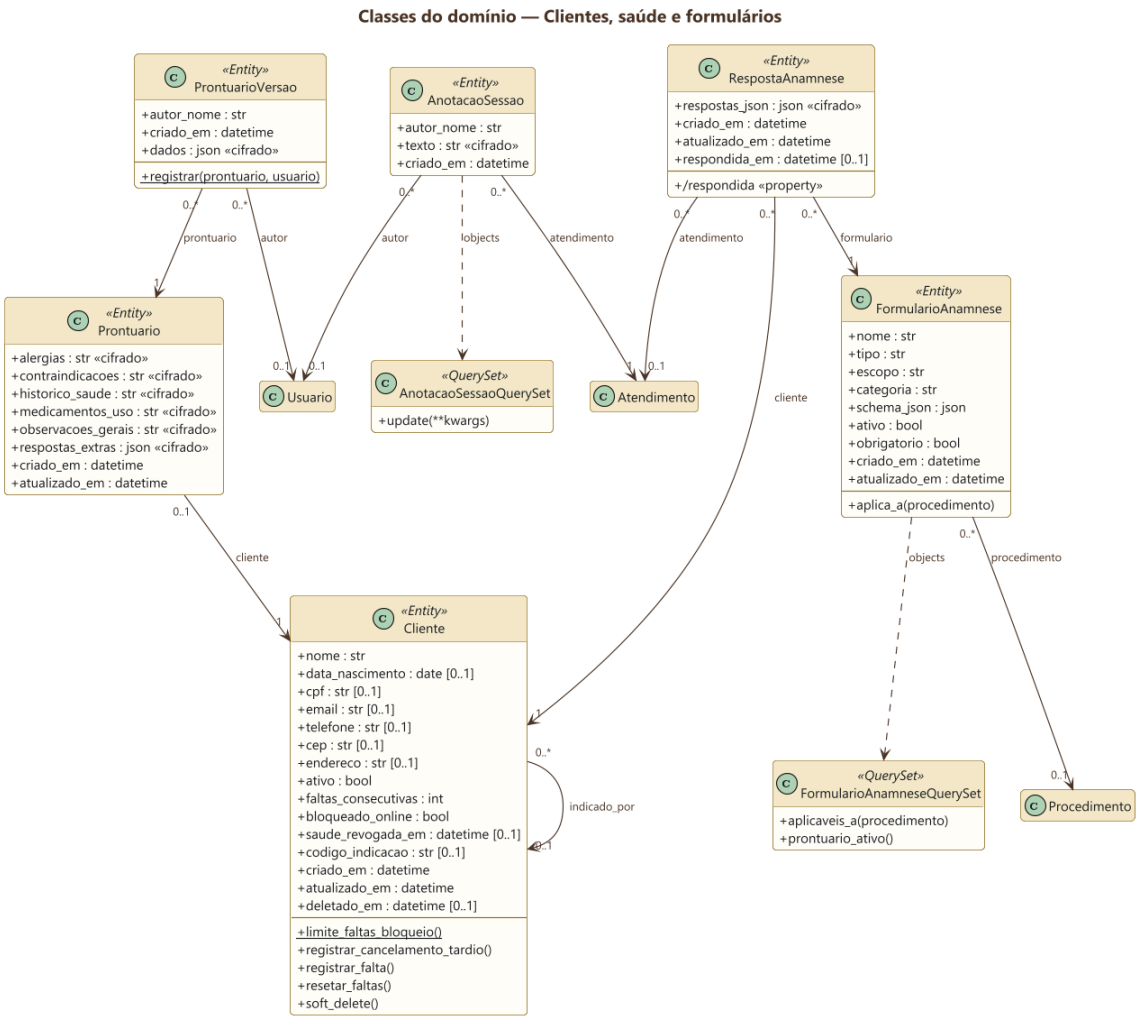


Figura 9 — Classes — clientes, saúde e formulários.

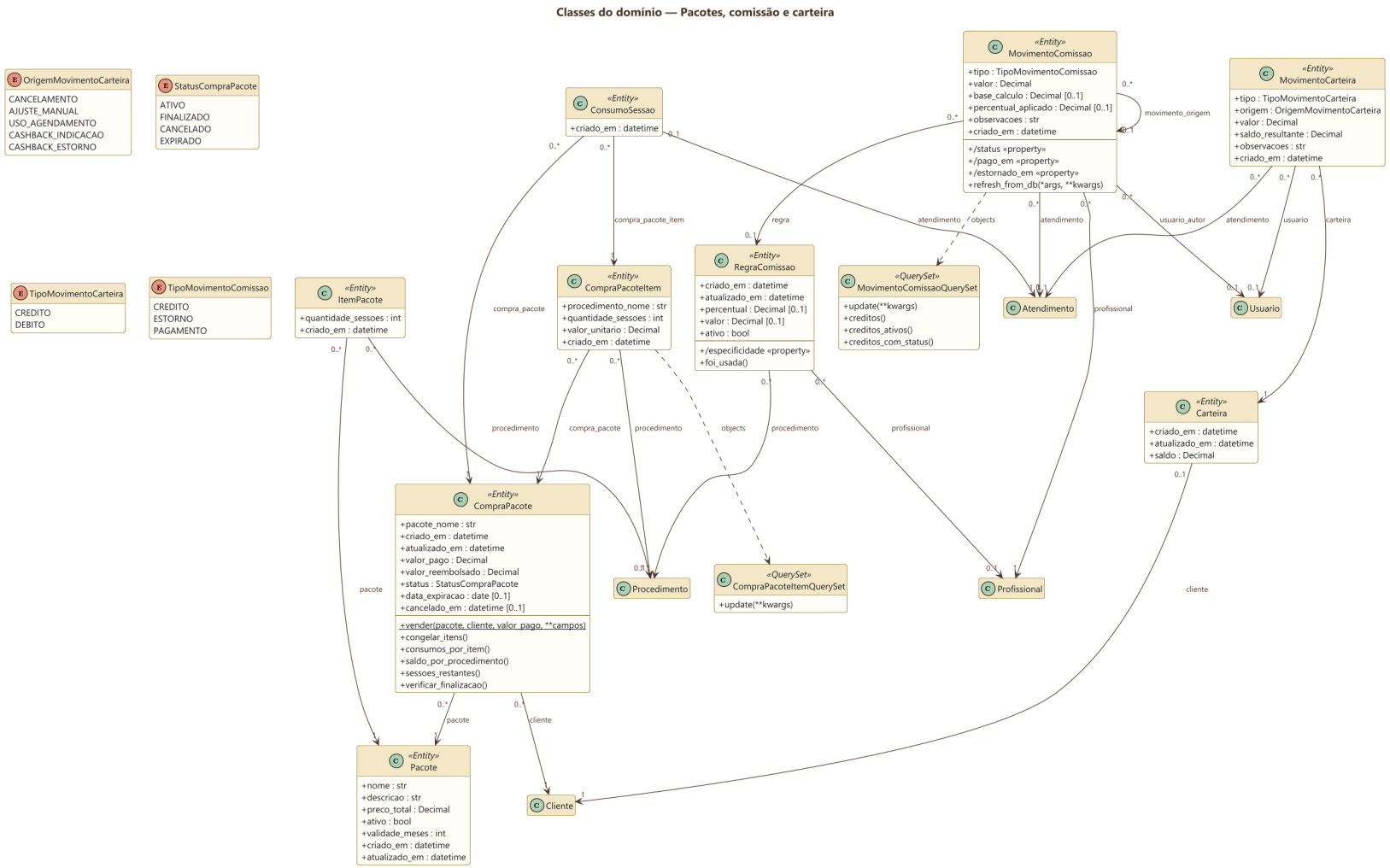


Figura 10 — Classes — pacotes, comissão e carteira.

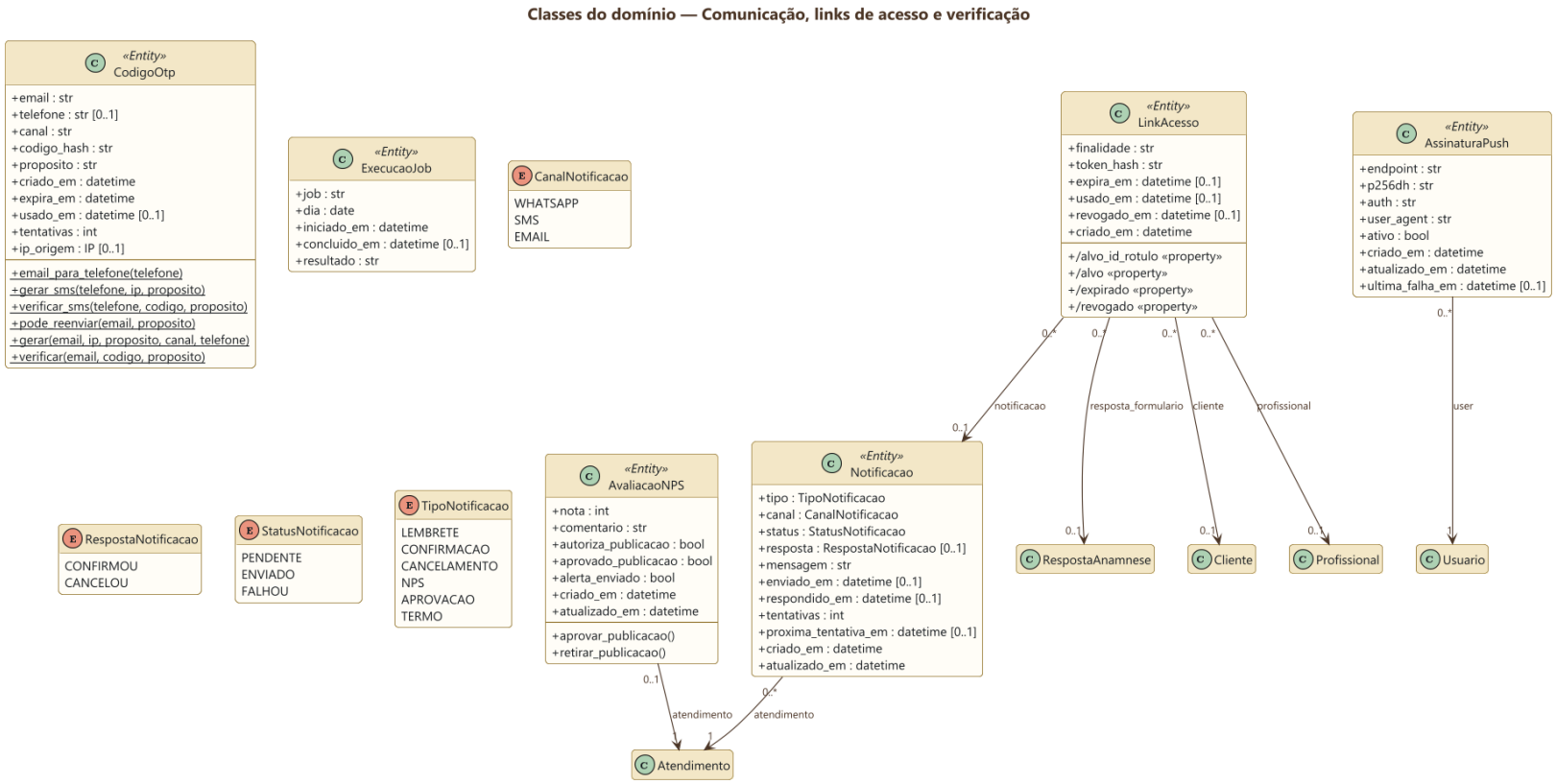


Figura 11 — Classes — comunicação, links de acesso e verificação.

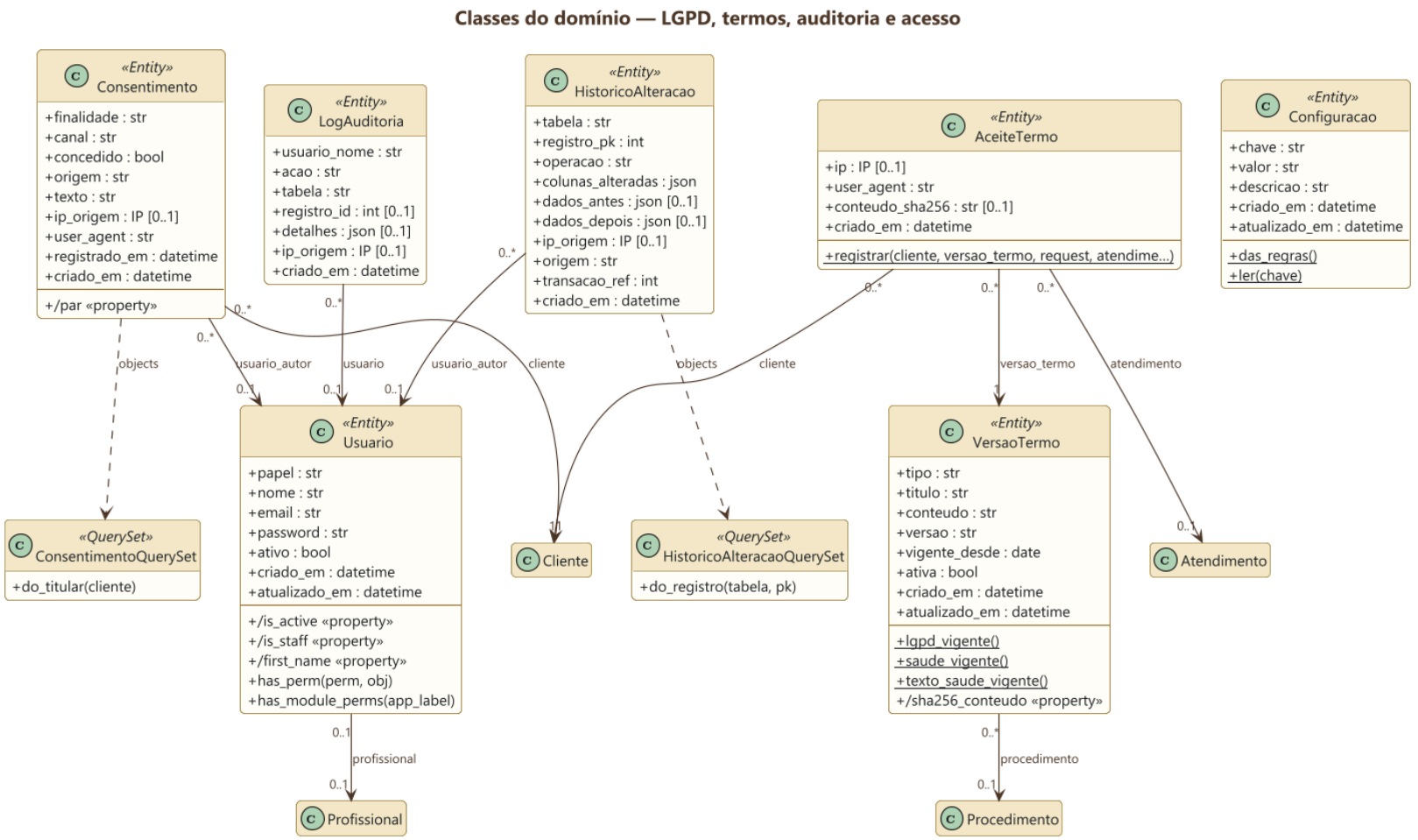


Figura 12 — Classes — LGPD, termos, auditoria e acesso.

8.1 Dicionário de entidades

Entidade	Tabela	Descrição
Cliente	cliente	Cliente da clínica: identidade pelo celular (só dígitos, 10–11, único entre ativas); e-mail, CPF, nascimento, CEP e endereço opcionais (ausente = NULL) — CPF, CEP e endereço só pela finalidade (nota fiscal e contrato de pacote); RG, profissão e foto não são coletados (saíram na 0074); contador de faltas (FALTOU e cancelamento tardio somam) e bloqueio do agendamento online; revogação do consentimento de dado de saúde (saude_revogada_em, 0075); indicação (código próprio + indicadora, base do cashback); exclusão lógica (deletado_em). As autorizações de comunicação ficam na tabela consentimento (histórico, 0050).
Profissional	profissional	Profissional que atende: antecedência mínima (0–720 h, padrão 2) e máxima (1–365 dias, padrão 60), dados de vitrine (especialidade, foto, biografia). A agenda vai para o calendário dela só pelo feed iCal (link_acesso FEED_ICS); o Google Agenda saiu na 0071.
AgendaHorario	agenda_horario	Grade semanal de atendimento do profissional: várias janelas por dia, sem sobreposição (EXCLUDE), dia_semana ISO (1 = segunda … 7 = domingo). Substitui disponibilidade_profissional (0048).
AgendaExcecao	agenda_excecao	Tudo o que muda a grade numa data (0048 unificou exceção, bloqueio e feriado): FOLGA (intervalo de datas; sem profissional = clínica inteira — feriado nacional/local ou recesso), HORARIO_DIFERENTE (substitui a grade num dia) e BLOQUEIO (instantes, pontual ou recorrente por RRULE DAILY/WEEKLY/MONTHLY; sem profissional = todos). Origem MANUAL, FERIADO_NACIONAL, FERIADO_LOCAL ou RECESSO (GCAL saiu na 0071); inativa = registrada e ignorada.
Procedimento	procedimento	Serviço do catálogo: duração, intervalo após a sessão (0–120 min), categoria, imagem e regra de retorno obrigatório (janela mínima/máxima em dias e duração do retorno, padrão 30 min). Todo atendimento é presencial (modalidade e videoconferência saíram na 0073).
Habilitacao	habilitacao	Liga profissional e procedimento (M2M through): só atende quem está habilitado; procedimento sem nenhuma habilitação sai do agendamento (0062).
Preco	preco	Preço versionado por data de início de vigência (data local), base (sem profissional) ou por profissional; o atendimento usa o preço da data do atendimento (profissional > base).
Promocao	promocao	Promoção por período: desconto percentual (0–100) XOR preço fixo; procedimento nulo = promoção geral (só percentual vale). Aplica-se só quando reduz o valor. Vale pela data do atendimento. O disparo por e-mail guarda o estado na própria linha (envio_cursor = último cliente reservado num lote em andamento, disparada_em = início do último disparo; 0068): disparo único, reenvio só confirmado.
Atendimento	atendimento	Agendamento/sessão: cliente, profissional, procedimento, período, preço gravado (valor cobrado, valor original, promoção e descrição), retorno (eh_retorno + atendimento de origem), atendimento que este substitui (reagendamento) e FSM de 7 estados. Sem token próprio: links públicos em link_acesso.
Notificacao	notificacao	Toda mensagem ligada a um atendimento (LEMBRETE — o D-1, por WhatsApp ou e-mail —, CONFIRMACAO, CANCELAMENTO, NPS, APROVACAO, TERMO; LEMBRETE_2H e

		PESQUISA, sem produtor, saíram na 0073) por canal (WhatsApp, SMS, e-mail) e status PENDENTE/ENVIADO/FALHOU. Também é a fila do e-mail transacional (tentativas, próxima tentativa; 0061); não guarda cópia de dado pessoal.
LinkAcesso	link_acesso	Link público com token (confirmar presença, NPS, termo, ficha, descadastro, feed iCal): finalidade + exatamente 1 alvo (notificação, ficha, cliente ou profissional); o banco guarda só o SHA-256 do token, a validade, o uso e a revogação (0049). O token em claro existe só na URL entregue. O legado GERENCIAR_AGENDAMENTO e o alvo atendimento saíram na 0072: reagendar/cancelar é só pelo portal com OTP.
Usuario	usuario	Usuário da equipe (login por e-mail): papel ADMIN ou PROFISSIONAL (RECEPCAO saiu na 0072); is_staff = ADMIN; vínculo opcional 1:1 com Profissional; desativar em vez de excluir.
AssinaturaPush	assinatura_push	Inscrição Web Push (VAPID) de um usuário da equipe, para o aviso de novo agendamento.
LogAuditoria	log_auditoria	Trilha de auditoria das ações (LGPD art. 37): autor + snapshot "Nome <email>", ação, tabela, registro, detalhes com PII mascarada e IP. Append-only no banco (0059): só a purga com 180+ dias, a pseudonimização do esquecimento e o SET NULL do autor.
HistoricoAlteracao	historico_alteracao	Trilha de dados gravada por trigger (0056) nas 11 tabelas sensíveis: operação, colunas alteradas com antes/depois (senha redigida), autor, IP, origem (web, cron, comando, migração) e transação. Append-only; leitura auditada.
Consentimento	consentimento	Histórico append-only de autorizações de comunicação por finalidade × canal (MARKETING/E-MAIL, LEMBRETE_AGENDAMENTO/WHATSAPP, PESQUISA_SATISFACAO/WHATSAPP): concedido ou revogado, origem (inclusive WHATSAPP: o "PARAR" respondido no WhatsApp, 0069; e PORTAL: "Minhas preferências" da área da cliente, 0075), texto exibido, IP, navegador, autor e data. Vale a linha mais recente do par; sem linha = não concedido (0050). O consentimento de dado de saúde fica fora desta tabela: a concessão é o aceite SAÚDE e a revogação é cliente.saude_revogada_em.
Prontuario	prontuario	Ficha base 1:1 da cliente preenchida pela equipe: alergias, contraindicações, histórico, medicamentos, observações e respostas do questionário do prontuário (formulário PRONTUARIO, 0051). Conteúdo cifrado em repouso (0060). Expurgado 20 anos depois do último evento de saúde da cliente (etapa saude do sp_purgar_dados_expirados, 0077).
ProntuarioVersao	prontuario_versao	Histórico append-only do prontuário: foto do estado anterior a cada edição (cifrada), com autor e data. DELETE só no expurgo de saúde aos 20 anos (flag local + idade, 0077).
AnotacaoSessao	anotacao_sessao	Anotação da sessão de um atendimento (texto cifrado), com autor preservado (PROTECT + snapshot do nome). Append-only: correção = nova anotação. DELETE só no expurgo de saúde aos 20 anos (fn_anotacao_sessao_imutavel, 0077).
FormularioAnamnese	formulario	Questionário em lista de perguntas (key, tipo, rótulo, obrigatória, opções, alerta de saúde): ANAMNESE e PESQUISA respondidas pela cliente e PRONTUARIO (perguntas extras da ficha, preenchidas pela equipe — no máximo 1 ativo, sempre global e não obrigatório). Escopo global, categoria ou procedimento (MODALIDADE saiu na 0073). Tabela formulario.

RespostaAnamnese	resposta_formulario	Ficha respondida pela cliente (respostas cifradas), ligada ao atendimento; o convite por link vive em link_acesso (FORMULARIO, 60 dias). Tabela resposta_formulario.
VersaoTermo	versao_termo	Termo versionado: LGPD (Política de Privacidade), SAUDE (consentimento para dado de saúde, art. 11) ou PROCEDIMENTO (geral ou de um procedimento); 1 versão ativa por escopo; imutável depois do 1º aceite. A v1.0 LGPD é a Política de Privacidade completa (conteudo/lgpd.py; 0045, seed e 0078) e a página /politica-de-privacidade/ mostra a versão vigente.
AceiteTermo	aceite_termo	Prova de aceite de termo: cliente, versão, atendimento, IP, navegador e SHA-256 do texto aceito. Nunca apagado; só a minimização LGPD muda (IP e navegador saem na pseudonimização — LGPD — e no expurgo de saúde — SAÚDE/PROCEDIMENTO; 0077).
CodigoOtp	codigo_otp	Desafio OTP de 6 dígitos guardado como HMAC-SHA256, preso ao telefone, com propósito AGENDAMENTO, LOGIN_CLIENTE ou DSAR, validade de 10 min e até 5 tentativas.
AvaliacaoNPS	avaliacao_nps	Avaliação NPS 0–10 de um atendimento: comentário, autorização de publicação da cliente, aprovação da clínica (só com a autorização) e alerta de detrator enviado.
ListaEspera	lista_espera	Pedido de aviso de vaga: procedimento, data, turno e profissional desejado opcionais. Anônima (nome_contato + telefone_contato, sem criar cliente) ou ligada à cliente quando o celular foi verificado por OTP — só então aceita e-mail de contato. O aviso grava ultimo_aviso_em e a inscrição continua na fila até a data passar ou a cliente agendar (0076).
Pacote	pacote	Catálogo de pacotes de sessões: valor total e validade em meses. Editável a qualquer momento — vale só para vendas futuras (o vendido fica congelado em compra_pacote_item).
ItemPacote	pacote_item	Item do catálogo do pacote: procedimento e quantidade de sessões. Tabela pacote_item.
CompraPacote	compra_pacote	Venda de pacote a uma cliente: nome do pacote congelado, valor pago, valor reembolsado, status ATIVO/FINALIZADO/CANCELADO/EXPIRADO, data de expiração (prorrogável) e cancelado_em (o reembolso deduz a receita do mês do cancelamento — competência, 0065).
CompraPacoteItem	compra_pacote_item	O que foi vendido (snapshot imutável, 0052): procedimento, nome, quantidade de sessões e valor unitário (valor pago rateado pelo preço de tabela de cada procedimento no dia da venda; uniforme se falta preço — base da comissão da sessão de pacote).
ConsumoSessao	consumo_sessao	Consumo de 1 sessão de um item da compra por um atendimento REALIZADO (OneToOne com o atendimento): mesmo procedimento, mesma compra, nunca retorno e só com saldo.
Carteira	carteira	Saldo de crédito da cliente (programa de indicação: crédito, uso no valor do atendimento e devolução); CHECK saldo ≥ 0.
MovimentoCarteira	movimento_carteira	Lançamento do livro-razão da carteira (crédito/débito, origem, saldo resultante, autor); imutável por trigger; 1 cashback por atendimento. Só origens com fluxo, sempre explícitas (VALE_PRESENTE e OUTRO saíram na 0067).
RegraComissao	regra_comissao	Regra de comissão por profissional e/ou procedimento: percentual (0–100) XOR valor fixo; regra já usada não muda nem se exclui — só desativa (tg_regra_comissao_validar e RegraComissao.save, 0066).
MovimentoComissao	movimento_comissao	Livro-razão da comissão (0053): CREDITO (no máximo 1 ativo

		— não estornado — por atendimento realizado, 0063; com a regra e o snapshot da base e do percentual, 0066), PAGAMENTO (baixa ou repasse em lote, com autor) e ESTORNO (cancelamento), os dois últimos referenciando o crédito. Status e saldo são derivados; o saldo pode ficar negativo (comissão paga e depois estornada).
ExecucaoJob	execucao_job	Trava "uma vez por dia" dos jobs de mensagem sem marca por destinatário (aniversario, pacote_expirando, nps_24h): a linha do dia local nasce antes do job e o UNIQUE job + dia faz a 2ª chamada receber 409 em vez de reenviar (0070). Sem dado pessoal.
Configuracao	configuracao	Chave-valor com dois donos: a marca e os contatos (tela Identidade visual, utils/branding) e as regras operacionais — registro tipado models/configuracao.CHAVES (email_admin: e-mail válido ou vazio; MAX_FALTAS_BLOQUEIO: inteiro de 1 a 10, padrão 3), editado na tela Regras operacionais, sem chave livre.
TimestampedMixin [ABSTRATO]	(abstract — sem tabela)	ABSTRATO: adiciona criado_em + atualizado_em com DEFAULT now() no banco (usado por Carteira e RegraComissao).

9. Camada de Serviços (Casos de Uso da Aplicação)

As views só traduzem HTTP: validam a entrada e chamam os serviços, onde vivem as regras de negócio e os efeitos colaterais. Os diagramas abaixo são gerados por análise do código (AST): cada módulo com suas operações públicas e as dependências entre módulos.

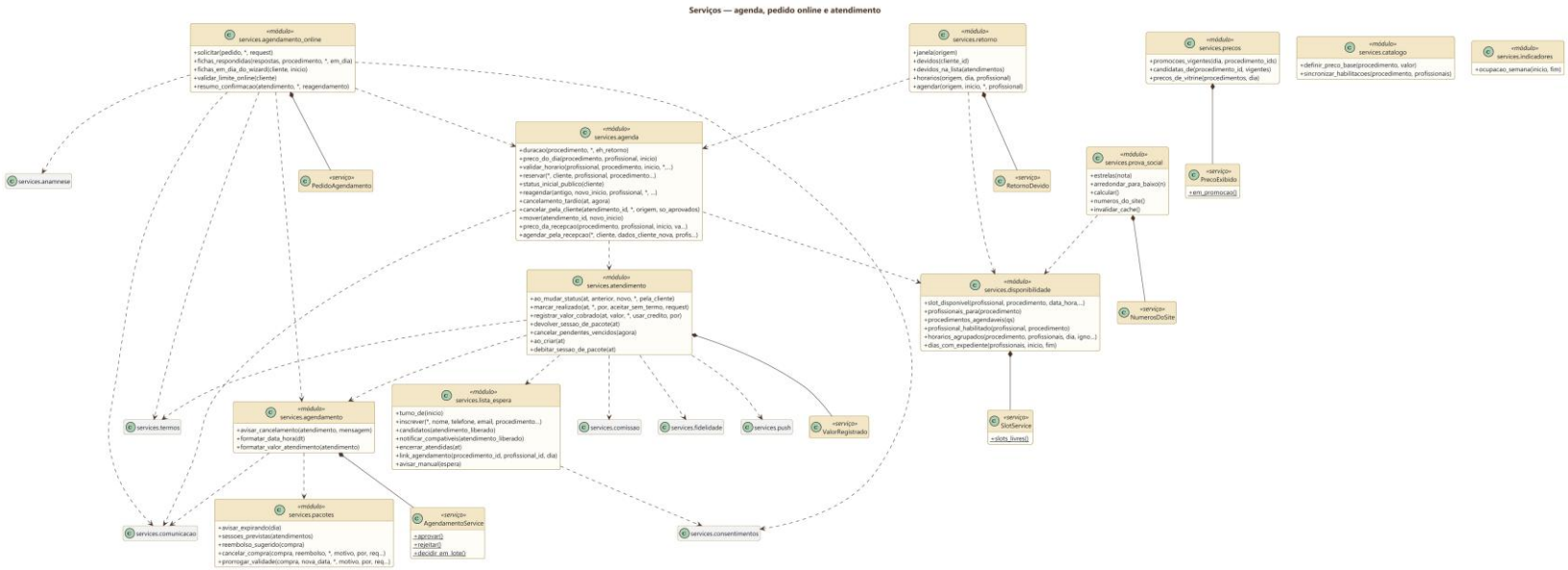


Figura 13 — Serviços — agenda, pedido online e atendimento.

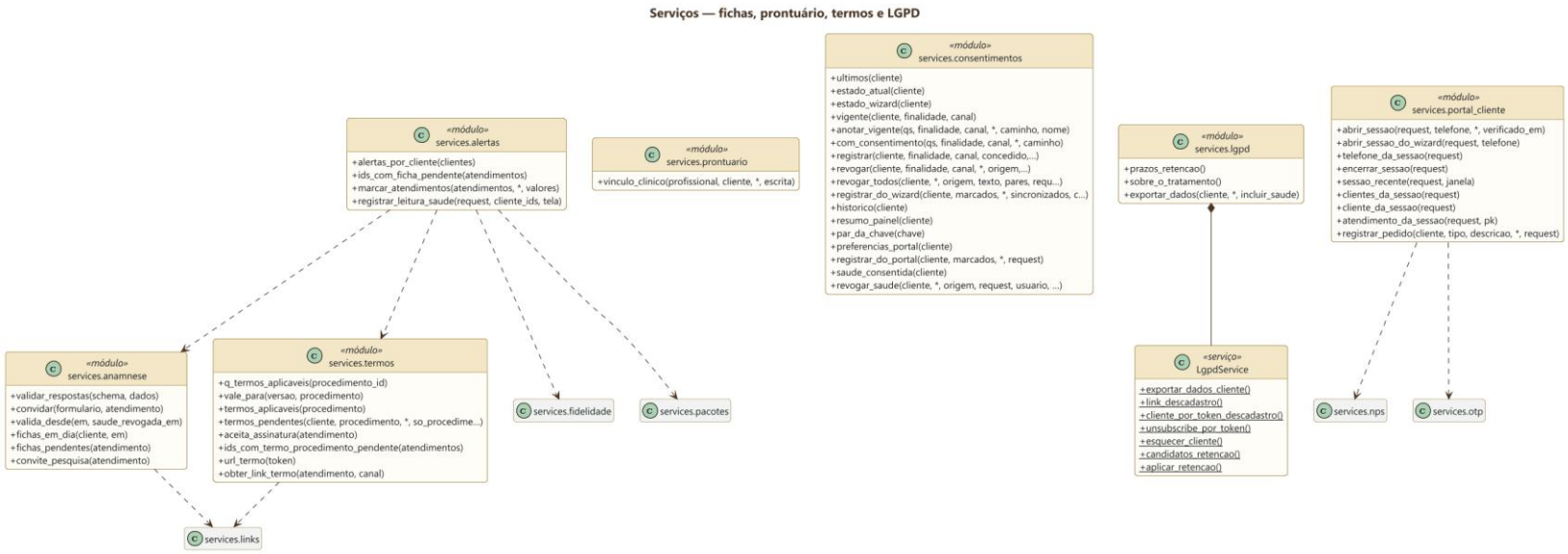


Figura 14 — Serviços — fichas, prontuário, termos e LGPD.

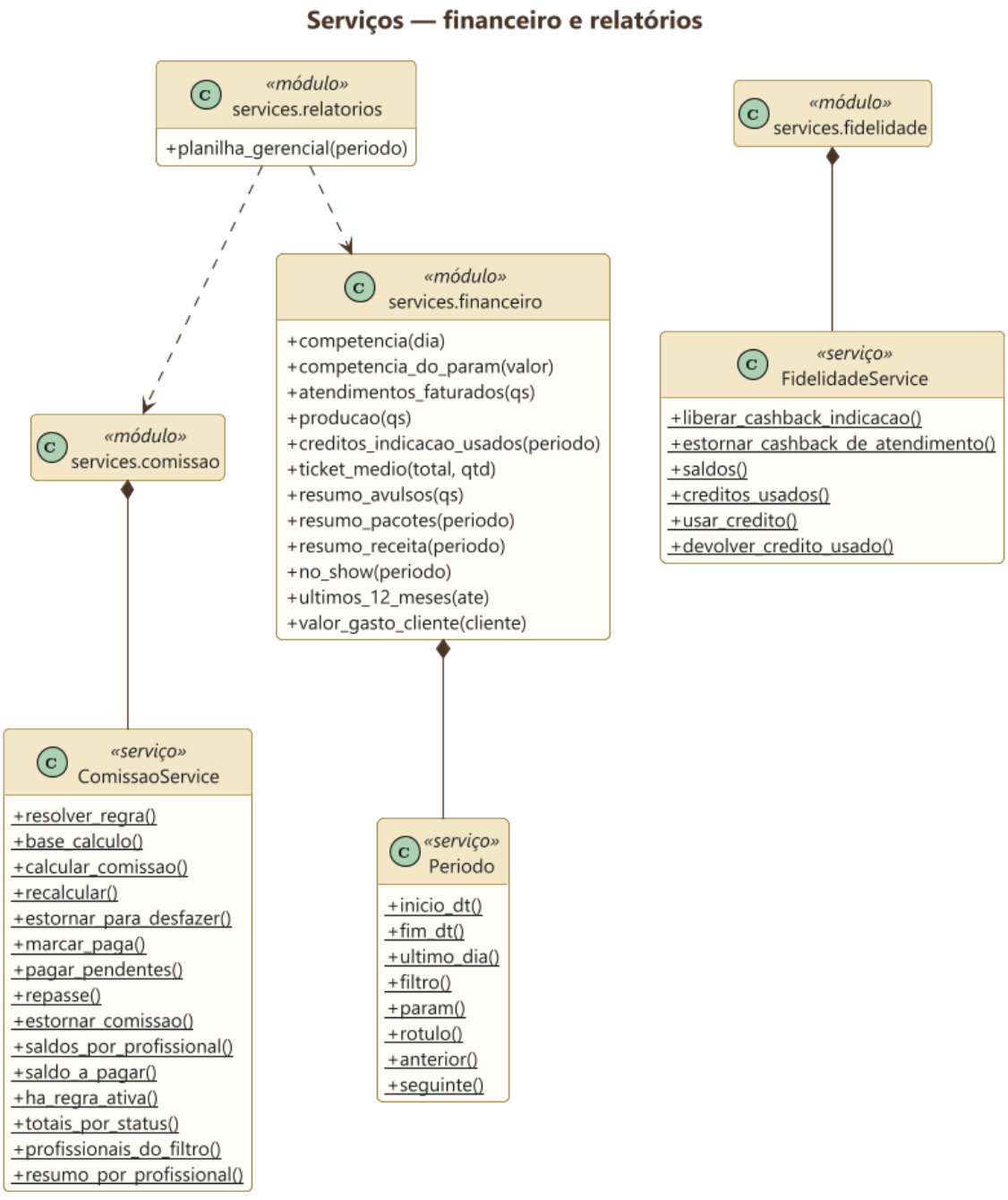


Figura 15 — Serviços — financeiro e relatórios.

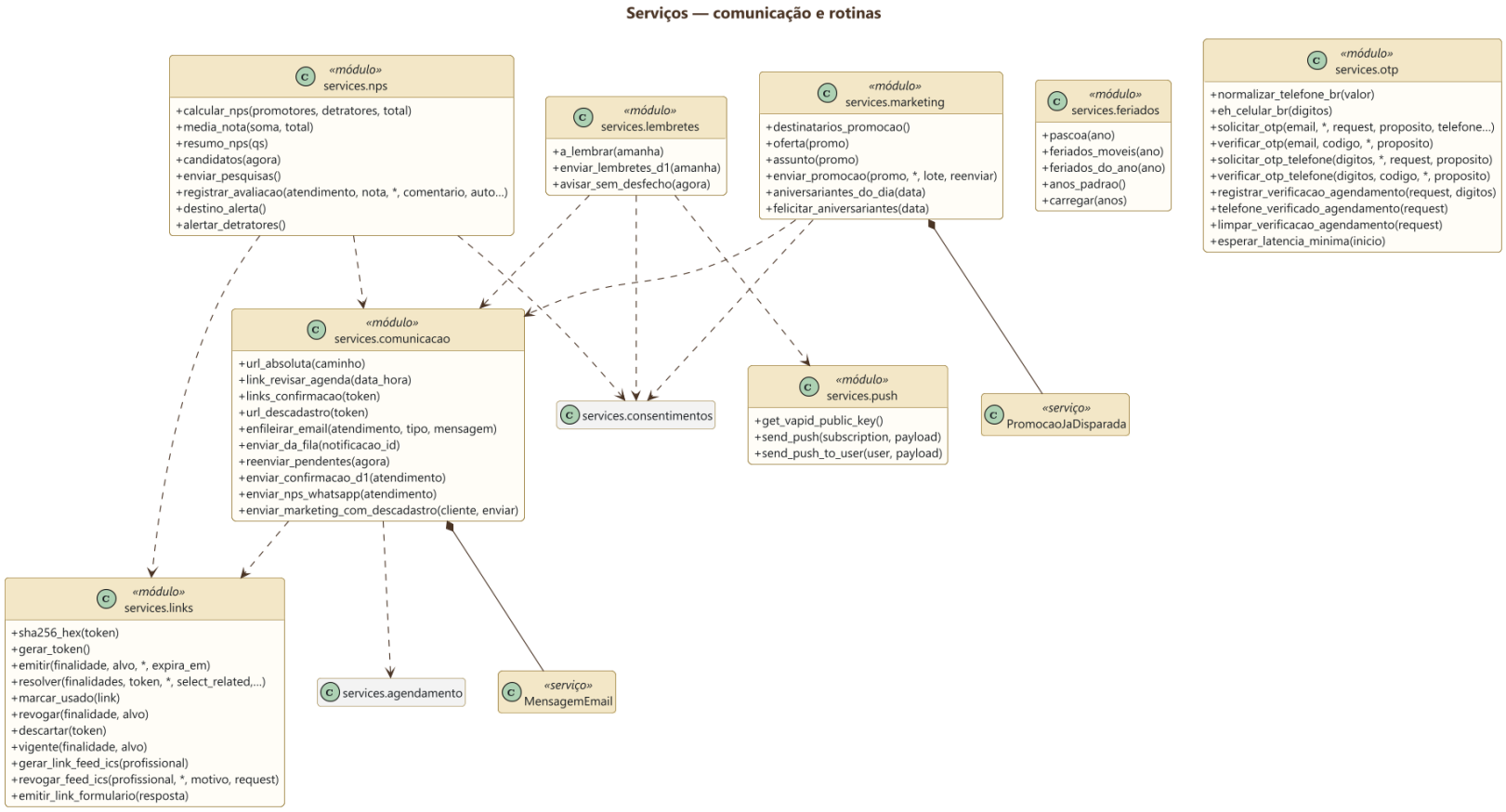


Figura 16 — Serviços — comunicação e rotinas.

9.1 Responsabilidade de cada serviço

Módulo	Responsabilidade (docstring do módulo)
services.agenda	Agenda: reservar, reagendar e mover atendimentos — fonte unica das regras de horario.
services.agendamento	Application Service de agendamento — aprovacao/rejeicao pelo painel.
services.agendamento_online	Caso de uso: pedido de agendamento pelo site (wizard publico, sem login).
services.alertas	Alertas de saude e marcadores em lote p/ listas (agenda do portal, agendamentos do painel).
services.anamnese	Validacao das respostas de ficha de anamnese contra o schema do formulario.
services.atendimento	Caso de uso do atendimento: TODOS os efeitos de criar e de mudar status, em ordem, num lugar.
services.catalogo	Catalogo de procedimentos: preco base versionado e quem realiza (Habilitacao).
services.comissao	Comissao Profissional — livro-razao (docs/specs/padrao-sql.md §4.f, migration 0053).
services.comunicacao	Comunicacao: o caso de uso de cada mensagem, o historico (Notificacao) e a fila de e-mail.
services.consentimentos	Consentimentos de comunicacao com historico (spec padrao-sql §4.c — migration 0050).
services.disponibilidade	SlotService — calculo de horarios disponiveis de um profissional.
services.feriados	Feriados nacionais: a regra (fixos + moveis pela Pascoa) e a carga na agenda.
services.fidelidade	F-CSB — Programa de Fidelidade por Indicacao.
services.financeiro	Regras de faturamento (D20) por COMPETENCIA MENSAL — fonte unica p/ visao geral, financeiro, Excel
services.indicadores	Indicadores do painel com definicao explicita (o que o numero quer dizer fica no codigo).
services.lembretes	Lembretes: o D-1 da cliente e a pendencia de desfecho da profissional.
services.lgpd	Servico de LGPD — DSAR (export), unsubscribe, esquecimento (pseudonimizacao) e retencao.
services.links	Links publicos com token — emitir, resolver, marcar uso, revogar (spec padrao-sql §4.b).
services.lista_espera	Lista de Espera — inscricao e aviso de vaga (decisao 17).
services.marketing	Marketing por e-mail: promocoes disparadas pelo painel e felicitacao de aniversario.
services.nps	NPS: o calculo do painel, quem recebe a pesquisa, o registro da nota e o alerta de detrator.
services.otp	Servico OTP: SMS Zenvia exclusivo (sem fallback email).
services.pacotes	Sessao de pacote PREVISTA: que compra vai cobrir um atendimento ainda nao realizado.
services.portal_cliente	Area da cliente ("Meus agendamentos") — sessao, titular e pedidos LGPD (decisao 39).
services.precos	Preco de vitrine ("A partir de") — a mesma conta do agendamento, em lote.
services.prontuario	Prontuario: quem pode ler/escrever o registro clinico de uma cliente (LGPD art. 11).
services.prova_social	Numeros do site publico (prova social): so aparece o que o banco ou a dona sustentam.
services.push	Web Push (VAPID) — envia notificacoes browser-native.
services.relatorios	Relatorio gerencial em Excel por COMPETENCIA MENSAL — os mesmos numeros do financeiro (D20).
services.retorno	F-RET — Retorno obrigatorio: marcado COM a cliente, nunca pelo sistema.
services.termos	Termos de consentimento: quais versoes valem p/ um atendimento e o que falta aceitar.

10. Diagramas de Estados

O status do atendimento é governado por uma máquina de estados finitos (Atendimento.TRANSICOES): cada transição trava a linha (SELECT FOR UPDATE), valida a origem, grava o status e a auditoria e aplica os efeitos na mesma transação — se um efeito falha, nada é gravado. Transição inválida levanta Atendimento.TransicaoInvalida com mensagem legível.

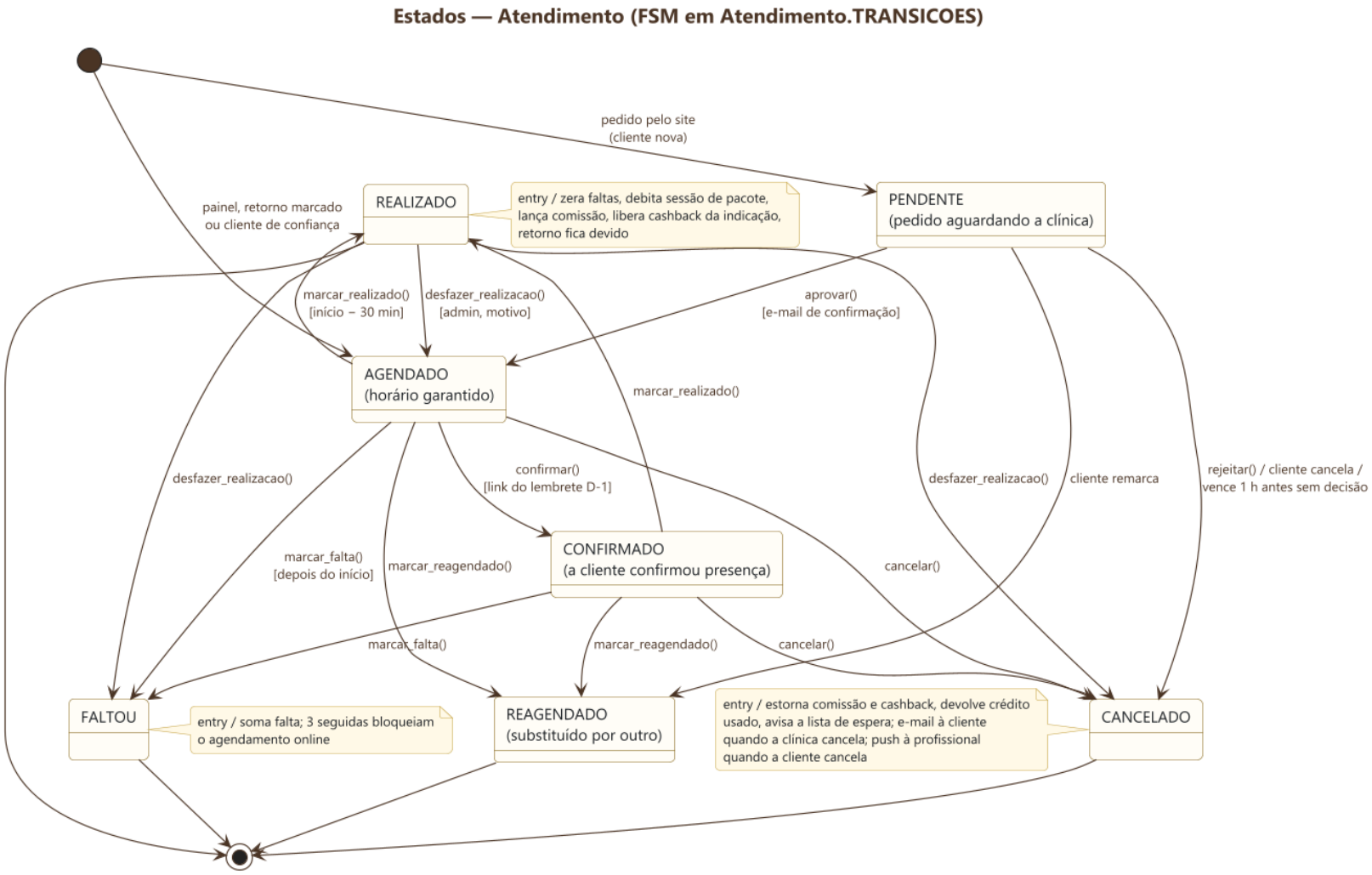


Figura 17 — Estados — Atendimento.

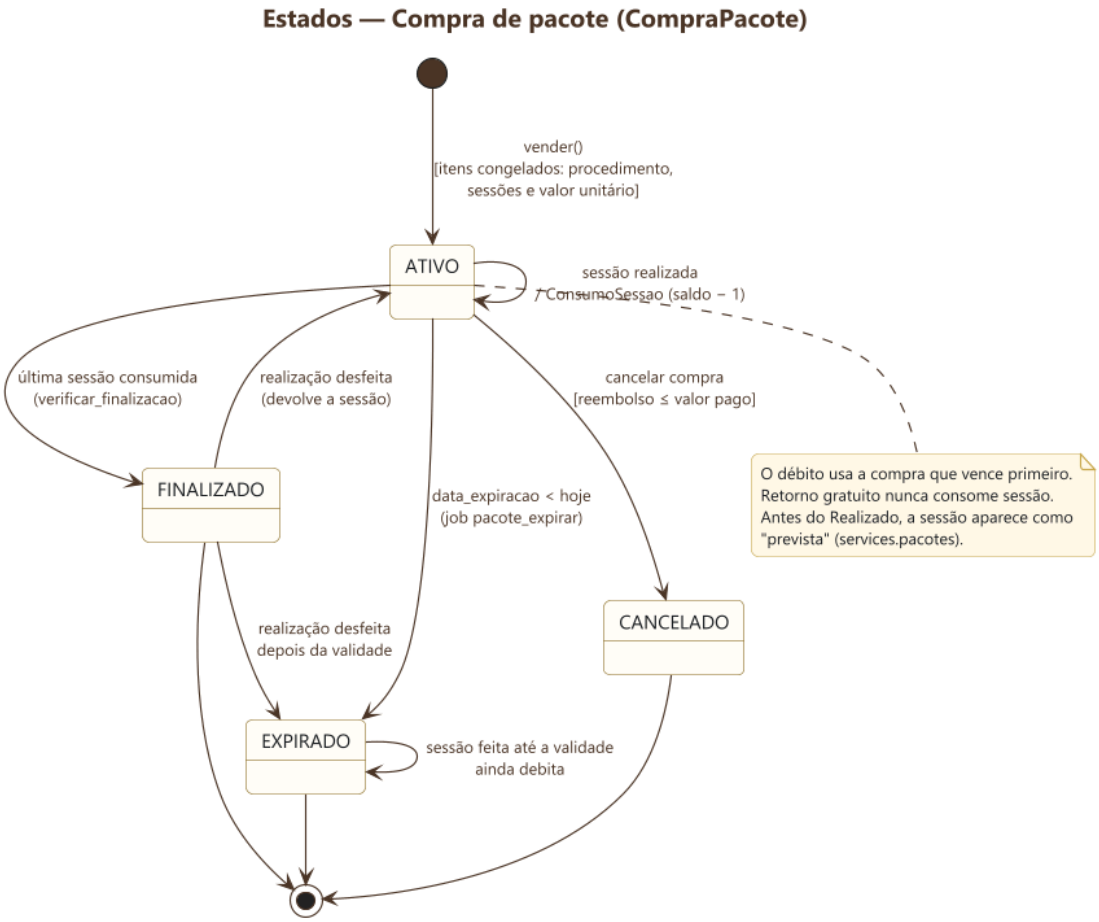


Figura 18 — Estados — compra de pacote.

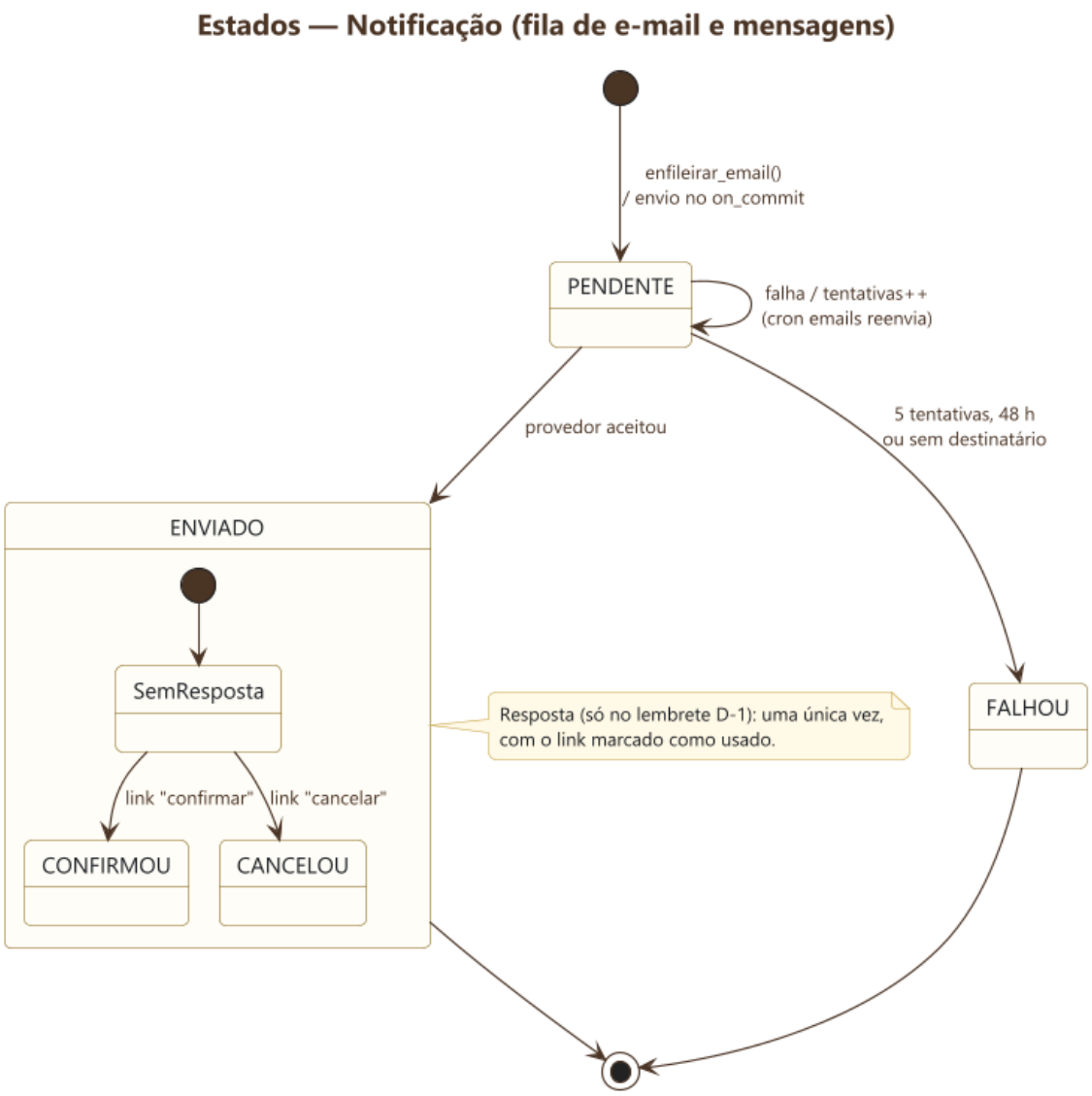


Figura 19 — Estados — notificação (fila de e-mail e mensagens).

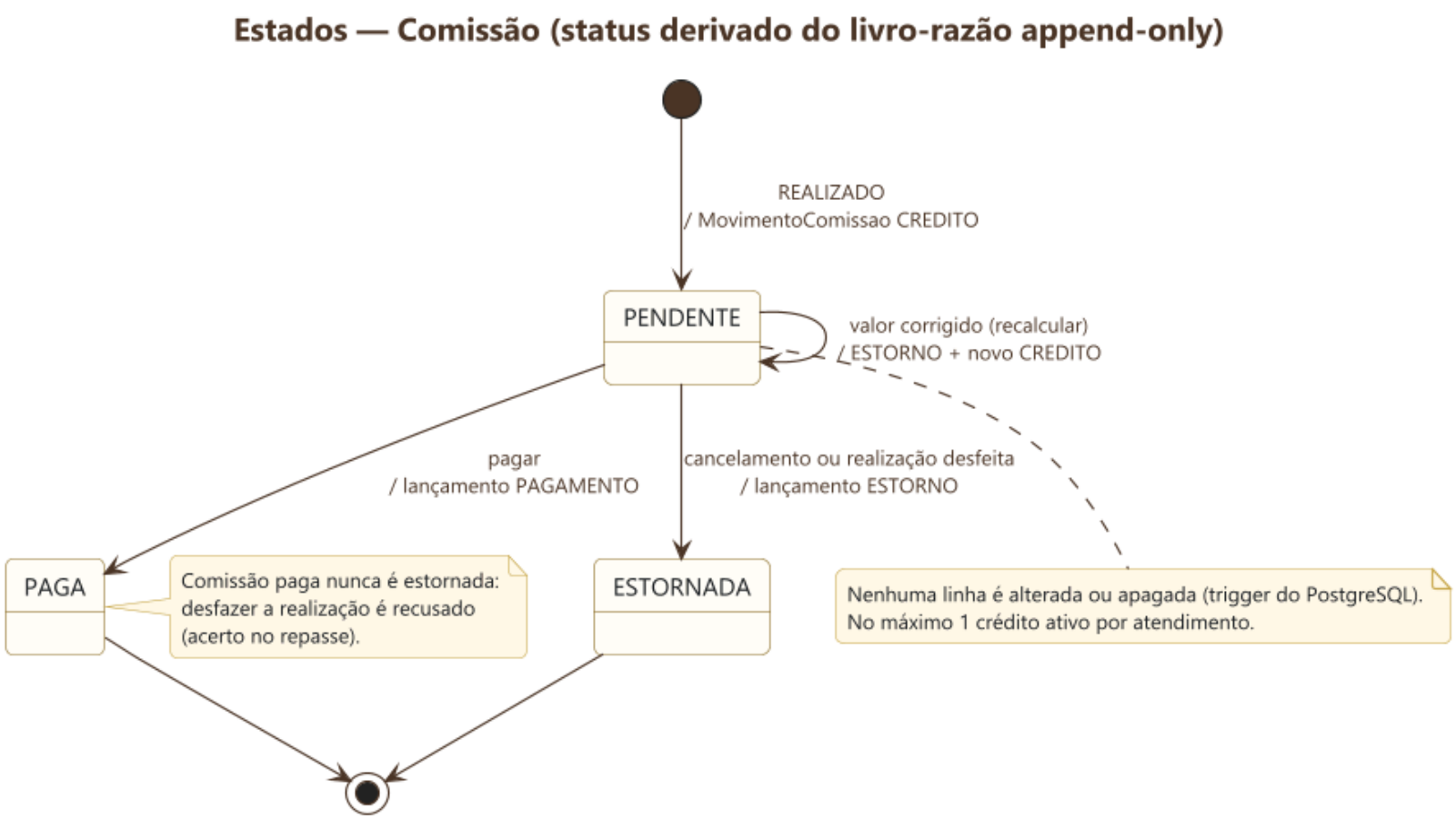


Figura 20 — Estados — comissão (derivado do livro-razão).

10.1 Tabela de transições do atendimento

Estado origem	Estado destino	Ação / gatilho
PENDENTE	AGENDADO	aprovar() — clínica aprova o pedido (botões Aprovar, lote item a item ou portal; sempre pelo AgendamentoService) + e-mail
PENDENTE	CANCELADO	cancelar() — rejeitar pedido, cliente cancela (portal; PENDENTE nunca conta falta) ou job limpeza_status (1 h antes do início, sem aprovação)
PENDENTE	REAGENDADO	marcar_reagendado() — services/agenda.reagendar
AGENDADO	CONFIRMADO	confirmar() — cliente confirma pelo link do lembrete D-1 ou equipe
AGENDADO	REALIZADO	marcar_realizado() — só a partir do início; exige termo aceito ou override auditado (services/atendimento.marcar_realizado, painel e portal)
AGENDADO	CANCELADO	cancelar() — clínica, ou a cliente (portal/link; com menos de 24 h é cancelamento tardio e soma 1 falta)
AGENDADO	FALTOU	marcar_falta() — só a equipe, a partir do início
AGENDADO	REAGENDADO	marcar_reagendado() — services/agenda.reagendar
CONFIRMADO	REALIZADO	marcar_realizado() — só a partir do início; exige termo aceito ou override auditado (services/atendimento.marcar_realizado, painel e portal)
CONFIRMADO	CANCELADO	cancelar() — clínica, ou a cliente (portal/link; com menos de 24 h é cancelamento tardio e soma 1 falta)
CONFIRMADO	FALTOU	marcar_falta() — só a equipe, a partir do início
CONFIRMADO	REAGENDADO	marcar_reagendado() — services/agenda.reagendar

10.2 Efeitos automáticos

- Toda transição: _transicionar trava a linha (select_for_update), valida TRANSICOES contra o status atual do banco, grava status + LogAuditoria e aplica os efeitos (services/atendimento.ao_mudar_status) na MESMA transação: efeito que falha desfaz a transição inteira. Transição inválida levanta Atendimento.TransicaoInvalida (a tela mostra a mensagem).
- Criação (services/agenda.reservar → ao_criar): push "Novo agendamento" à profissional no on_commit, best-effort; as inscrições da cliente na lista de espera do procedimento saem da fila (savepoint).
- → REALIZADO, em ordem: zera faltas e desbloqueia a cliente; debita 1 sessão do item congelado do pacote que vence primeiro (nunca em retorno; validade na data da sessão); lança o CREDITO de comissão (base = valor cobrado, ou valor unitário congelado da sessão de pacote); libera o cashback da indicadora no 1º atendimento pago; deixa o retorno obrigatório devido (a recepção marca com a cliente, valor 0) se o procedimento exige.
- → FALTOU: registrar_falta — soma a falta e suspende o agendamento online no limite (padrão 3).
- → CANCELADO: lança o ESTORNO da comissão e estorna o cashback; vindo de um estado ativo, avisa a lista de espera. Cancelado pela clínica: e-mail à cliente (fila de e-mail). Cancelado pela própria cliente com menos de 24 h de um horário aprovado (agenda.cancelar_pela_cliente): cancelamento tardio, soma 1 falta para o bloqueio online.
- → REAGENDADO: vindo de um estado ativo, avisa a lista de espera.
- Lista de espera: seleção dos compatíveis (procedimento, dia, profissional, turno, antecedência mínima) em savepoint na transação de quem liberou a vaga; e-mail e WhatsApp no on_commit só para inscrição ligada ao cadastro; o aviso não tira da fila; falha no aviso nunca desfaz o cancelamento.
- Aprovação (PENDENTE → AGENDADO) e rejeição geram e-mail à cliente pela fila de e-mail (Notificacao EMAIL na mesma transação, envio no on_commit, reenvio pelo job emails).

- NPS e lembrete D-1 não são disparados por transição: vêm dos jobs nps_24h e lembrete_diario (serviço Cron ou cron HTTP); o lembrete vai por WhatsApp a quem autorizou e por e-mail às demais.
- PENDENTE sem aprovação a 1 h do início → CANCELADO pelo job limpeza_status (de hora em hora); AGENDADO/CONFIRMADO sem desfecho nunca viram falta sozinhos: entram no push diário à profissional (job sem_desfecho, 08:00) e a equipe decide falta ou realizado.
- Toda escrita em atendimento entra na trilha historico_alteracao (trigger) com autor, IP e origem.
- Cliente cancela ou remarca (portal; cancelar também pelo link do lembrete): push à profissional no on_commit.
- Pedido criado pela recepção ou aprovado: e-mail de confirmação à cliente (fila de e-mail).

11. Diagramas de Sequência

Do catálogo ao atendimento criado: horários livres calculados pelo SlotService, verificação do celular por SMS, trava do horário e gravação transacional com os aceites e a ficha.

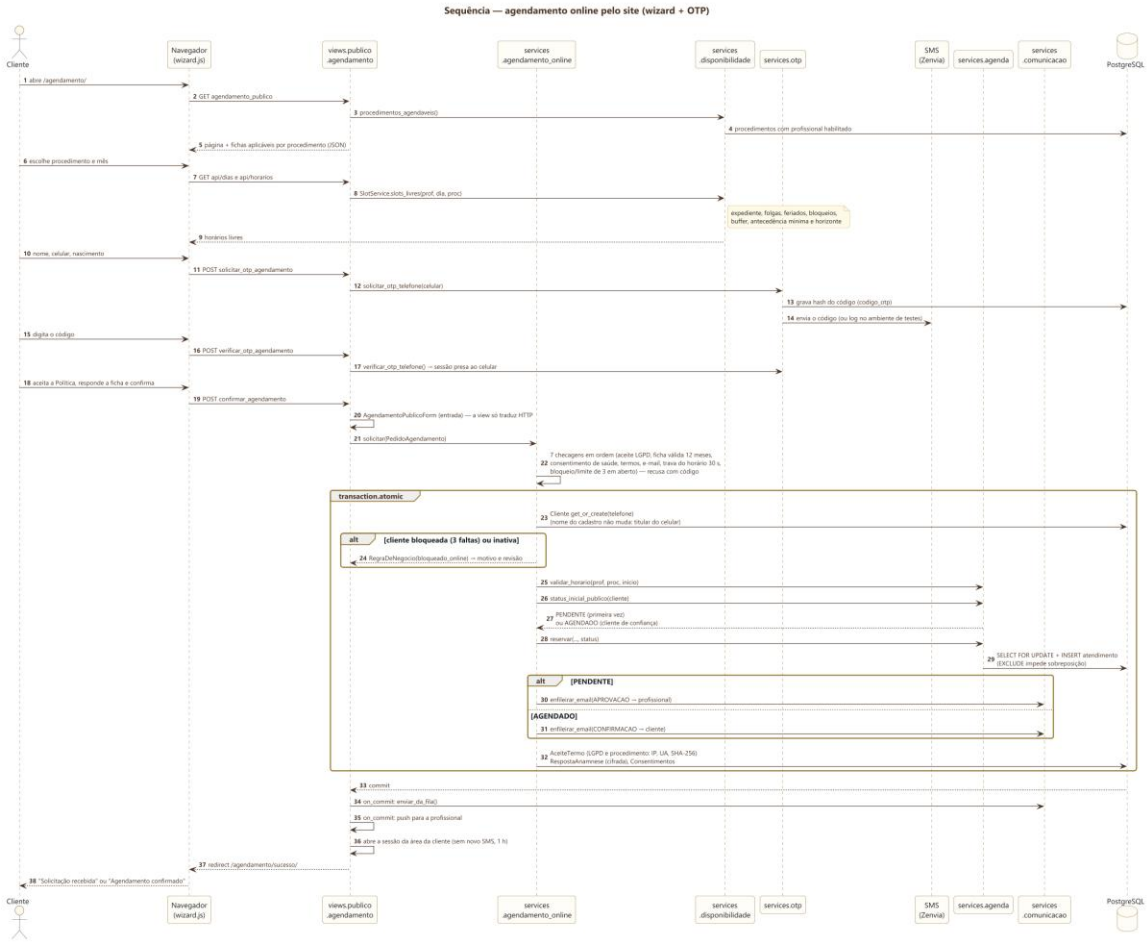


Figura 21 — Sequência — agendamento online (wizard + OTP).

Botão, lote ou seletor de status passam pelo mesmo serviço — a cliente sempre recebe a resposta.

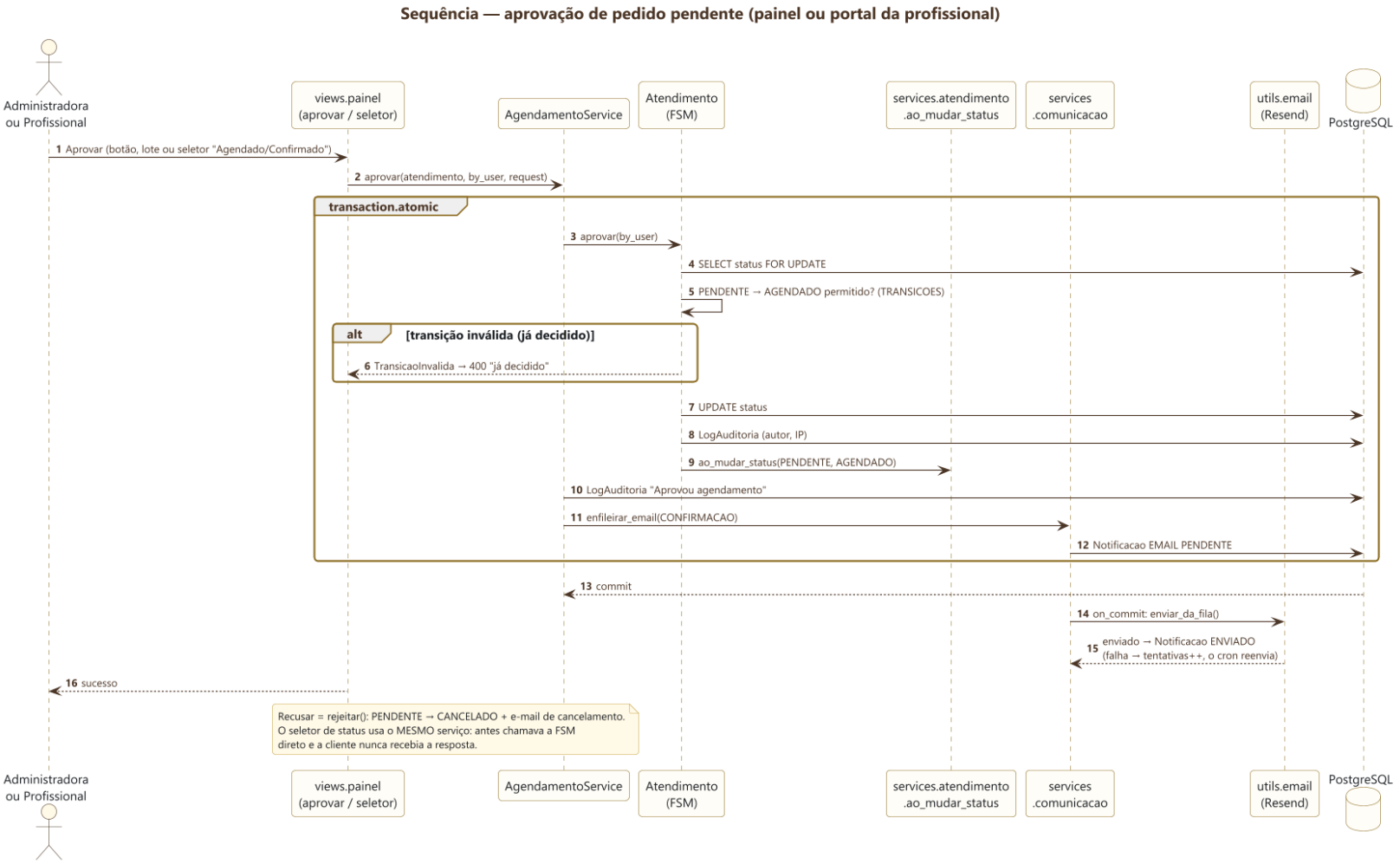


Figura 22 — Sequência — aprovação de pedido pendente.

Faltas, pacote, comissão e cashback na mesma transação, garantidos também por triggers.

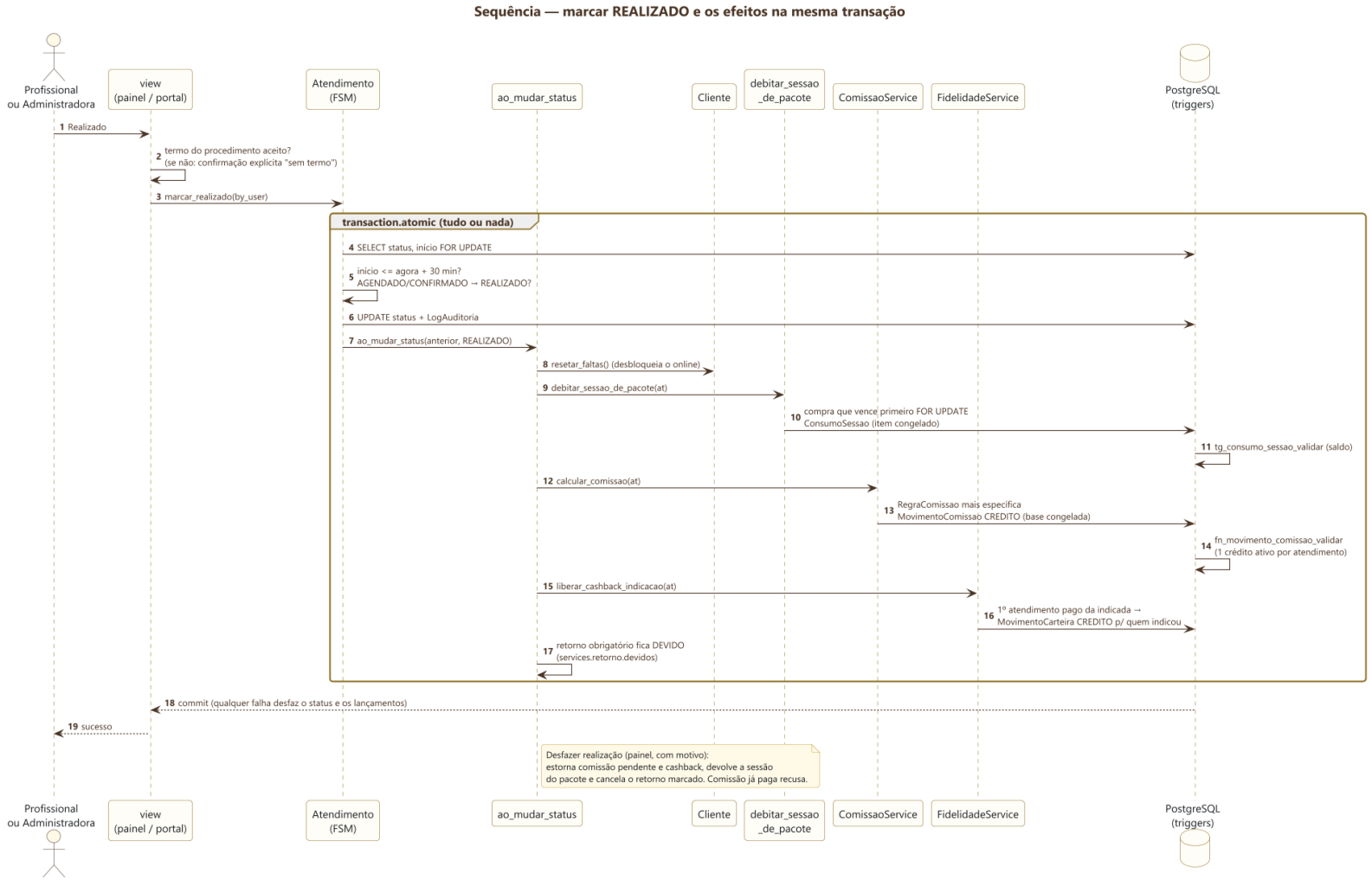


Figura 23 — Sequência — marcar realizado e os efeitos.

Estornos, aviso à lista de espera e push à profissional.

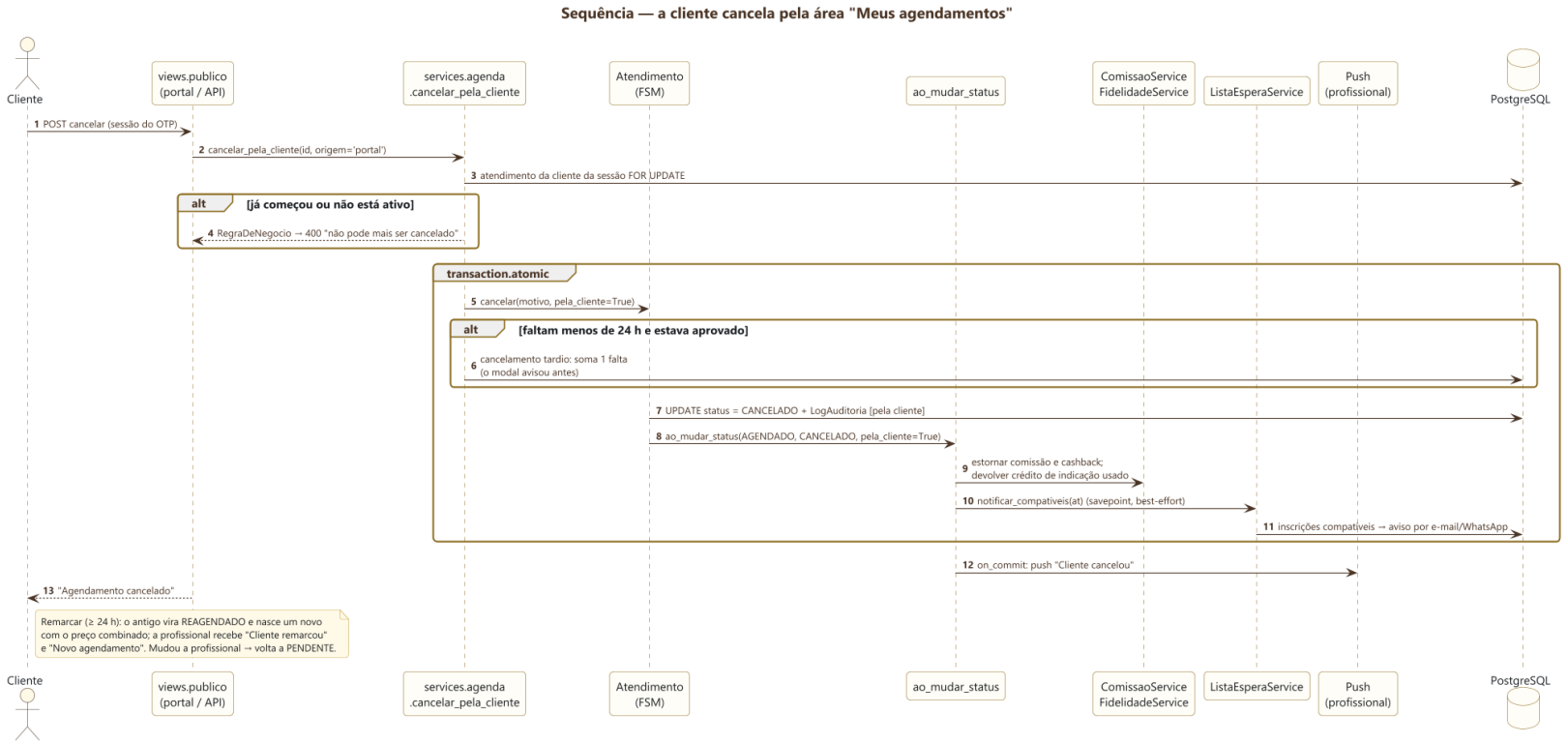


Figura 24 — Sequência — cancelamento pela cliente.

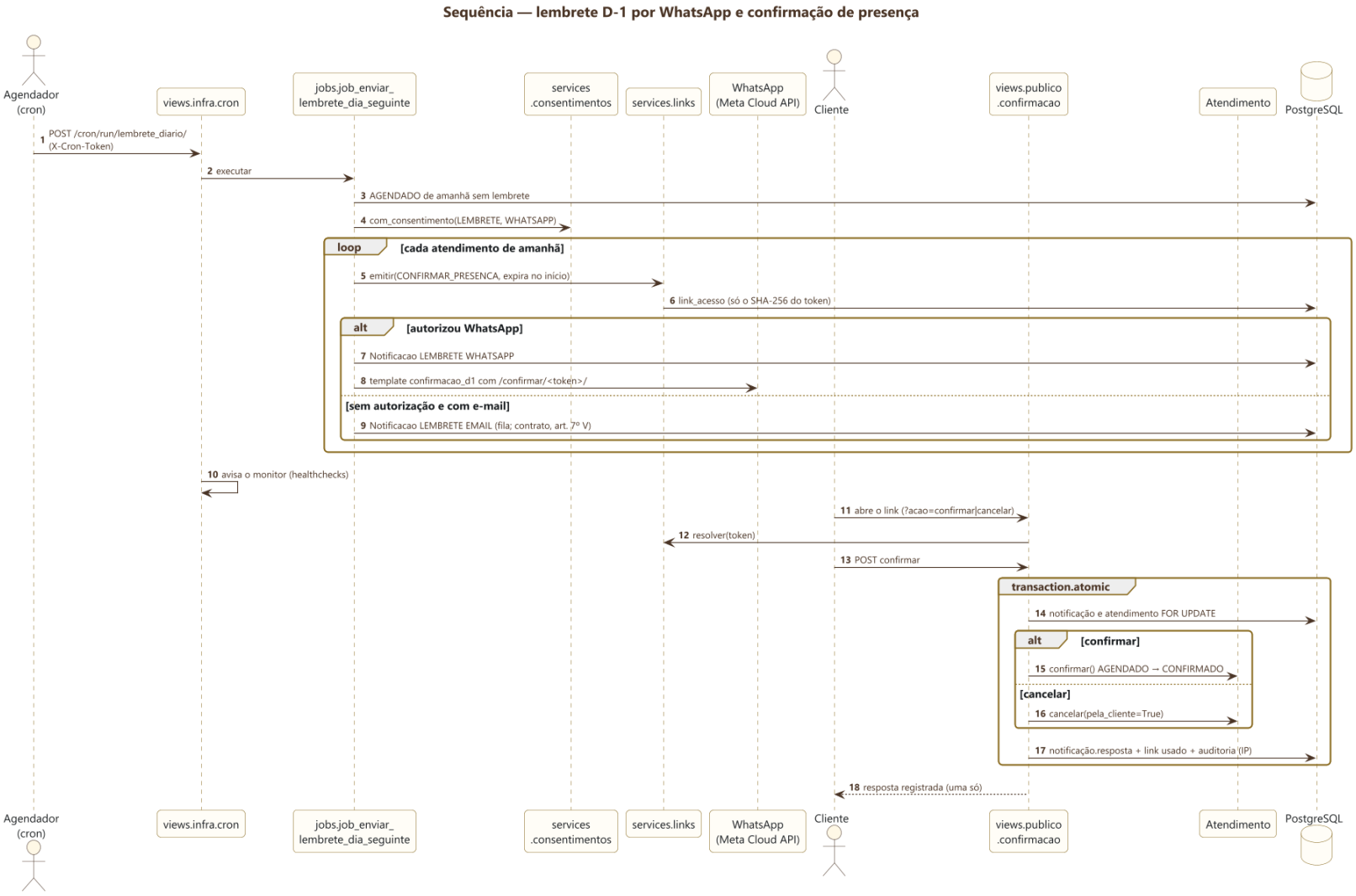


Figura 25 — Sequência — lembrete D-1 e confirmação de presença.

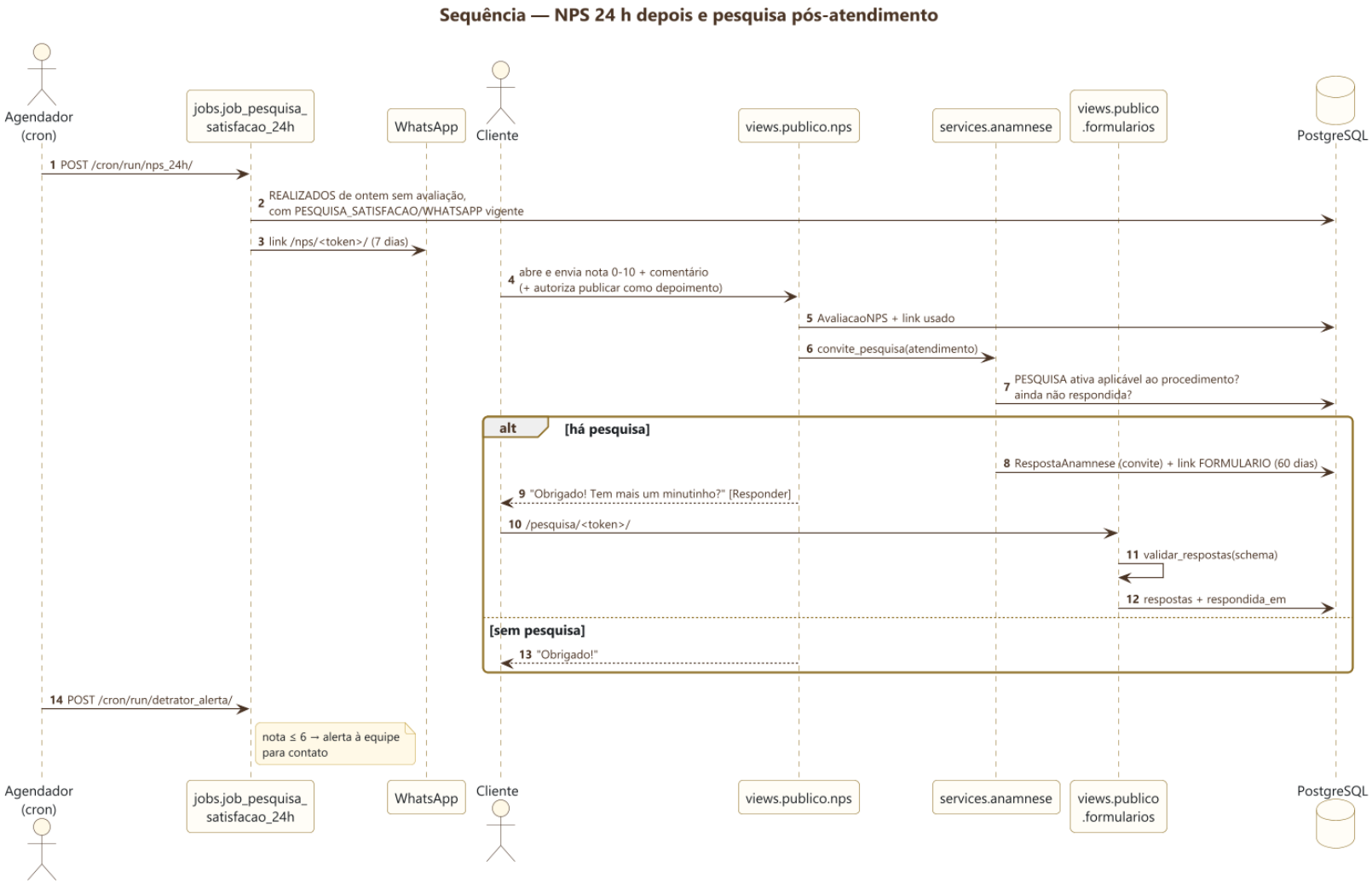


Figura 26 — Sequência — NPS e pesquisa pós-atendimento.

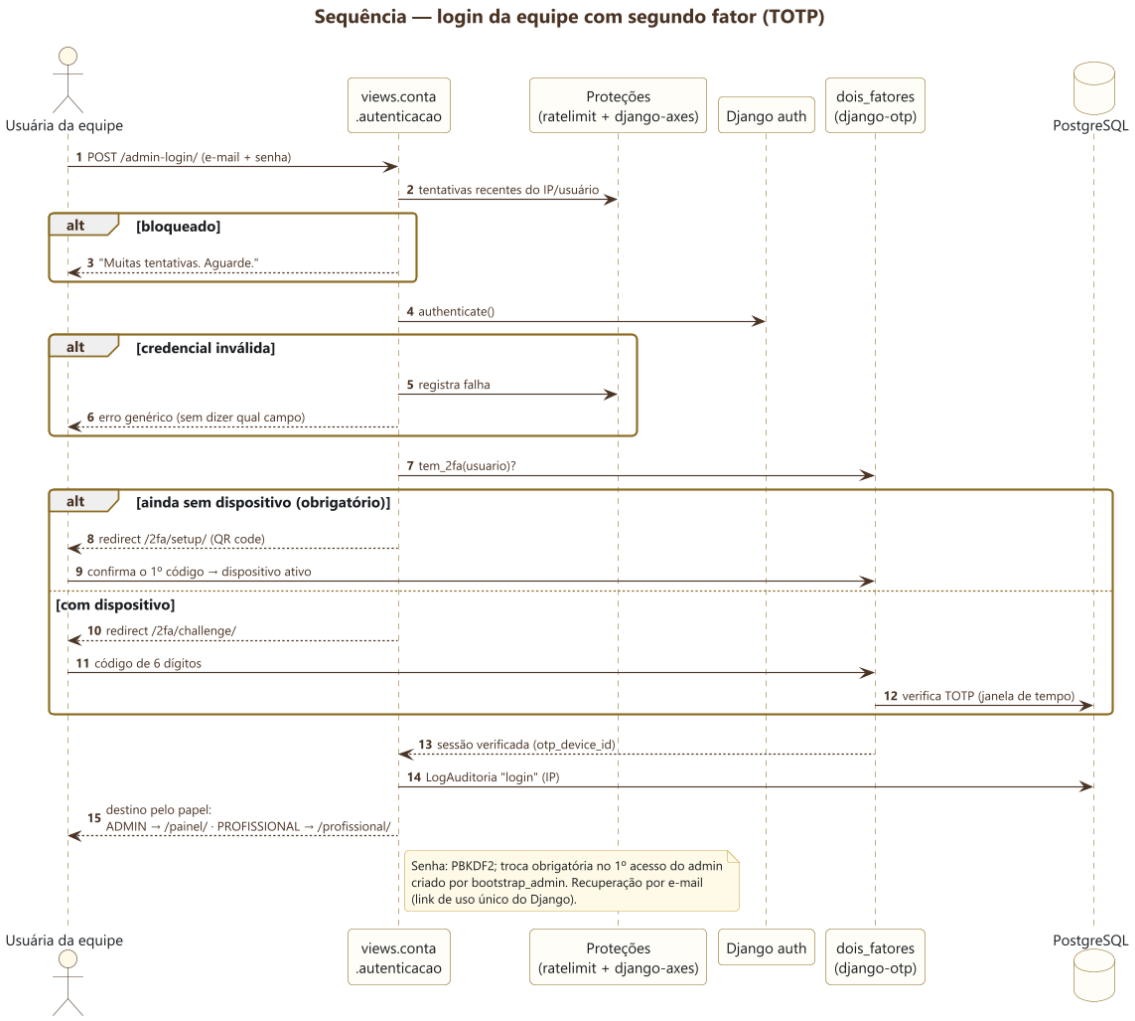


Figura 27 — Sequência — login da equipe com 2FA.

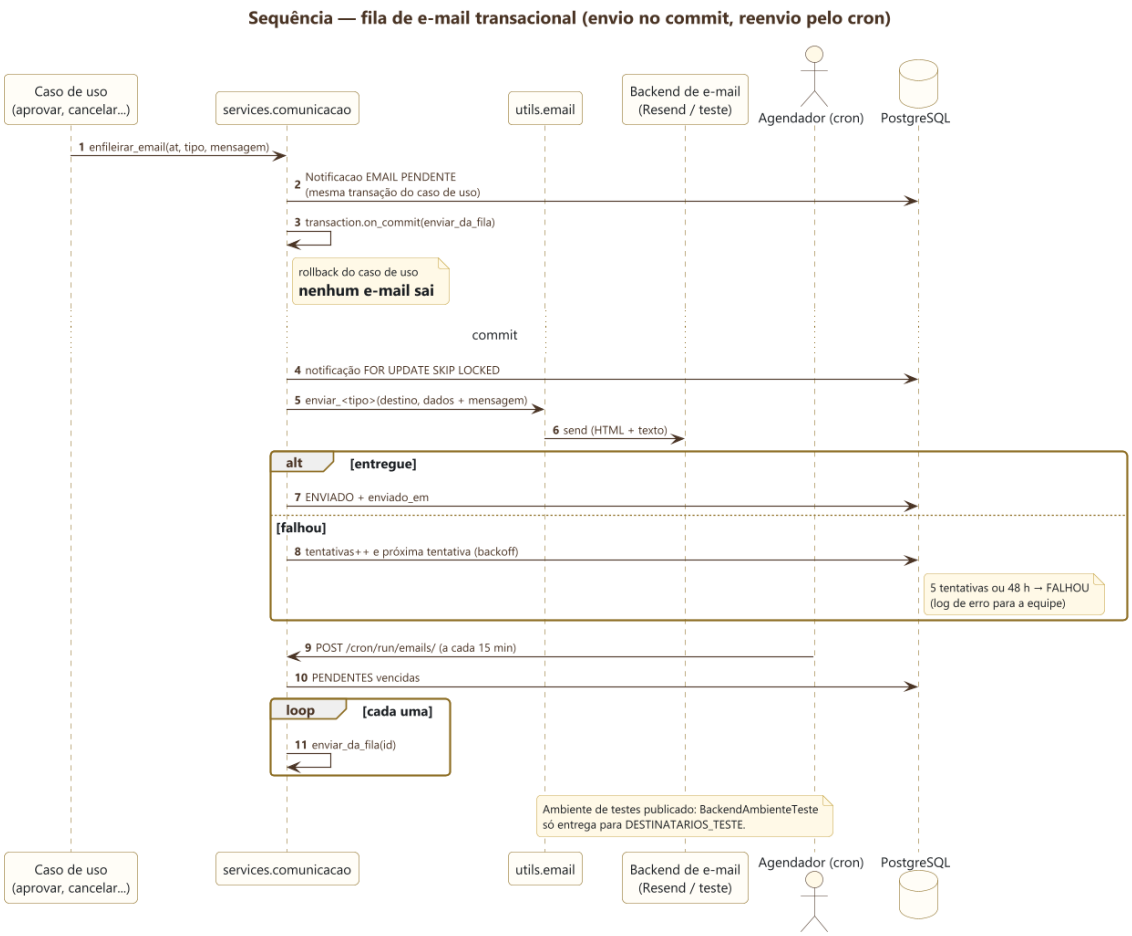


Figura 28 — Sequência — fila de e-mail transacional.

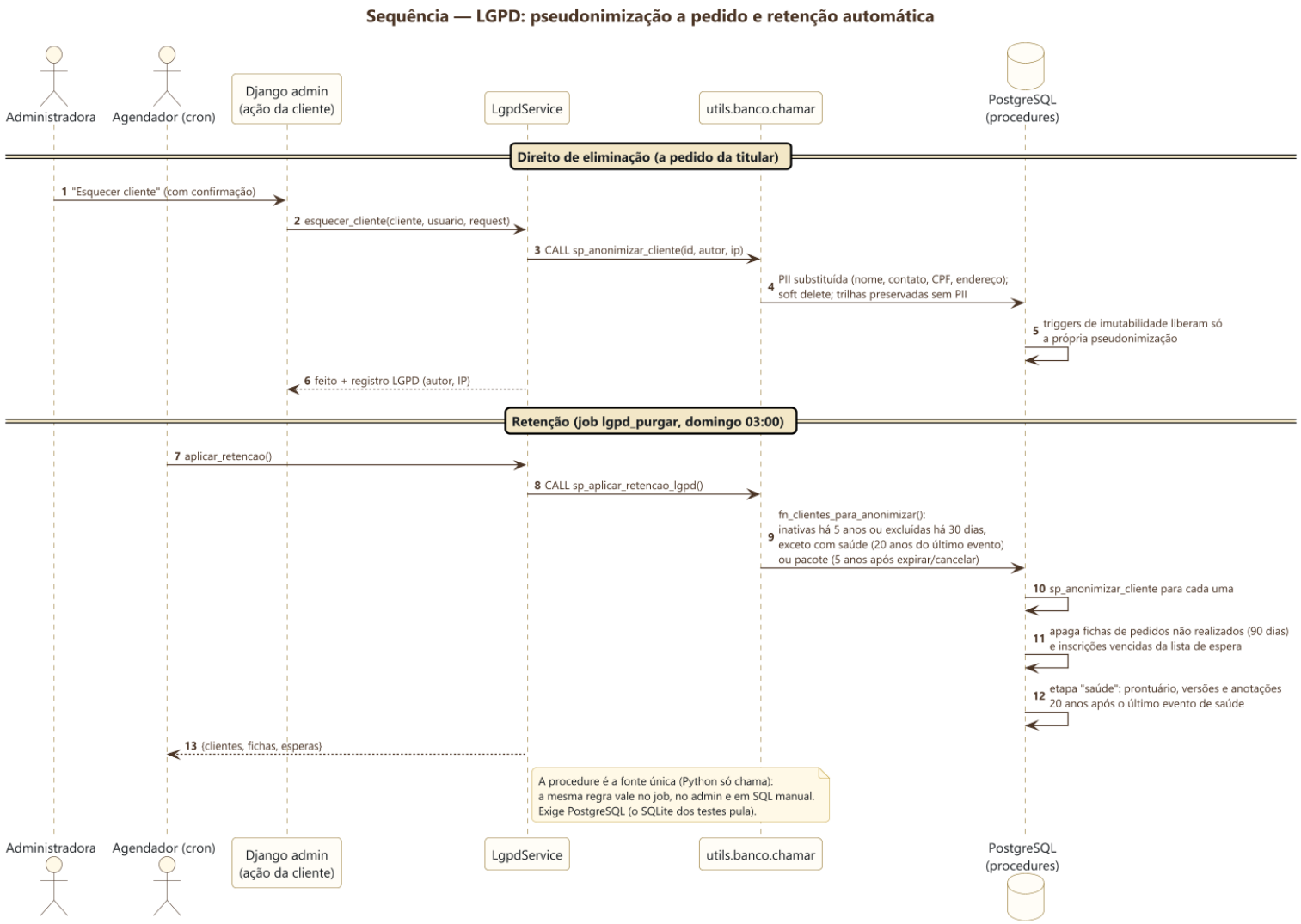


Figura 29 — Sequência — LGPD: pseudonimização e retenção.

11.1 Passo a passo do agendamento online

1. A cliente abre /agendamento/; o wizard recebe o catálogo com o preço da data (promoção), os termos e as fichas aplicáveis.
2. Escolhe procedimento e data; o wizard consulta /ajax/dias-disponiveis/ e /ajax/horarios-disponiveis/ (SlotService sobre agenda_horario, agenda_excecao e atendimentos ativos).
3. Escolhe o horário e o profissional e avança com o botão Continuar.
4. Informa nome, celular, nascimento e e-mail opcional; marca (nunca pré-marcadas) as autorizações de comunicação; aceita a Política de Privacidade e os termos; responde a ficha e o consentimento de saúde.
5. Pede o código: o servidor valida o Turnstile, recusa fixo, confere intervalo de 60 s e cotas de SMS e grava o CodigoOtp (HMAC-SHA256); a Zenvia entrega o SMS.
6. Digita o código: até 5 tentativas; o telefone fica verificado na sessão por 30 min e o cadastro daquele telefone pré-preenche o formulário.
7. Confirma: o servidor exige o telefone do formulário = o verificado, o aceite da política e idade ≥ 18.
8. services/agendamento_online.solicitar: termo LGPD vigente, services/agenda.validar_horario (habilitação, horário futuro, feriado/recesso e o slot), fichas obrigatórias pendentes ou vencidas (a respondida há menos de 12 meses não é exigida), termos do procedimento e e-mail de outro cadastro.
9. Trava do horário no cache (30 s) e transaction.atomic: cadastro da titular do telefone (SELECT FOR UPDATE; o nome do cadastro fica), recusa se bloqueada online ou com 3 horários futuros ativos.
10. services/consentimentos.registrar_do_wizard grava as concessões/revogações (histórico append-only).
11. services/agenda.reservar: conflito com SELECT FOR UPDATE, preço da data e INSERT do atendimento PENDENTE num savepoint (corrida perdida para o EXCLUDE vira HorarioIndisponivel).
12. Na mesma transação: Notificacao EMAIL de aprovação à profissional (fila), AceiteTermo LGPD, de procedimento e SAÚDE (IP, navegador, SHA-256), fichas cifradas e LogAuditoria do consentimento art. 11; a trilha historico_alteracao registra o atendimento.
13. Após o commit: e-mail à profissional e push (best-effort); a trava do cache é liberada.
14. A cliente vê a página de sucesso (aguardando aprovação da clínica) com a área "Meus agendamentos" já aberta (sem novo SMS); a clínica aprova (AGENDADO + e-mail) ou rejeita.

12. Diagramas de Atividades

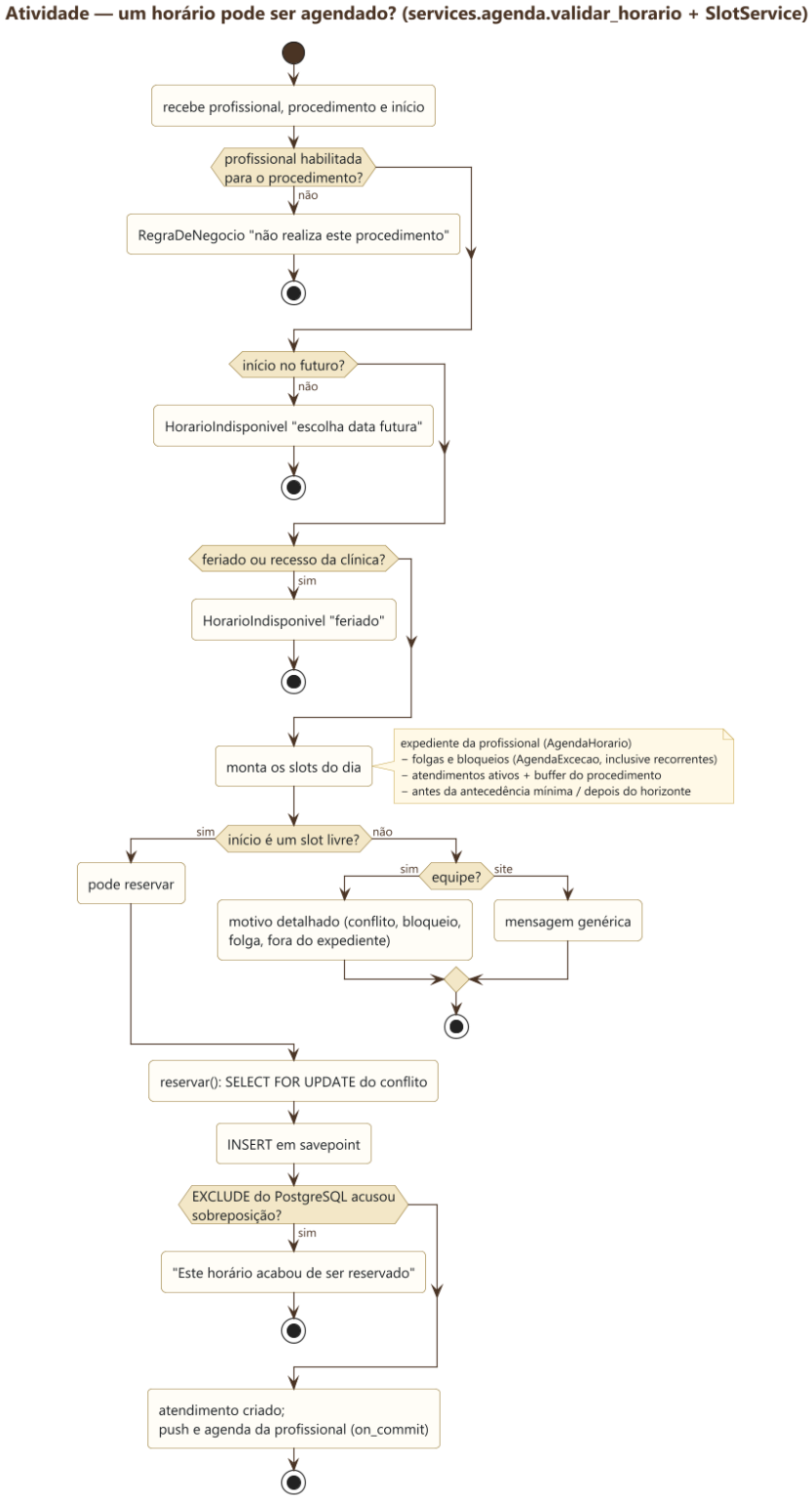


Figura 30 — Atividade — validação de um horário.

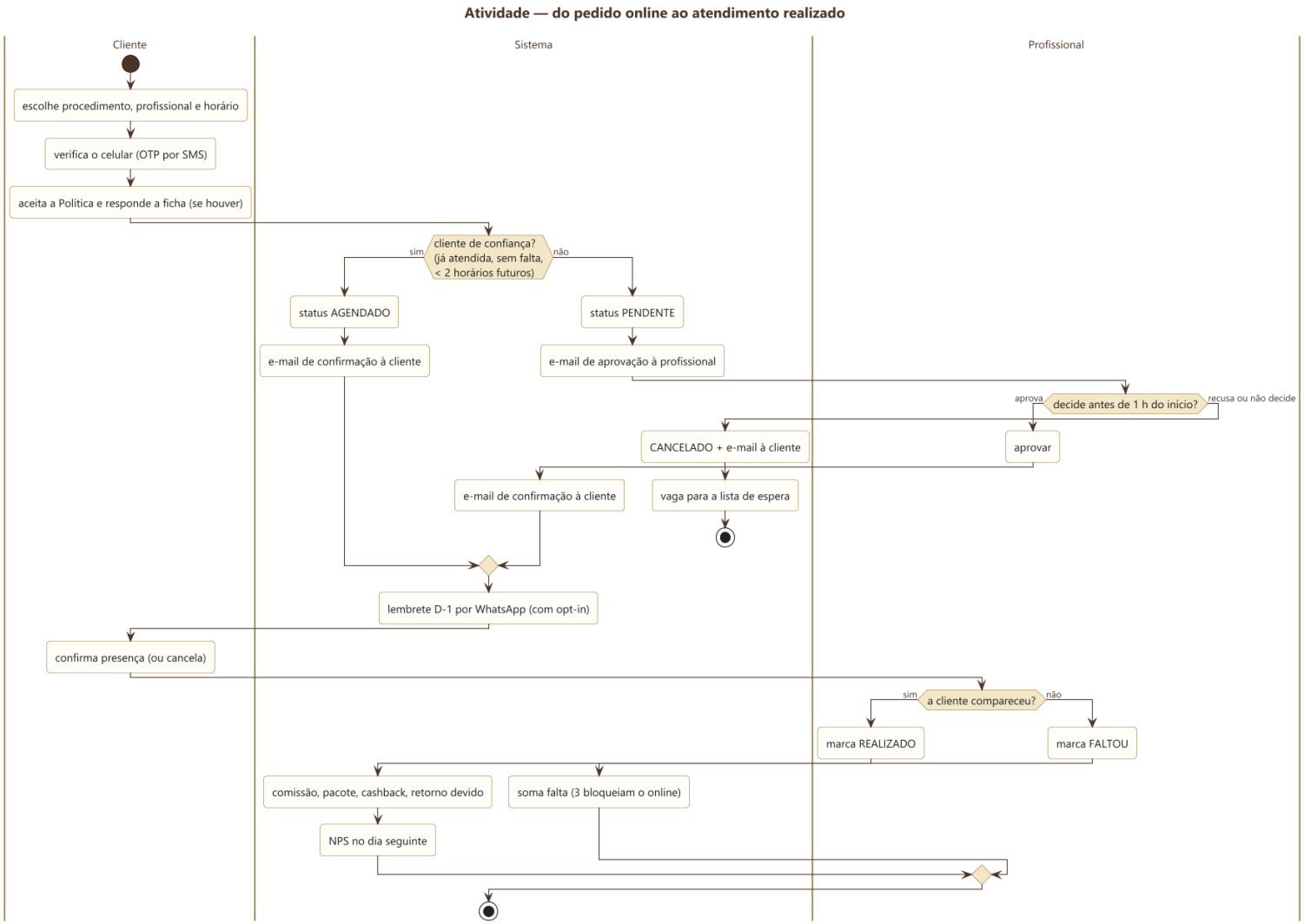


Figura 31 — Atividade — do pedido online ao atendimento realizado.

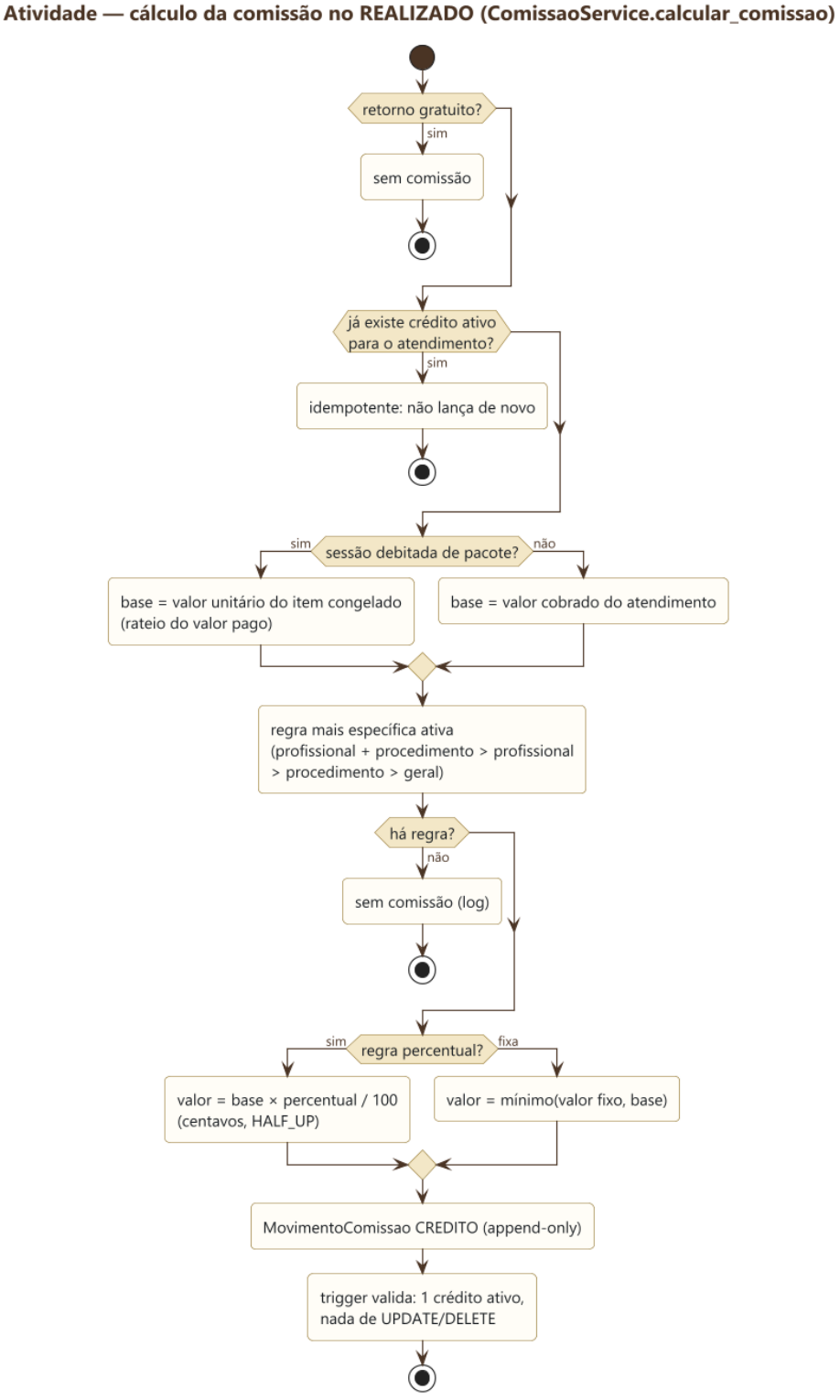


Figura 32 — Atividade — cálculo da comissão.

13. Arquitetura

Monólito Django em camadas: borda HTTP (urls e views separadas por área: público, conta, painel, profissional e infraestrutura), formulários, serviços (casos de uso), domínio (models, máquina de estados e QuerySets) e banco. O PostgreSQL é a fonte única da escrita: sobreposição de horários, imutabilidade dos livros-razão e trilha de alterações são garantidas por constraints e triggers, valendo também para o Django admin e para SQL manual. Não há fila assíncrona (Celery): as rotinas são funções chamadas por um cron externo via HTTP autenticado, e o e-mail é uma fila na tabela de notificações, enviada após o commit.

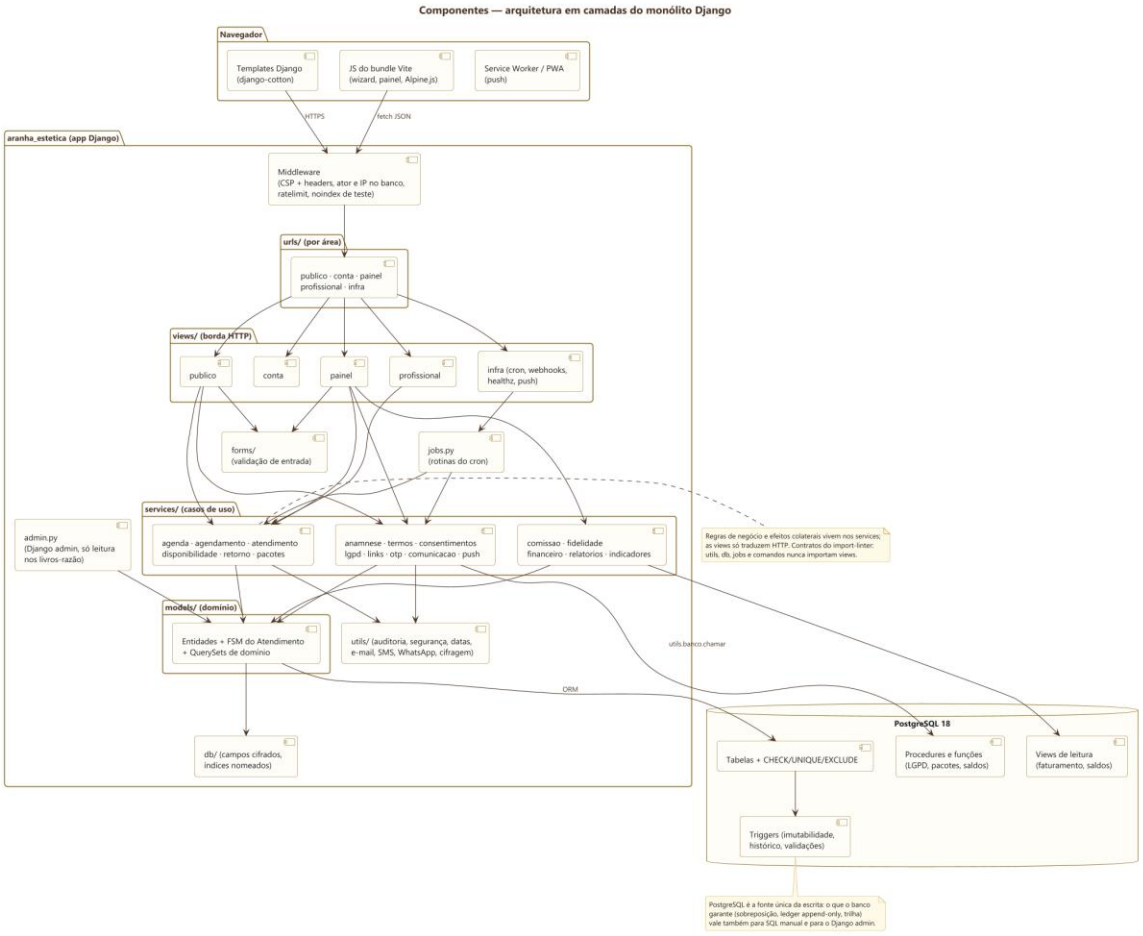


Figura 33 — Componentes — arquitetura em camadas.

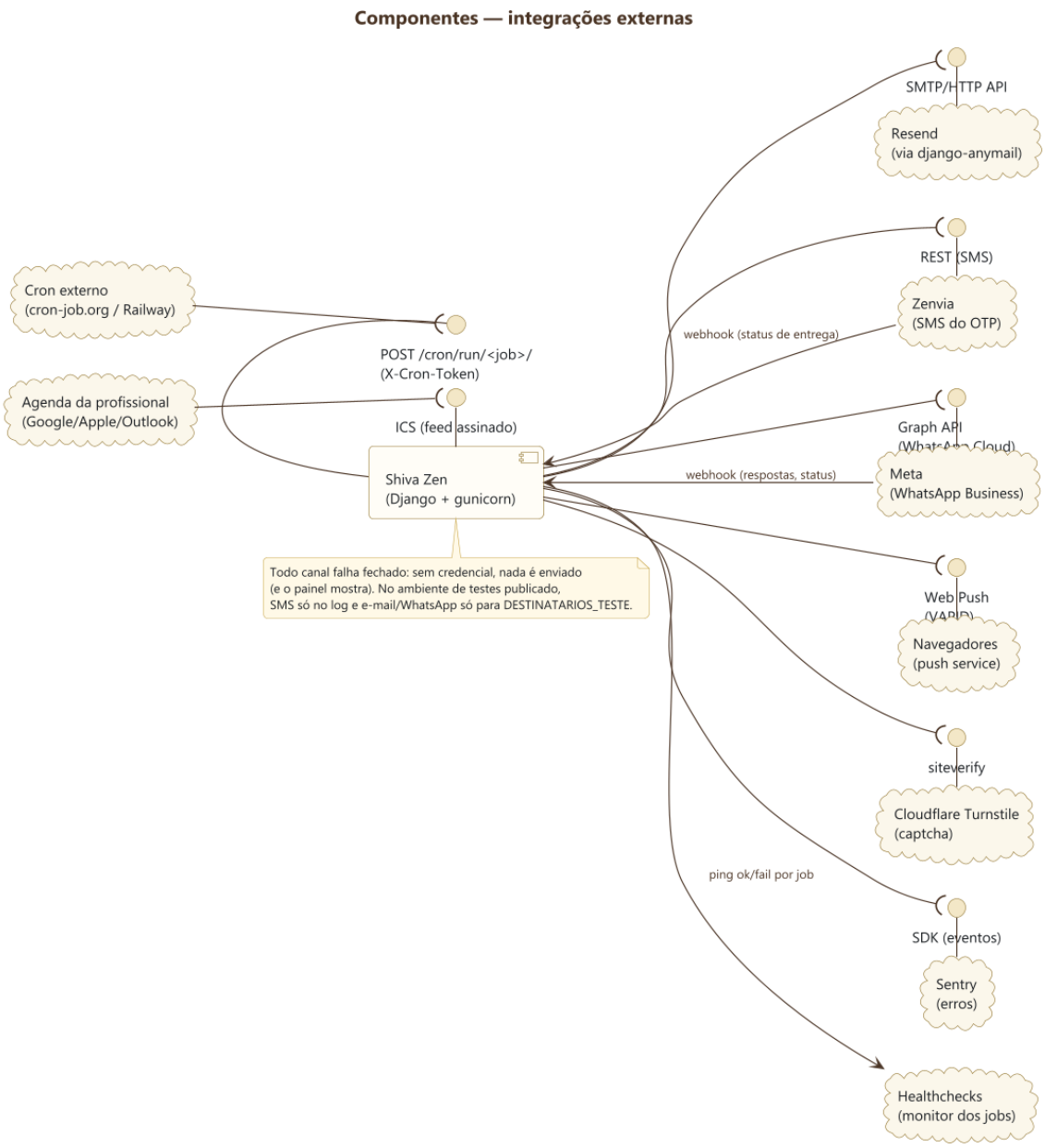


Figura 34 — Componentes — integrações externas.

13.1 Componentes

Componente	Papel
Navegador (site público + wizard)	Páginas server-render com Vite, Tailwind CSS v4, Alpine.js (build CSP) e componentes django-cotton; uma entrada JS por tela; CSS das páginas no site.css (só tokens); fontes locais; fotos responsivas (tag foto: WebP + JPEG das variantes geradas por scripts/imagens.py); números do site de services/prova_social; PWA com service worker (só páginas públicas).
Navegador (painel ADMIN + portal do profissional)	App-shell PWA da equipe com 2FA, Django Forms, calendário (FullCalendar) e Web Push, num design system próprio (componentes.css + componentes cotton: botão, campo, cartão, selo, aviso, KPI, menu de ações, diálogo, tabela responsiva, abas) com o comportamento em painel.js (vanilla); a agenda usa os módulos do Vite

	painel-status e painel-calendario (POST JSON pelo lib/requisicao.js) e a visão geral o painel-visao-geral; FullCalendar e Chart.js vêm do npm no bundle, sem CDN. O portal do profissional tem casca própria (profissional/base.html), no mesmo design system.
Django App (gunicorn)	Monólito Django 5.2: views (validação + permissão) → services/utils (regra de negócio) → models (FSM, managers, constraints). Middlewares de CSP com nonce, headers, 2FA, axes, rate-limit e ContextoBancoMiddleware (Ator da requisição).
services/agenda e services/atendimento	Fonte única das regras de horário (validar_horario, reservar, reagendar, mover) e das portas com caso de uso próprio (agendar_pela_recepcao, cancelar_pela_cliente com o cancelamento tardio), e dos efeitos de criar/mudar status do atendimento (ao_criar, ao_mudar_status), chamados explicitamente na transação da FSM; marcar_realizado e registrar_valor_cobrado são os casos de uso da equipe.
services/agendamento_online (caso de uso)	O pedido de agendamento pelo site, testável sem HTTP: forms/agendamento.AgendamentoPublicoForm lê o POST e confere o OTP, solicitar(PedidoAgendamento) tem a regra inteira e recusa com RegraDeNegocio + código; a view só liga os dois. A vitrine sai de services/precos e o catálogo (preço base, habilitações) de services/catalogo.
Área da cliente e LGPD (services/portal_cliente, services/lgpd, conteudo/lgpd.py)	Sessão do portal presa ao telefone (OTP ou fim do wizard), preferências e revogação de saúde (services/consentimentos), pedidos LGPD com prazo, export sem a ficha de saúde; a Política de Privacidade em conteudo/lgpd.py é o termo LGPD, a página e a declaração do DSAR.
Jobs (jobs.py, jobs_manutencao.py)	Registro (JOB_MAP), agenda única (JOB_AGENDA) e execução (executar, com a trava diária execucao_job): o serviço Cron do Railway roda rodar_jobs_devidos a cada 15 min; o cron HTTP /cron/run/<job>/ (X-Cron-Token) e manage.py rodar_job são alternativas; sem Celery nem worker de fila.
Fila de e-mail (notificacao)	E-mail transacional gravado como Notificacao PENDENTE na transação, enviado no on_commit e reenviado pelo job emails com espera crescente.
PostgreSQL 18	37 tabelas de domínio no padrão SQL; invariantes por EXCLUDE, CHECK, UNIQUE parciais e 47 triggers; trilha historico_alteracao; 25 funções fn_*, 9 views vw_* de relatório (faturamento por competência) e 4 procedures sp_* (retenção/LGPD com expurgo de saúde aos 20 anos e pseudonimização, expiração de pacotes); extensões btree_gist, pg_trgm e unaccent.
Cache e sessão	LocMemCache + sessão no banco (1 worker); REDIS_URL troca para django-redis.
WhiteNoise	Estáticos comprimidos e com hash servidos pelo próprio processo.
Pre-deploy (Railway)	migrate_atomico (todas as migrations numa transação, com lock_timeout) + bootstrap_admin; imagem Docker multi-stage com usuário não-root e healthcheck. O serviço Cron (railway.cron.json) usa a mesma imagem, sem pre-deploy.

13.2 Integrações externas

Serviço	Uso
Zenvia SMS	OTP do agendamento, do "Meus agendamentos" e do DSAR (só celular), com cotas; webhook de status autenticado (segredo no header e/ou IP). Sem configuração o agendamento online fecha e o botão Agendar leva ao WhatsApp.
WhatsApp Cloud API (Meta)	Templates de lembrete D-1, NPS e aviso de vaga; webhook assinado (X-Hub-Signature-256) captura a nota do NPS e o pedido de "PARAR" (revoga lembrete e pesquisa por WhatsApp; confirmação em texto livre dentro da janela de 24 h).
E-mail (backend Django)	Transacional pela fila (aprovação, rejeição, cancelamento, lembrete D-1 de quem não autorizou o WhatsApp, aviso à profissional), termos, pacote expirando, reset/convite de senha e marketing com List-Unsubscribe.
Web Push (VAPID)	Avisos à profissional: novo agendamento, cliente cancelou/remarcou e atendimentos sem desfecho.
Cloudflare Turnstile	Captcha no pedido de código OTP (wizard, portal e "Meus dados"), no contato e na lista de espera.

Sentry	Erros e transações amostradas sem PII (scrubber de contato, saúde e tokens); opcional.
Feed ICS (sem integração)	A profissional assina a própria agenda no Google, Apple ou Outlook pelo link link_acesso FEED_ICS (nome público da cliente); é o único caminho da agenda para fora — o Google Agenda por OAuth saiu na 0071.

13.3 Decisões de arquitetura (ADR)

ID	Decisão	Motivo
D1	Backend Django server-render mantido	Sólido, SEO grátis, 1 mantenedor
D2	Não vira SPA; Alpine CSP, sem HTMX	Nenhuma tela precisava de parcial por HTMX; CSP estrita
D3	Tailwind v4 (não Bootstrap)	1 config de tokens para site + painel
D4	Direção visual "Clínico-premium" (dourado #C9A84C, serif + sans)	Confiança; afunila para o agendamento
D5	Painel como PWA app-shell	Uso como app instalado
D6	Fase 7 do banco em PR dedicada	Mexe no cálculo de slots
D7	Todo agendamento público exige OTP do celular; a identidade é o telefone, e-mail nunca é identidade	Anti-sequestro de cadastro; sem enumeração
D8	Agendamento público nasce PENDENTE (clínica aprova), exceto cliente de confiança (já atendida, sem falta, < 2 horários futuros) que nasce AGENDADO; interno nasce AGENDADO. Pelo site, no máximo 3 horários futuros ativos por cliente (MAX_ATIVOS_ONLINE; a recepção marca além disso). Toda decisão sobre o pedido passa pelo AgendamentoService (botão ou seletor)	Tira o gargalo da aprovação de quem já é cliente sem abrir a agenda a desconhecidos (o PENDENTE trava o horário: sem teto, um celular verificado reservaria a semana); a cliente sempre recebe a resposta
D9	2FA obrigatório para ADMIN e PROFISSIONAL em prod (válvulas ADMIN_2FA_OBRIGATORIO=false / PROFISSIONAL_2FA_OBRIGATORIO=false, avisos W008/W012); códigos de backup gerados no painel	Painel e portal leem dado de saúde (LGPD art. 11/46)
D10	Rotas do django-two-factor (/account/) e ReDoc não publicadas	2ª tela de login burlava o 2FA; ReDoc exige unsafe-inline
D11	~~RECEPCAO sem login até existirem telas próprias~~ — substituída pela D27 (o papel saiu)	Papel sem superfície própria = acesso indevido ao painel
D12	Prova de aceite imutável (SHA-256 do texto + trigger) e termo aceito imutável	Evidência legal (LGPD art. 8)
D13	Histórico append-only do prontuário (prontuario_versao)	CFM 1.638/2002 — edição não apaga o anterior
D14	O sistema nunca marca FALTOU sozinho: atendimento sem desfecho vira um push diário à profissional (job sem_desfecho, 08:00), não falta	Falta é terminal e bloqueia online; só a equipe decide — e a pendência precisa chegar a quem decide, não só ao log
D15	Aniversário = felicitação sem desconto; promoção sem cupom, anunciada pela data do atendimento (o período em que o preço vale), disparo único em lotes com o cursor na própria promoção (reenvio só confirmado)	Nada é prometido sem mecanismo que aplique; clique duplo ou queda no meio nunca repetem e-mail
D16	Deploy por Dockerfile + migrate_atomico no pre-deploy; rollback = restaurar dump	Upgrade 0026→0046 tudo-ou-nada; reverses não recuperam dados
D17	Sem Celery (saiu em 2026-10-27): jobs são funções com horário na jobs.JOB_AGENDA (fonte única), rodadas por um serviço Cron do Railway (rodar_jobs_devidos a cada 15 min), pelo cron HTTP (X-Cron-Token) ou rodar_job; job de mensagem sem marca por destinatário roda 1×/dia (execucao_job, 409 na 2ª); e-mail transacional é fila na própria notificacao (0061, reenvio pelo job emails)	Custo; um serviço de jobs no lugar de um por horário; nada roda "em segundo plano" sem rastro nem manda duas vezes
D18	/anamnese/<token>/ e /pesquisa/<token>/ com produtor:	Ficha obrigatória chega a quem não passou

	"Link da ficha" na agenda do painel (cliente agendada pela recepção) e convite da pesquisa no fim do NPS	pelo wizard; a pesquisa reaproveita o link do NPS (sem segunda mensagem)
D19	Site só pt-BR (sem LocaleMiddleware); sessão da equipe 8h deslizantes	Sem traduções; 30 min fixos deslogavam no meio do atendimento
D20	Faturamento = avulsos + venda de pacote; sessão de pacote não soma; comissão da sessão de pacote = valor_pago / total de sessões (congelado na venda, compra_pacote_item.valor_unitario); ticket médio e LTV da ficha pela mesma regra (services/financeiro)	Evita contar a receita duas vezes e inflar comissão
D21	Dado de saúde cifrado na aplicação (Fernet, CHAVES_CIFRAGEM, subchave por finalidade; 0060), sem busca no banco por conteúdo (o token OAuth do Google, também cifrado, saiu com a D26)	Dump/backup vazado não expõe a ficha (LGPD art. 46/48 §3); pgcrypto deixaria a chave no SQL de toda consulta
D22	Trilhas append-only no banco: log_auditoria imutável e expurgo só com 180+ dias (0059)	Mesmo usuário do banco p/ app e migrations: SQL injetado não apaga a prova (art. 37)
D23	Postgres é a fonte única da escrita de esquecimento, retenção LGPD, limpeza e expiração de pacotes (procedures 0058, sem fallback Python); funções de leitura seguem como espelho testado do Python	Decisão do dono (2026-10-27): uma regra, um lugar; custa exigir Postgres (Docker) para rodar esses testes e rotinas localmente
D24	Ambiente de testes publicado = perfil staging (prod.py + travas: SMS só em log com a prévia, e-mail/WhatsApp só p/ DESTINATARIOS_TESTE, noindex, faixa, seed --demo); DJANGO_ENV=dev no Railway derruba o boot e produção sem Postgres é Error (aranha.E002)	Testar o fluxo inteiro (wizard + OTP) na internet sem mandar mensagem a cliente real nem expor DEBUG
D25	Financeiro por competência mensal (services/financeiro.competencia): pacote = vendas pela data da venda − reembolsos pela data do cancelamento (compra_pacote.cancelado_em); comissão pela data do atendimento; rateio da venda ponderado pelo preço de tabela; CRÉDITO de comissão congela base e percentual; regra usada é imutável (trigger)	Mês fechado não muda; o valor de cada sessão reflete o procedimento; comissão explicável depois
D26	Google Agenda removido (0071): a agenda da profissional sai só pelo feed ICS assinado (link_acesso FEED_ICS, nome público da cliente); sem OAuth, sem importação de eventos como bloqueio	O feed cobre Google, Apple e Outlook sem guardar token de terceiro nem manter sincronização em dois sentidos; um operador e um segredo a menos
D27	Papéis da equipe só ADMIN e PROFISSIONAL (0072; substitui a D11): a dona faz a recepção pelo painel	YAGNI: o papel RECEPCAO não tinha tela nem login e só existia como risco de acesso indevido
D28	Todo atendimento é presencial (0073): sem modalidade nem link de videoconferência; a ficha vale por 3 escopos (global, categoria, procedimento)	Nenhum serviço online no catálogo; o escopo MODALIDADE só repetia o GLOBAL
D29	A cliente tem um acesso só: o portal "Meus agendamentos" por OTP (reagendar/cancelar por id + sessão). O link legado de reagendar (GERENCIAR_AGENDAMENTO) e o alvo atendimento do link_acesso saíram (0072)	Os tokens legados vinham do banco da 0026, descartado no go-live; dois caminhos eram duas superfícies de ataque para a mesma ação
D30	Minimização do cadastro (0074): RG, profissão e foto da cliente não são coletados; CPF, CEP e endereço ficam pela finalidade (nota fiscal, contrato de pacote)	LGPD art. 6º III (necessidade): dado sem finalidade é risco sem benefício e entra no esquecimento à toa
D31	Cookies só essenciais: o aviso é informativo e "Entendi" grava só no navegador; nada é registrado no servidor (saiu /lgpd/aceitar-cookies/)	Sem cookie de análise ou de terceiro não há consentimento a provar; guardar a resposta era dado pessoal sem finalidade
D32	Runner único manage.py test (pytest, pytest-django e conftest saíram; teste em função solta reprova)	Dois runners coletavam conjuntos diferentes: teste só do pytest ficava fora do CI
D33	Áreas de views independentes (publico, painel, profissional, conta, infra não se importam — import-linter); o que mais de	Mudar uma tela não quebra outra área; o acoplamento entre áreas fica explícito num

	uma área renderiza igual mora em views/comum.py, a regra em services/	lugar só
D34	Configuração só nos settings: a env é lida e validada em clinica/settings e o código lê settings.X na chamada (ruff TID251); o .env.example é conferido contra o código; segredo fraco num perfil publicado é erro (E003)	Valor inválido derruba o boot com o nome da variável em vez de virar 500 no meio de um fluxo; override_settings vale nos testes; o exemplo não sobe segredo para o Railway
D35	utils/telefone é a fonte única do telefone: forma canônica sem DDI (a do cadastro, do OTP e das buscas), E.164 só para telefone BR válido, máscara de log	O telefone é a identidade da cliente: cópias da normalização em OTP, lista de espera, formulário e webhook divergiam, e número estrangeiro virava destino de SMS
D36	Contrato JSON único (utils/respostas): {"ok": true, ...} ou {"ok": false, "codigo", "mensagem"}; o front decide pelo codigo	Cada view respondia num formato; o texto da mensagem não é contrato
D37	Logs redigidos e imagem endurecida: filtro RedigirLog (token de link, DETAIL do Postgres, e-mail, CPF, telefone) no log da aplicação; imagem sem curl, usuário sem shell, código do root só leitura, testes e scripts fora	O django.request levava /confirmar/<token>/ para o log do Railway em todo 4xx/5xx; um RCE não reescreve código nem baixa ferramenta
D38	Pedido online como caso de uso: services/agendamento_online.solicitar(PedidoAgendamento) tem a regra inteira (termo LGPD, horário, fichas válidas por 12 meses, termos, cadastro da titular do celular, teto, reserva, e-mails e provas); forms/agendamento.AgendamentoPublicoForm lê o POST e confere o OTP; a view só liga os dois. Recusa = RegraDeNegocio com código (sem_termo_lgpd, ficha_invalida, consent_saude_ausente, termo_pendente, email_de_outro_cadastro, horario_em_confirmacao, bloqueado_online, limite_online, horario_ocupado)	A view tinha complexidade ciclomática 71 (hoje 9) e a regra só era testável por HTTP; outra porta (painel, API) reusa o service
D39	Regras operacionais em registro tipado (models/configuracao.CHAVES: email_admin, MAX_FALTAS_BLOQUEIO 1–10 e, com a D51, anos_experiencia 1–60 opcional), lidas por Configuracao.ler; a tela grava só essas chaves (sem chave livre) e a marca tem a tela Identidade visual	A chave-valor livre listava estado interno, aceitava chave inventada e um valor inválido caía no padrão em silêncio
D40	Desligamento revoga o feed ICS: desativar a profissional, o login dela ou trocar o vínculo do login revoga o link na hora (auditado); reativar exige link novo	O calendário de quem saiu continuaria recebendo nome de cliente (o feed é um operador fora da clínica)
D41	Política de Privacidade como fonte única (conteudo/lgpd.py): o mesmo texto é o termo LGPD aceito no wizard (0045/0078 e seed), a página /politica-de-privacidade/ (renderiza a versão LGPD vigente) e a declaração do "baixar meus dados" (finalidades, bases, operadores, prazos). Os prazos LGPD ficam fixos em settings.RETENCAO_, sem env, e o check aranha.W016 compara com o texto da versão vigente. Revisão jurídica da dona antes do go-live	A página e o termo eram dois textos que divergiam, e o prazo que a procedure aplicava podia não ser o que a cliente leu; a prova do aceite (SHA-256) agora cobre exatamente o que a página mostra
D42	Retenção por janela e pseudonimização completa (0077): o registro de saúde é expurgado 20 anos depois do último evento de saúde (etapa saude do sp_purgar_dados_expirados), o pacote retém a cliente 5 anos depois de expirar/cancelar, e a pseudonimização tira também o código de indicação, quem indicou, IP/user-agent do aceite LGPD e a inscrição anônima da lista de espera. Os triggers só aceitam o expurgo com a flag local e 20 anos de idade	Quem tinha ficha ou pacote ficava identificada para sempre (contra os arts. 15/16 e a política); o mínimo legal do registro de saúde fica garantido pelo banco mesmo com um prazo errado no settings. É pseudonimização (art. 13 §4), não anonimização: a saúde e os contratos seguem ligados ao id
D43	Consentimento de saúde revogável (art. 11 I, art. 8 §5): a concessão é o aceite SAÚDE e a revogação é cliente.saude_revogada_em (portal ou Django admin com	Com base só no consentimento, revogar tem de ser possível e tão fácil quanto dar; a ficha já feita fica pelo prazo de guarda

	motivo), fora da tabela consentimento; os alertas mostram a revogação e um aceite SAÚDE novo reativa	(exercício de direitos)
D44	Direitos pela área da cliente, sem a ficha de saúde no site: "Meus agendamentos" concentra preferências (origem PORTAL), revogação de saúde, pedido de correção/exclusão (trilha com prazo de 15 dias + e-mail ao encarregado) e "baixar meus dados"; o export self-service (portal e /lgpd/meus-dados/) não leva saúde e, no portal, exige código de até 10 min; a sessão do portal abre no fim do wizard sem novo SMS	O celular é um fator só (SIM-swap): o dado sensível não sai pelo site. Um lugar para tudo o que a titular pede, sem e-mail solto nem segundo login
D45	Cancelamento tardio conta falta: a cliente sempre pode cancelar online antes do início (a vaga volta para a lista), mas com menos de 24 h de um horário aprovado soma 1 falta para o bloqueio online, sem virar FALTOU (agenda.cancelar_pela_cliente, portal e link); pedido PENDENTE não conta	Cancelar em cima da hora tem o mesmo efeito de faltar para a agenda; o aviso antes de confirmar e a política (art. 20) deixam a regra explícita
D46	Lista de espera sem cadastro e formulários públicos com anti-abuso: a inscrição é anônima (nome + celular) e só se liga à cliente — e só aceita e-mail — com o celular verificado por OTP; o aviso não tira da fila e agendar encerra a inscrição. Lista e contato com captcha, honeypot e limite por IP (contato: teto global diário); o contato não tem caixa de marketing e o mapa não carrega nada do Google	Um formulário sem login não pode criar nem alterar cadastro, nem prender um e-mail ao telefone de outra pessoa; a cota de e-mail é compartilhada com o reset de senha; opt-in de marketing só onde há prova
D47	Agenda do painel por casos de uso: agenda.agendar_pela_recepcao (cliente nova na mesma transação, preço do dia ou combinado, AGENDADO, e-mail de confirmação), atendimento.marcar_realizado (a regra do termo igual no painel e no portal, TermoPendente), atendimento.registrar_valor_cobrado e AgendamentoService.decidir_em_lote (item a item, cada um na sua transação); a entrada é Django Form (forms/agenda) e a view só traduz HTTP	A view do novo agendamento tinha 191 linhas (hoje 43; complexidade do mccabe 27 → 7) e o lote numa transação só desfazia tudo por um item decidido em outra tela
D48	Seletor de status só com o que há para decidir: sem PENDENTE (decide nos botões, pelo AgendamentoService) nem status final; Realizado/Faltou só a partir do início (a FSM recusa com desfecho_antes_do_inicio, 409). O JS da agenda e do calendário são entradas do Vite (painel-status, painel-calendario, lib/requisicao.js) no contrato utils/respostas; as ações da agenda (status, valor, desfazer realização, aprovar/recusar/lote, mover, exceções e bloqueios) usam @escrita_painel (POST + 30/min por usuário)	Um clique na agenda da semana seguinte gerava comissão, debitava pacote e contava falta; o mesmo JS existia em duas cópias inline
D49	Leitura de alerta de saúde auditada: toda tela que mostra alerta (agenda e visão geral do painel, ficha da cliente, lista de prontuários, agenda do portal da profissional) grava "Leu alertas de saúde" (tabela prontuario, {clientes, tela}, sem nome)	O RIPD promete que cada leitura de dado de saúde vai para a trilha (art. 37); o alerta na lista também é leitura
D50	Design system das telas da equipe (painel e portal da profissional): classes de componente em static/src/css/componentes.css na camada @layer components (o utilitário do template sempre vence, sem !important), emitidas por componentes cotton (<c-botao>, <c-campo>, <c-card>, <c-selo>, <c-nota>, <c-kpi>, <c-vazio>, <c-icone>, <c-menu-acoes>, <c-dialogo>, <c-tabela>, <c-abas>); abas WAI-ARIA, menu "⋯", modais, Ctrl+K e foco da tabela que rola num painel.js vanilla por delegação, não em Alpine; lib de terceiro só pelo npm no bundle do Vite (FullCalendar 6.1.21, Chart.js 4.5.1 — nenhum CDN na CSP); o ARIA de grade do FullCalendar achatado para presentation;	As telas repetiam classe utilitária longa e ~160 style="", com cor fixa de tema claro que o escuro não alcançava, e cada uma resolvia modal e menu do seu jeito: o componente é um ponto de mudança só, com o padrão acessível embutido. Sem JS as abas são âncoras para seções visíveis e o "⋯" é <details> nativo; com Alpine cada instância pediria x-data e nada funcionaria antes do JS. O jsDelivr serviria qualquer pacote npm com o nonce da página. O FullCalendar 6 desenha um role="grid" de

	caixa de frase, texto base 15px, rótulo 13px e nada abaixo de 12px, sem style=""; toda rota pública, da equipe e da profissional varrida no CI (1366px claro e 390px escuro) com axe-core serious/critical	layout sem linhas (axe aria-required-children/aria-required-parent): como tabela de layout, a informação segue no texto. A varredura pega erro de JS/CSP, rolagem lateral no celular e regressão de acessibilidade que só apareceriam olhando tela por tela
D51	Prova social só com dado real (services/prova_social): nota = média do NPS ÷ 2 (escala de 5), só com 10+ respostas, e as estrelas desenhadas em meias, sem arredondar 4,7 para 5; clientes atendidas = clientes distintas com atendimento REALIZADO, só a partir de 50 e arredondadas para baixo ("127" vira "120+", "1.234" vira "1.200+"); tratamentos = procedimentos agendáveis online (no total e por categoria); anos de experiência = regra operacional anos_experiencia (1–60, opcional; em branco não aparece). O que não atinge o mínimo some do template. Uma conta a cada 10 min (cache), zerada quando Configuracao muda. A "decisão do dono: manter" o selo fixo "5.0/5 · 32 avaliações" (e os "5+ / 500+ / 20+") foi revertida a pedido do dono ao aplicar a revisão do front	Número sem lastro no site de uma clínica de estética é promessa que a cliente não tem como conferir (e o selo fixo nunca mudava); com 3 notas 10 a média "5,0" diz mais sobre o acaso que sobre a clínica, e o "+" nunca promete mais do que houve. O cache evita 4 agregações a cada visita da home

14. Modelo de Dados

O modelo físico é gerado dos models com os tipos reais do PostgreSQL, chaves (PK, FK, UK) e nulidade (* = obrigatório). Nomes seguem o padrão SQL do projeto (tabelas no singular, colunas eh_*, constraints ck_/uq_/ex_/fk_ e índices ix_). A visão geral mostra todas as tabelas; as demais, uma área do domínio cada.

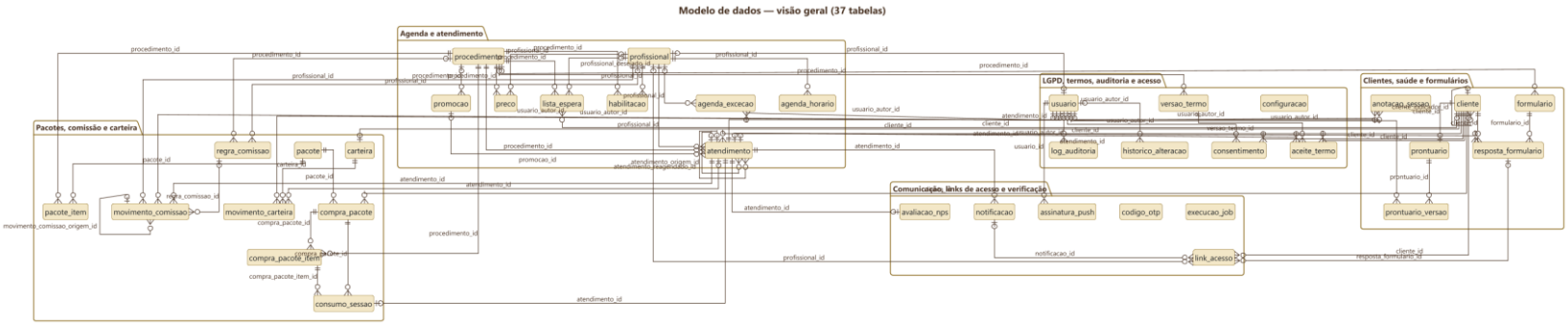


Figura 35 — Modelo de dados — visão geral.

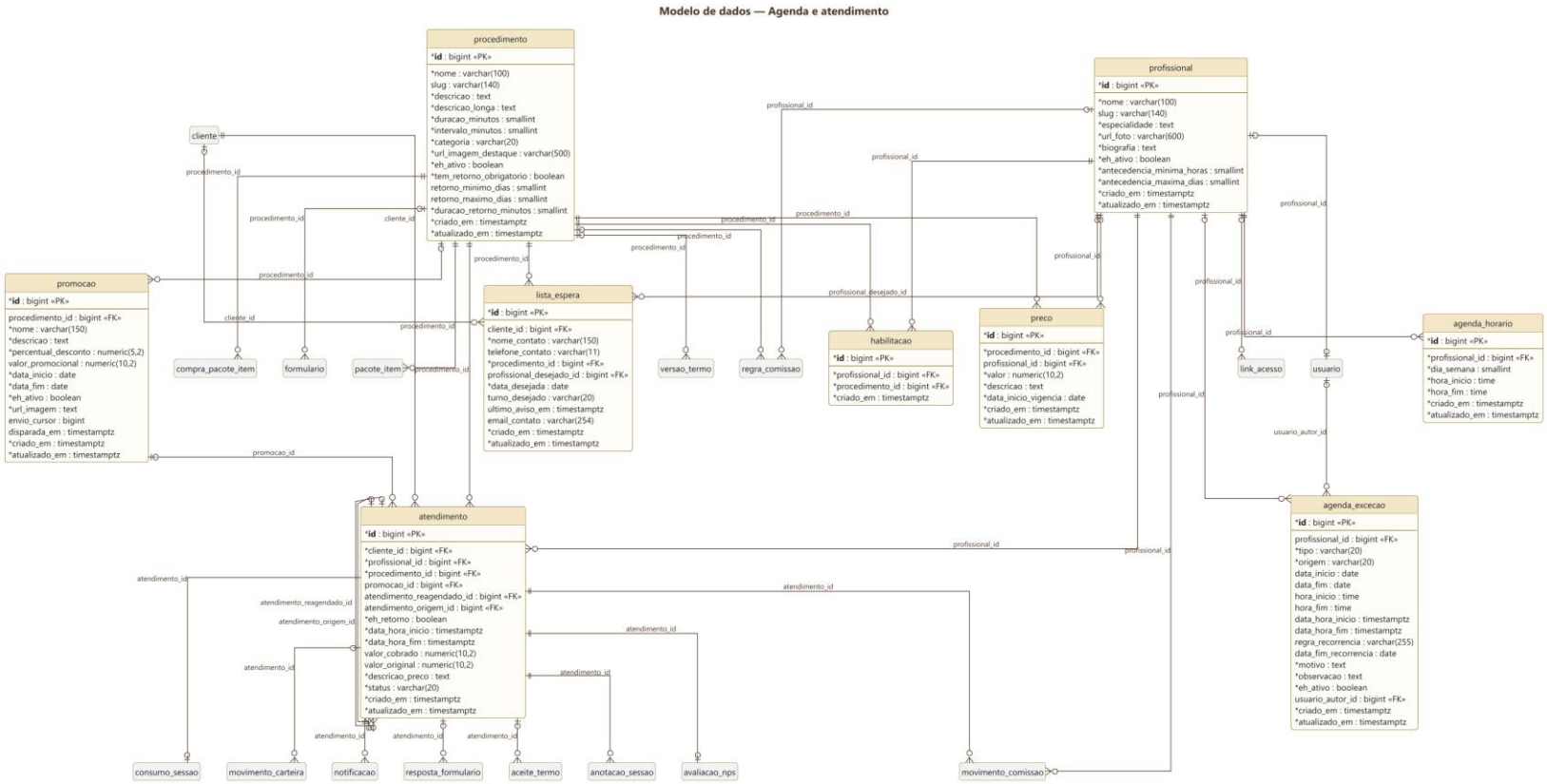


Figura 36 — Modelo de dados — agenda e atendimento.

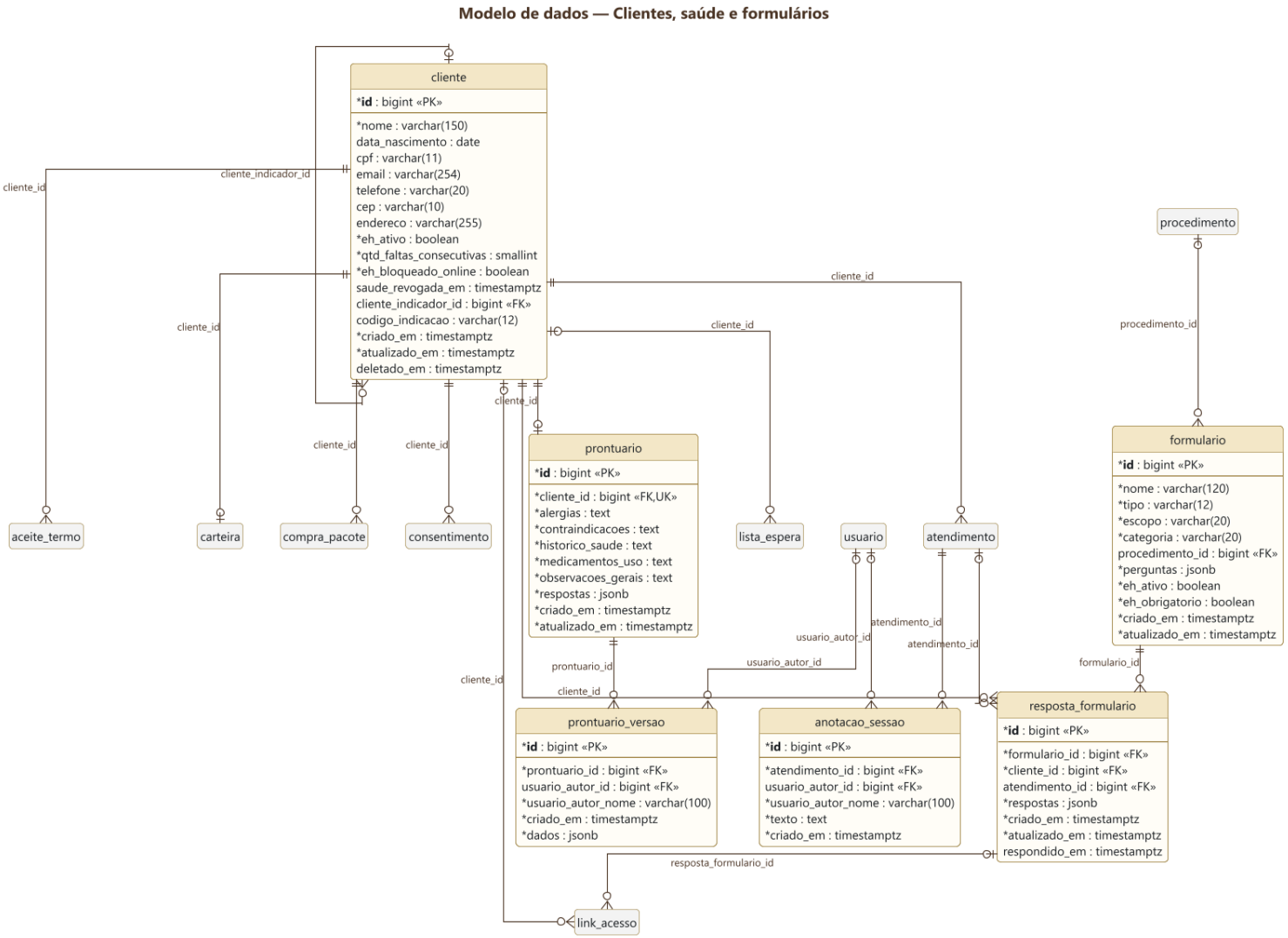


Figura 37 — Modelo de dados — clientes, saúde e formulários.

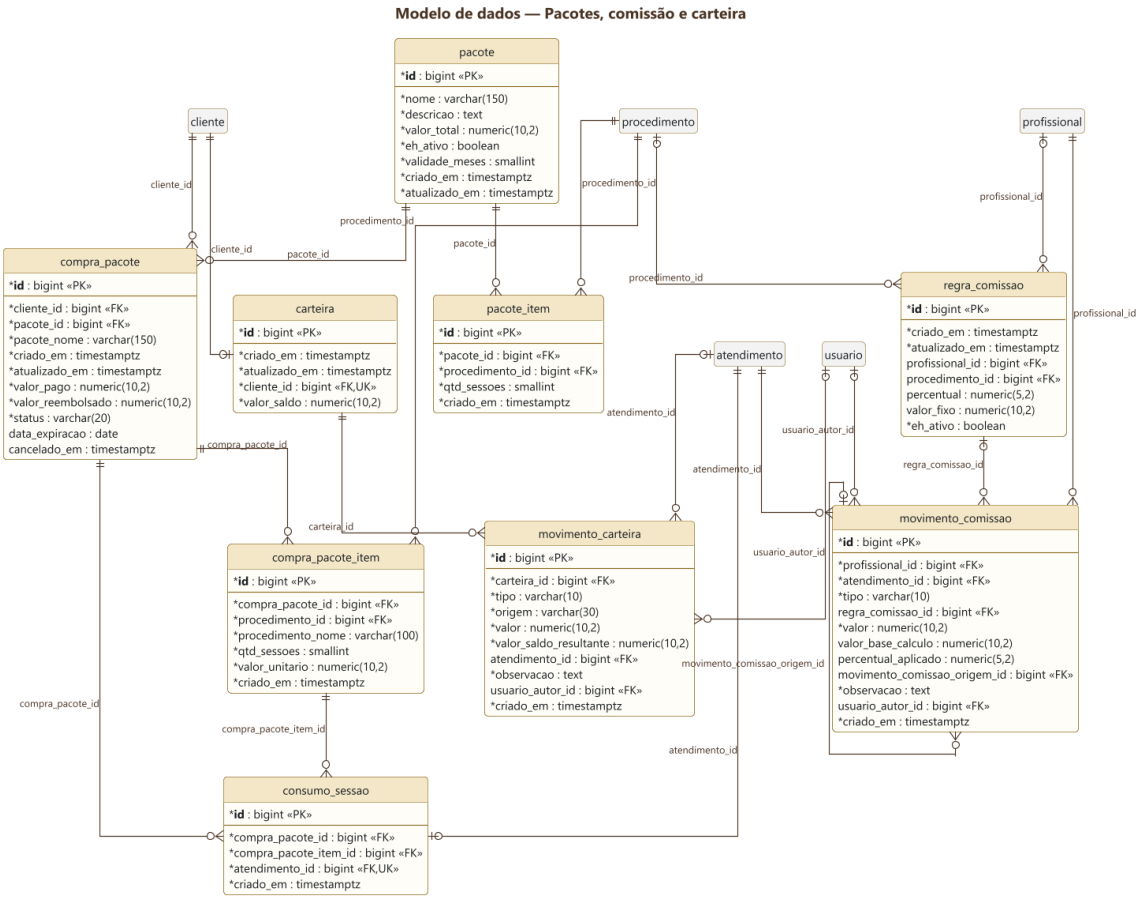


Figura 38 — Modelo de dados — pacotes, comissão e carteira.

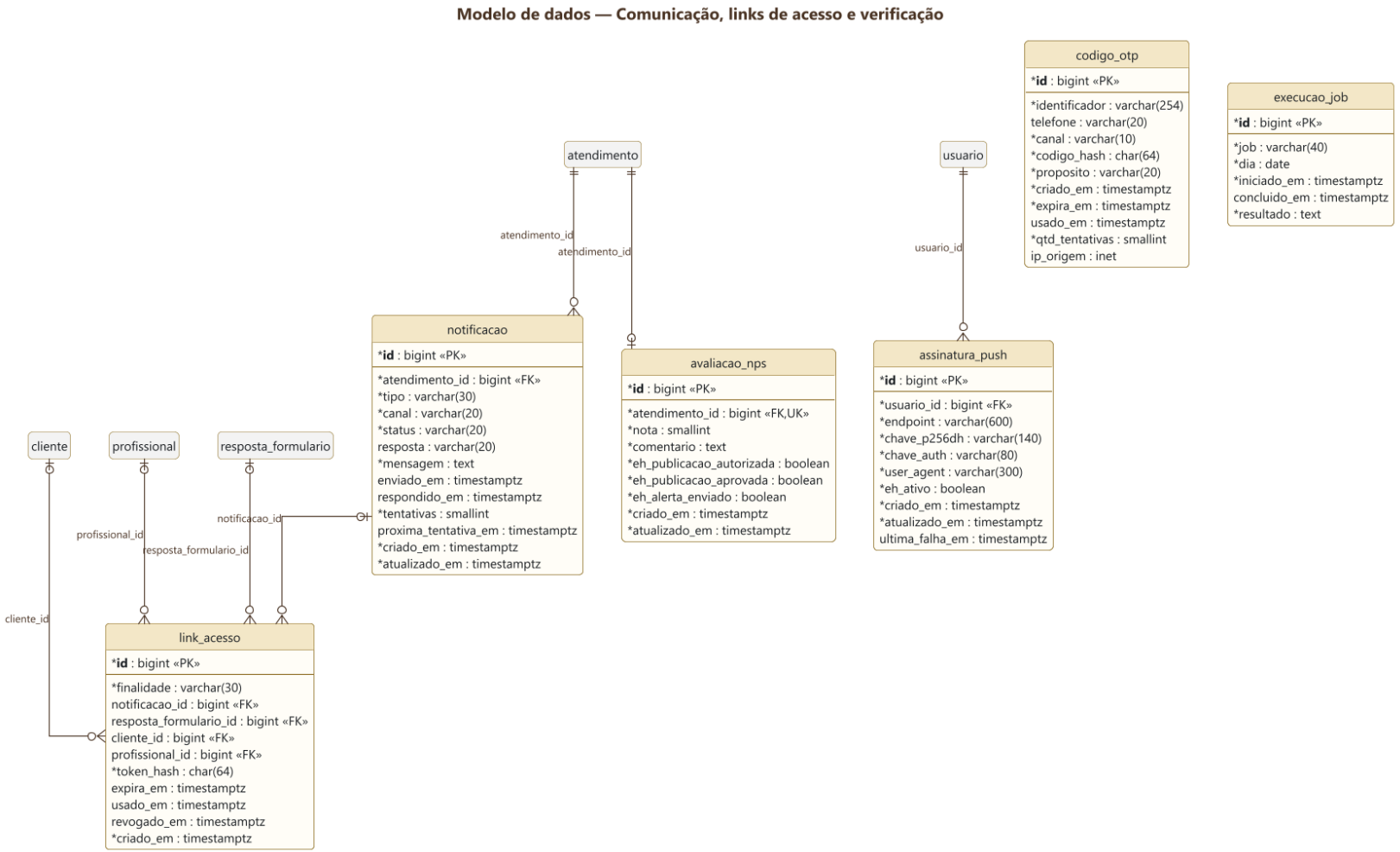


Figura 39 — Modelo de dados — comunicação, links e verificação.

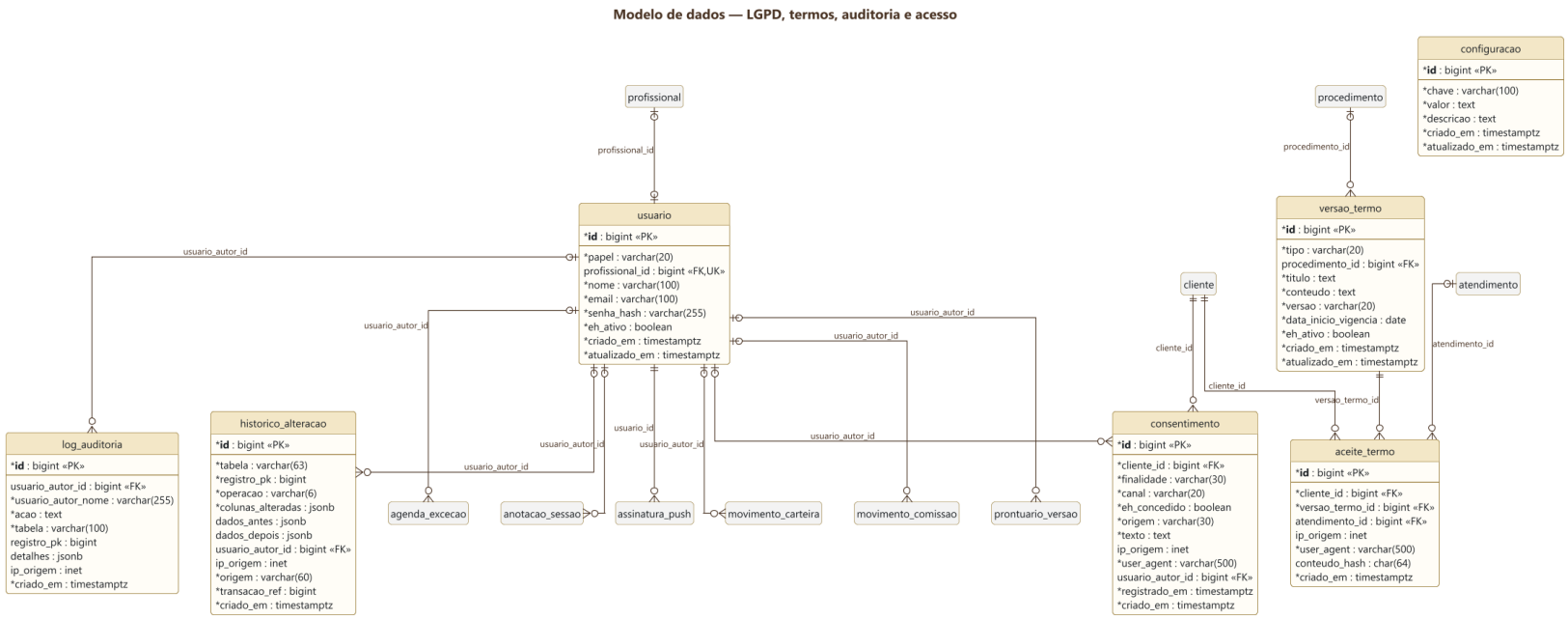


Figura 40 — Modelo de dados — LGPD, termos, auditoria e acesso.

14.1 Lógica no banco

- EXCLUDE (btree_gist) impede dois atendimentos ativos sobrepostos da mesma profissional.
- Livros-razão append-only (movimento_comissao, movimento_carteira): trigger recusa UPDATE/DELETE; no máximo um crédito de comissão ativo por atendimento.
- Trilha historico_alteracao preenchida por trigger em toda escrita das tabelas sensíveis, com autor, IP e origem da requisição (variáveis de sessão definidas pelo middleware).
- Procedures sp_anonimizar_cliente e sp_aplicar_retencao_lgpd: a regra de retenção e pseudonimização vive no banco e é a mesma para o job, o admin e SQL manual.
- Funções e views de leitura (saldo de pacote, horários livres, faturamento) com paridade testada contra a implementação em Python.
- Dado de saúde (prontuário, respostas de ficha) gravado cifrado (Fernet, chaves rotacionáveis).

15. Segurança e Conformidade com a LGPD

15.1 Segurança da aplicação

- Equipe: senha (PBKDF2), segundo fator TOTP obrigatório, bloqueio por tentativas (django-axes) e ratelimit; a cliente não tem senha — prova a posse do celular por código SMS de uso único.
- Links enviados à cliente (confirmação, NPS, ficha, termo, agenda ICS) guardam só o hash SHA-256 do token, com validade e uso único quando aplicável; logs nunca registram tokens.
- Cabeçalhos: HSTS, CSP com nonce (Alpine na build CSP, sem eval), X-Frame-Options, Referrer-Policy; cookies Secure/HttpOnly/SameSite; CSRF em todo POST.
- Webhooks e cron autenticados (token no cabeçalho, comparação em tempo constante, allowlist de IP).
- Auditoria (LogAuditoria) de toda ação administrativa e de cada leitura ou escrita de dado de saúde.
- Ambiente de testes publicado isolado: SMS só no log, e-mail e WhatsApp apenas para destinatários autorizados, robots e cabeçalho noindex.

15.2 LGPD

- Base legal por finalidade: execução de contrato (agendamento e mensagens transacionais), consentimento específico e destacado para dado de saúde (art. 11) e consentimento para marketing, lembrete e pesquisa por WhatsApp — com histórico (quem, quando, texto exibido, IP).
- Prova de aceite imutável: versão do termo, hash do texto, IP e user-agent.
- Direitos da titular: cópia dos dados (com OTP), descadastro por link e pseudonimização a pedido.
- Retenção: clientes inativas há 5 anos são pseudonimizadas; registros de saúde e contratos ficam pelo prazo legal; fichas de pedidos não realizados são apagadas em 90 dias.
- Minimização: feed de agenda da profissional sem dado de saúde; inventário de dados por coluna (o que é apagado, pseudonimizado ou retido).

16. Qualidade e Testes

A suíte tem 2078 testes automatizados (Django test runner), executados no SQLite e no PostgreSQL 18 — onde também são testadas as constraints, triggers, procedures e a paridade das funções SQL com o Python. Há testes de data migrations, de rotas (toda URL mapeada é exercida com cada perfil de acesso) e testes de navegador (Playwright): o wizard de agendamento, a agenda do painel e uma varredura visual de todas as rotas do site, do painel e do portal (desktop no tema claro e celular no escuro) que reprova erro de JavaScript ou de CSP, rolagem lateral no celular, sintaxe de template vazada e violação grave de acessibilidade (axe-core).

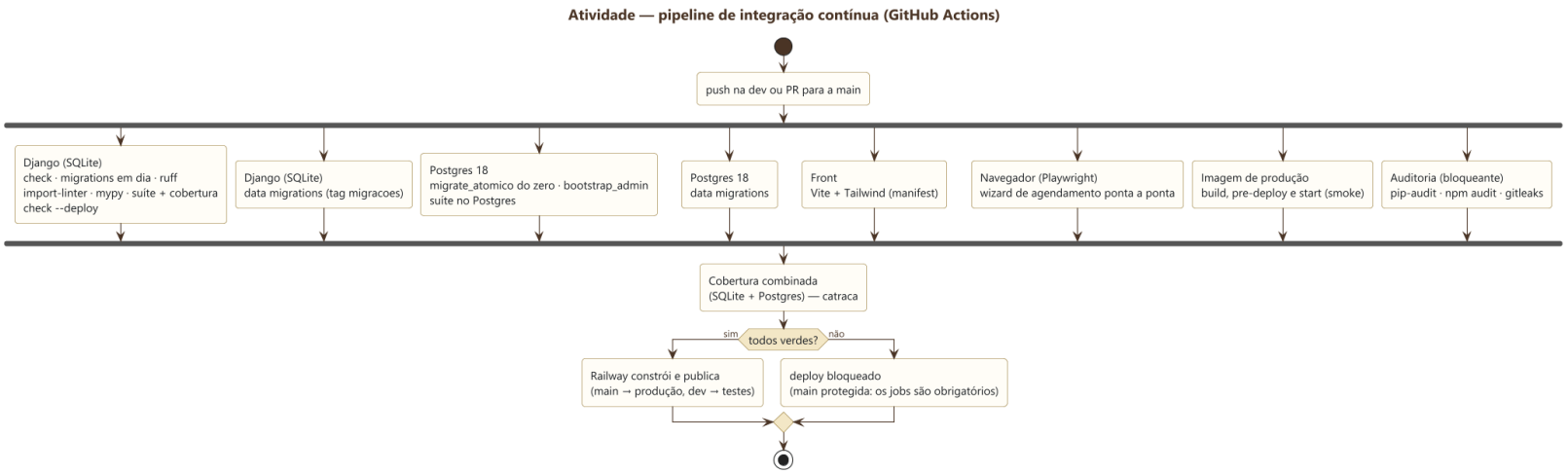


Figura 41 — Atividade — pipeline de integração contínua.

Verificação	Ferramenta	Garante
Estilo e erros	ruff	código sem erro estático; datas sempre com fuso
Camadas	import-linter	utils, db, jobs e comandos nunca importam views
Tipos	mypy (services)	contratos dos casos de uso
Migrations	makemigrations --check	models e banco em dia
Cobertura	coverage (mínimo no CI)	regressão de cobertura bloqueia o merge
Dependências	pip-audit	nenhuma vulnerabilidade conhecida
Navegador	Playwright + axe-core	wizard, agenda e todas as rotas sem erro nem violação grave de acessibilidade
Contrato da API	openapi-spec-validator	OpenAPI 3.1 válido e toda rota JSON documentada

17. Implantação e Operação

A imagem Docker é construída em três estágios (front com Node 22, dependências e runtime Python 3.12 slim, usuário não-root). No Railway, cada environment tem o serviço web e o seu PostgreSQL 18; o pre-deploy aplica todas as migrations numa única transação (migrate_atomico) e o tráfego só muda quando /healthz/ responde. A branch dev publica o ambiente de testes (perfil staging) e a main publica a produção, protegida pelos jobs obrigatórios do CI.

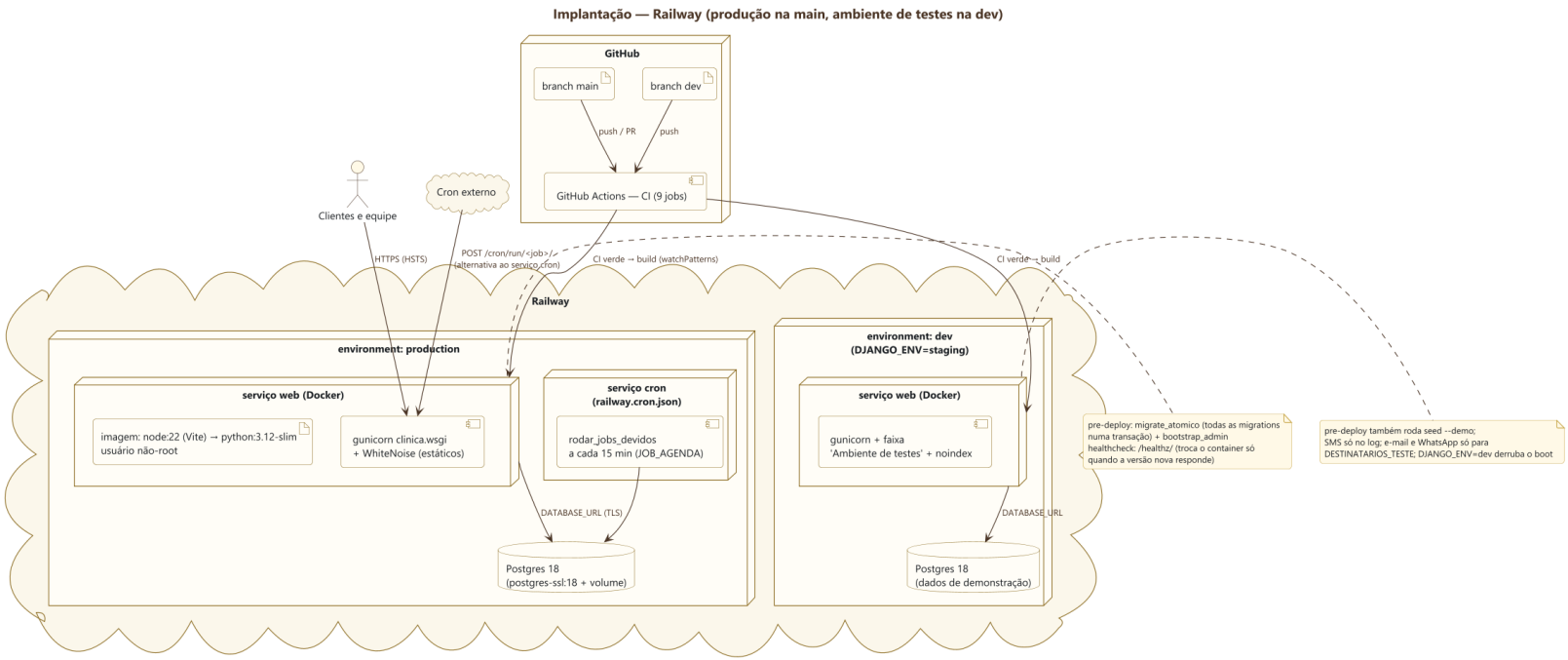


Figura 42 — Implantação — Railway.

Ambiente	Branch / perfil	Características
Desenvolvimento local	DJANGO_ENV=dev	DEBUG, SQLite ou Postgres local, SMS em log
Testes publicado	dev / DJANGO_ENV=staging	igual à produção + travas de envio, faixa e noindex, seed --demo
Produção	main / DJANGO_ENV=prod	HTTPS, Postgres obrigatório, cifragem, 2FA, Sentry

17.1 Rotinas (cron)

Job	Quando	O que faz
emails	a cada 15 min	reenvia a fila de e-mail
lembrete_diario	08:00	lembrete D-1 por WhatsApp (com consentimento)
nps_24h / detrator_alerta	10:00 / 10:30	pesquisa NPS e alerta de nota baixa
limpeza_status	de hora em hora	vence pedido pendente a 1 h do início; lista atendimentos sem desfecho
pacote_expirando / pacote_expirar	07:00 / 00:30	aviso de validade e expiração de pacotes
aniversario	09:00	felicitação (com consentimento de marketing)
lgpd_purgar	domingo 03:00	retenção e pseudonimização
housekeeping / feriados	04:00 / dia 1	limpeza técnica e carga de feriados

18. Rotas

Área	Rota	Função
Site público	/, /quem-somos/, /equipe/, /especialidades/, /galeria/, /depoimentos/, /promocoes/	Páginas institucionais; depoimentos só com autorização + aprovação; promoções com o mesmo preço do agendamento
Site público	/servicos/faciais/, /servicos/corporais/, /servicos/detalhe/<slug>/	Catálogo de serviços
Site público	/contato/, /termos-de-uso/, /politica-de-privacidade/	Contato (e-mail de contato da clínica; captcha, honeypot, limites e teto diário, sem caixa de marketing) e textos legais (a política é o texto do termo LGPD vigente)
Site público	/lista-espera/ (+ sucesso/)	Pedido de aviso de vaga sem criar cadastro (captcha, honeypot, 20/dia por IP)
Site público	/duvidas/	Perguntas frequentes por categoria (a página inicial mostra as 5 em destaque)
Site público	/sitemap.xml, /robots.txt, /manifest.json, /painel/manifest.json, /profissional/manifest.json, /sw.js, /favicon.ico	SEO e PWA (três apps instaláveis: site, painel e agenda da profissional)
Agendamento	/agendamento/, /agendar/<slug>/, /embed/agendar/	Wizard (geral, direto por profissional, widget para iframe)
Agendamento	/ajax/dias-disponiveis/, /ajax/horarios-disponiveis/	Dias do mês e horários livres (SlotService)
Agendamento	POST /agendamento/otp/solicitar/, POST /agendamento/otp/verificar/	Código OTP do celular (Turnstile quando configurado)
Agendamento	POST /agendamento/confirmar/, /agendamento/sucesso/	Grava o atendimento PENDENTE
Cliente	/meus-agendamentos/ (+ otp/enviar/, otp/verificar/, POST sair/)	Área da cliente (código sempre ao celular; também aberta no fim do wizard; sair só por POST)
Cliente	POST /meus-agendamentos/preferencias/, saude/revogar/, pedido/, meus-dados/	Minhas preferências (origem PORTAL), revogar o consentimento de saúde, pedido de correção ou exclusão e baixar meus dados (código de até 10 min)
Cliente	/meus-agendamentos/<id>/reagendar/ (+ <id>/horarios/), POST /ajax/cancelar-agendamento/	Reagendar e cancelar pela sessão do portal (o único caminho da cliente; não há link de reagendar)
Cliente	/confirmar/<token>/, /termo/<token>/, /nps/<token>/ (+ obrigado/)	Confirmar presença (lembrete D-1), aceitar termos, responder NPS (o obrigado oferece a pesquisa)
Cliente	/anamnese/<token>/, /pesquisa/<token>/ (+ obrigado/)	Ficha e pesquisa por link (convites: "Link da ficha" do painel e o fim do NPS)
Cliente	/lgpd/meus-dados/, /lgpd/unsubscribe/<token>/	"Meus dados" (export sem a ficha de saúde, com OTP) e descadastro (o aviso de cookies não grava nada no servidor)
Equipe	/admin-login/, /admin-logout/, /admin-login/recuperar/…	Login da equipe (logout só via POST) e reset de senha
Equipe	/painel/seguranca/2fa/ (+ verificar/, challenge/)	Cadastro e desafio TOTP
Equipe	/profissional/ (+ atendimento/<pk>/{realizado,anotar,aprovar,rejeitar}/, calendario/novo-link/, comissoes/)	Portal do profissional, link do próprio feed iCal e "Minhas comissões"
Infraestrutura	/agenda/<slug>/feed.ics?token=	Feed iCal do profissional
Painel	/painel/, /painel/overview/	Dashboard

Painel	/painel/agendamentos/ (+ novo/, bulk/, <pk>/aprovar|rejeitar|termo-link|ficha-link|valor|desfazer-realizacao/), /painel/atualizar-status/, /painel/retornos/	Agenda em lista (marcadores em lote, "Agendar retorno"), agendamento interno, aprovação um a um e em lote item a item, links do termo e da ficha, valor cobrado, desfazer realização, seletor de status (409 termo_pendente e desfecho_antes_do_inicio), retornos a marcar
Painel	/painel/calendario/ (+ eventos/, mover/)	Calendário com arrastar-e-soltar
Painel	/painel/clientes/, /painel/clientes/<pk>/	Clientes e ficha (pacotes, alertas, autorizações de comunicação, histórico)
Painel	/painel/prontuario/ (+ <cliente_id>/, salvar/), /painel/anotacao/<id>/salvar/	Prontuário com histórico de versões e anotações
Painel	/painel/profissionais/… (+ excecoes/, ics/novo-token/), /painel/bloqueios/…	Profissionais, exceções de agenda, bloqueios e link do feed iCal
Painel	/painel/procedimentos/…, /painel/pacotes/… (+ vender/, compras/<pk>/cancelar/, compras/<pk>/prorrogar/), /painel/promocoes/… (+ disparar/)	Catálogo, pacotes (venda, cancelamento, prorrogação) e promoções (disparo único em lotes)
Painel	/painel/financeiro/?mes=, /painel/comissoes/ (+ <pk>/pagar/, repasse/, repasse/<pk>/, regras/…), /painel/nps/ (+ publicacao/), /painel/exportar-relatorio/?mes=	Financeiro do mês (competência), comissões (baixa, repasse em lote e recibo, regras), NPS e moderação de depoimentos, Excel do mês
Painel	/painel/lista-espera/ (+ notificar/), /painel/anamneses/…, /painel/termos/ (+ criar/, compliance/)	Lista de espera, formulários e termos
Painel	/painel/notificacoes/, /painel/auditoria/, /painel/usuarios/…, /painel/configuracoes/…, /painel/branding/, /painel/email-preview/, /painel/api/ (+ openapi.yaml)	Sistema: notificações, auditoria, usuários, Regras operacionais (registro tipado), Identidade visual (marca e contatos), prévia dos e-mails, documentação da API (Swagger UI do OpenAPI 3.1)
Painel	/webpush/…, /django-admin-sv/	Web Push da equipe e Django admin (só ADMIN com 2FA verificado)
Infraestrutura	GET/POST /api/whatsapp/webhook/, POST /api/zenvia/webhook/	Webhooks autenticados (Meta e Zenvia)
Infraestrutura	POST /cron/run/<job>/	Jobs periódicos (header X-Cron-Token, 30/h por IP; alternativa ao serviço Cron)
Infraestrutura	/healthz/, /health/	Liveness e readiness

19. API (OpenAPI 3.1)

O sistema não expõe uma API REST pública: as telas são renderizadas no servidor. As rotas de máquina — chamadas pelo JavaScript do wizard, do portal da cliente e do painel, pelos provedores (Meta e Zenvia), pelo agendador dos jobs e pelos calendários externos — estão descritas no contrato aranha_estetica/api/openapi.yaml (OpenAPI 3.1.0, 27 caminhos), navegável no Swagger UI do painel (/painel/api/, só a equipe; "Try it out" apenas em GET). Um teste automatizado reprova rota JSON nova sem documentação, caminho que não corresponde à rota do Django e lista de jobs divergente do código.

19.1 Contrato das respostas

Caso	Corpo JSON	Uso
Sucesso	{"ok": true, ...dados}	o front segue com os dados
Erro	{"ok": false, "codigo", "mensagem", ...extra}	o front decide pelo código (estável) e mostra a mensagem
Fora do envelope	formato do provedor / do FullCalendar / text/calendar	webhooks, saúde, eventos do calendário, feed ICS, manifests

19.2 Autenticação

Esquema	Onde	Descrição
sessaoEquipe	cookie: sessionid	Sessão da equipe (papel ADMIN) após /admin-login/ e, quando exigido, o desafio 2FA (TOTP).
sessaoProfissional	cookie: sessionid	Sessão de usuária com papel PROFISSIONAL (portal "Minha agenda").
sessaoCliente	cookie: sessionid	Sessão do portal da cliente aberta pelo código SMS (1 h, presa ao telefone do cadastro).
csrf	header: X-CSRFToken	Token CSRF do Django, lido do formulário da própria página (o cookie csrftoken é HttpOnly).
cronToken	header: X-Cron-Token	Segredo CRON_TOKEN. Nunca na URL (vazaria em log).
assinaturaMeta	header: X-Hub-Signature-256	sha256=<HMAC-SHA256 do corpo com WHATSAPP_APP_SECRET>. Sem o segredo configurado, toda requisição é recusada.
segredoZenvia	header: X-Zenvia-Signature	Segredo estático ZENVIA_WEBHOOK_SECRET (o corpo não é assinado).
tokenFeed	query: token	Token do link de calendário gerado no portal da profissional ou no painel (revogável).

19.3 Operações

Grupo	Operação	Acesso	Descrição
Agendamento online	GET /ajax/dias-disponiveis/	Pública	Dias do mês com expediente para o procedimento
Agendamento online	GET /ajax/horarios-disponiveis/	Pública	Horários livres de um dia, agrupados por horário
Agendamento online	POST /agendamento/otp/solicitar/	Pública	Envia o código de 6 dígitos por SMS
Agendamento online	POST /agendamento/otp/verificar/	Pública	Confere o código e devolve o pré-preenchimento do cadastro
Portal da cliente	POST /meus-agendamentos/otp/enviar/	Pública	Envia o código de login do

			portal
Portal da cliente	POST /meus-agendamentos/otp/verificar/	Pública	Confere o código e abre a sessão do portal
Portal da cliente	GET /meus-agendamentos/{pk}/horarios/	Cliente (sessão SMS)	Horários livres para reagendar um atendimento
Portal da cliente	POST /ajax/cancelar-agendamento/	Cliente (sessão SMS)	Cancela um agendamento pela cliente
Portal da cliente	POST /meus-agendamentos/meus-dados/	Cliente (sessão SMS)	"Baixar meus dados" pela sessão do portal
LGPD	POST /lgpd/meus-dados/	Pública	"Meus dados" do site: pede o código e baixa o export
Painel da equipe	POST /painel/atualizar-status/	Equipe (ADMIN)	Muda o status de um atendimento (select das listas)
Painel da equipe	GET /painel/calendario/eventos/	Equipe (ADMIN)	Eventos do calendário (formato FullCalendar)
Painel da equipe	POST /painel/calendario/mover/	Equipe (ADMIN)	Reagenda pelo arrastar e soltar do calendário
Painel da equipe	POST /painel/anotacao/{atendimento_id}/salvar/	Equipe (ADMIN) ou Profissional	Adiciona anotação clínica a um atendimento
Web Push	GET /webpush/public-key/	Pública	Chave pública VAPID
Web Push	POST /webpush/subscribe/	Equipe (ADMIN)	Registra (ou reativa) a assinatura do navegador
Web Push	POST /webpush/unsubscribe/	Equipe (ADMIN)	Remove a assinatura do navegador
Agenda externa	GET /agenda/{slug}/feed.ics	Token do link	Agenda da profissional como calendário (RFC 5545)
Integrações	GET /api/whatsapp/webhook/	Pública	Verificação do webhook pela Meta
Integrações	POST /api/whatsapp/webhook/	Assinatura HMAC da Meta	Mensagens recebidas no WhatsApp (Meta Cloud API)
Integrações	POST /api/zenvia/webhook/	Segredo da Zenvia	Status de entrega do SMS (Zenvia)
Jobs	POST /cron/run/{job_name}/	X-Cron-Token	Executa um job periódico
Saúde	GET /health/	Pública	Readiness — banco, cache e bundle do front
Saúde	GET /healthz/	Pública	Liveness — processo vivo (healthcheck do Railway)
PWA	GET /manifest.json	Pública	Manifest do site (app da clínica)
PWA	GET /painel/manifest.json	Pública	Manifest do app "Painel" (escopo /painel/)
PWA	GET /profissional/manifest.json	Pública	Manifest do app "Minha agenda" (escopo /profissional/)
Documentação	GET /painel/api/openapi.yaml	Equipe (ADMIN)	Esta especificação (OpenAPI 3.1, YAML)

Glossário

Termo	Significado
Atendimento	Uma sessão marcada (procedimento, profissional, cliente, horário).
Pedido pendente	Agendamento online aguardando a aprovação da profissional.
Cliente de confiança	Já atendida, sem falta em aberto e com menos de 2 horários futuros: o pedido já nasce aprovado.
Retorno	Sessão de acompanhamento sem custo, marcada dentro da janela do procedimento.
Pacote	Conjunto de sessões vendido com validade; os itens são congelados na venda.
Livro-razão	Tabela só de inclusão (crédito, estorno, pagamento): o saldo é a soma dos lançamentos.
OTP	Código de uso único enviado por SMS para provar a posse do celular.
NPS	Net Promoter Score: nota de 0 a 10 de recomendação.
FSM	Máquina de estados finitos que governa o status do atendimento.
Pseudonimização	Substituição dos dados pessoais por valores sem vínculo com a titular, mantendo o histórico.

Histórico de Versões

Versão	Data	Descrição
2.1	21/06/2026	Documento de requisitos + modelagem UML gerado a partir do código (pós-auditoria de backend e migração do front-end para base_v2).
2.2	23/09/2026	Pós-auditoria pré-produção: OTP em todo agendamento, consentimentos com prova de aceite imutável, 2FA obrigatório, histórico do prontuário, agendamento interno, Docker e migração atômica (migrations 0040–0046).
2.3	28/10/2026	Revisão de outubro/2026 (migrations 0047–0061): agenda unificada, links em hash, pacote congelado na venda, comissão como livro-razão, lógica no banco, cifragem do dado de saúde, fila de e-mail e saída do Celery.
3.0	29/10/2026	Documentação técnica completa: UML refeita em PlantUML (casos de uso, classes geradas do código, sequência, estados, atividades, componentes, implantação e ER gerado dos models), arquitetura, segurança/LGPD, qualidade e implantação. Migrations até 0078: aprovação automática de cliente de confiança, matriz de comunicação, retorno marcado com a cliente, sessão de pacote prevista, financeiro por competência e repasse em lote, lembrete por e-mail e NPS a cada 90 dias, retenção de saúde por 20 anos e área da cliente (preferências, revogação, pedidos LGPD), pedido online como caso de uso, remoção de legado (Google Agenda, link antigo, papel RECEPCAO) e endurecimento de segurança.
3.1	29/10/2026	Interface: design system único das telas da equipe (tokens claro/escuro, componentes cotton, agenda em tabela, ficha da cliente em abas), FullCalendar e Chart.js empacotados sem CDN, site com números reais (avaliação, clientes, tratamentos), página de dúvidas, fotos responsivas e varredura visual com axe-core de todas as rotas no CI.
3.2	29/10/2026	API documentada em OpenAPI 3.1 (rotas JSON, webhooks, cron, feed ICS e saúde, com parâmetros, corpos, códigos de erro, autenticação e limites), Swagger UI no painel e teste que reprova rota sem documentação; contrato único das respostas JSON em todas as rotas do app.